



The attached document has been archived and is provided solely for historical purposes.

It may have been superseded by another document (indicated below).

Archived Document

Title:	X.509 Certificate Policy for the Federal Bridge Certification Authority (FBCA) Version 3.2
Publication Date:	July 6, 2023
Archive Date:	November 3, 2023
Archive Notes:	This document has been superseded.

Superseding Document

Title:	X.509 Certificate Policy for the Federal Bridge Certification Authority (FBCA) Version 3.3
Publication Date:	November 3, 2023
URL:	Current Version: https://www.idmanagement.gov/docs/fpki-x509-cert-policy-fbca.pdf

Additional Information

Contact:	fpki@gsa.gov
-----------------	--

Page Reviewed/Updated: November 3, 2023



X.509 Certificate Policy for the Federal Bridge Certification Authority

Version 3.2

July 6, 2023

Signature Page

BALDRIDGE.TIM
.W.1455368100



Digitally signed by
BALDRIDGE.TIM.W.1455368100
Date: 2023.07.31 12:28:49 -05'00'

Co-chair, Federal Public Key Infrastructure Policy Authority

MATTHEW
ARNOLD



Digitally signed by MATTHEW
ARNOLD
Date: 2023.07.31 13:58:27
-04'00'

Co-chair, Federal Public Key Infrastructure Policy Authority

Revision History

Document Version	Document Date	Revision Details
2.1	January 12, 2006	2005-03: Changes to the FBCA CP to modify audit cycle for consistency with Government certification and accreditation process
2.2	September 28, 2006	2006-02: Omnibus Policy Issues Raised During the CertiPath Mapping and e-Auth Business Rules Review
2.3	March 14, 2007	2007-01: Harmonization between Federal Bridge and Common Policy Framework
2.4	June 13, 2007	2007-02: Clarification on multiparty physical access control in Physical Access for CA Equipment
2.5	July 12, 2007	2007-03: SAFE Harmonization Policy Change Recommendations
2.6	August 16, 2007	2007-04: Citizenship/Security Clearance Policy
2.7	September 26, 2007	2007-05: Alignment of Cryptographic Algorithm Requirements with SP 800-78-1
2.8	February 15, 2008	2008-01: Alignment of Cryptographic Algorithm Requirements with NIST Special Publication 800-57
2.9	August 13, 2008	2008-02: Changes to FBCA CP to clarify the archive definition and how its records are intended to be used 2008-03: § 8.3 Assessor's Relationship to Assessed Entity
2.10	October 16, 2008	2008-04: § 1.2 Document Identification

2.11	November 20, 2008	2008-05: Changes to FBCA CP to include a provision for a role-based signature certificate 2008-06: Change to CA Key Usage Period for CAs issuing end user certificates and clarification of organizational responsibilities concerning device certificates
2.12	February 11, 2009	2009-01: Change to the FBCA CP to remove the requirement for backing up the archive
2.13	December 10, 2009	2009-02: Change to the FBCA CP to align key length requirements with SP 800-57
2.14	January 20, 2010	2010-01: Remote Administration of Certification Authorities
2.15	April 8, 2010	2010-02: § 8.1 and 8.4
2.16	May 14, 2010	2010-03: Certificate Policy Updates to Address PIV-I
2.17	June 10, 2010	2010-04: Specify String Format for UUID in serialNumber RDN
2.18	August 15, 2010	2010-05: Addition of the Real ID credential for States to use in meeting FPKI Identity Proofing requirements
2.19	October 15, 2010	2010-06: Digitally Signed Declaration of Identity
2.20	November 18, 2010	2010-07: Legacy use of SHA-1 during the transition period January 1, 2011 to December 31, 2013
2.21	December 16, 2010	2010-08: Clarify requirements to support CA Key Rollover
2.22	January 24, 2011	2011-01: Protection of Subscriber Information 2011-02: Specify requirement for Background Check Refresh

2.23	February 4, 2011	2011-03: Clarify key generation location for PIV-I Key Management certificates
2.24	February 25, 2011	2011-04: Clarify CMS requirements
2.25	December 13, 2011	2011-05: Updates to Certificate Policy to add a New Device Specific Policy (superseded by 2011-07) 2011-06: Remove requirements for Lightweight Directory Access Protocol (LDAP) 2011-07: Updates to Certificate Policy to add two New Device Specific Policies (replaces 2011-05)
2.26	April 26, 2012	2012-01: Clarify RA audit requirements: Insert new Section 1.3.1.6, replace second paragraph in Section 8, add new last sentence to second paragraph of Section 8.4, revise Section 8.6, revise "Policy Management Authority" glossary definition.
2.27	December 2, 2013	2013-01: FBCA CP Clarifications recommended to the FPKIMA during the Annual PKI Compliance Audit. Allow modification of cross-certificates for corrections (Section 4.8.1) and Clarify division of responsibilities between trusted roles (Section 5.2.1). 2013-02: Move SHA-1 policies from Common Policy to FBCA and remove 12/31/2013 restriction on all SHA-1 policies.
2.28	January 14, 2016	2015-01: Clarify assertion of policies for devices. Change to Section 1.2. 2015-02: Align PIV-I card life with FIPS 201-2. Change to Sections 6.2.1, 6.3.2, Appendix A item #10.

2.29	May 20, 2016	2016-01: Added new Section 6.2.1.1; added “Custodial Subscriber Key Stores” to glossary.
2.30	October 5, 2016	2016-02: Allow for Long-Term CRL for retired CA key. Added to Sections 5.6 and 5.8. 2016-03: Allow alternate FBCA key change procedures. Added to Section 5.6.
2.31	June 29, 2017	2017-01: Align with current FPKIMA practice for CA certificates 2017-02: Requires CAs to publish information pertaining to resolved incidents on their websites. 2017-03: Requires CAs to notify the FPKIPA whenever a change is made to their infrastructures 2017-04: Clarifies the period of time PIV-I card stock may continue to be used once it has been removed from the GSA Approved Products List 2017-05: CAs cross certified with the FBCA have a single trust path to the FBCA.
2.32	April 4, 2018	2018-01: Add requirements for key recovery
2.33	May 10, 2018	2018-02: Add reference to Annual Review Requirements 2018-03: Mandate specific ECU in certificates issued after June 30, 2019 2018-04: Certificate revocation requirements for transitive closure after August 15, 2018. 2018-05: Requirements for virtual implementations

2.34	October 4, 2018	2018-06: Incorporate “supervised remote identity proofing” and other new guidance as defined in NIST SP 800-63-3 effective as of October 4, 2018
2.35	April 15, 2019	2019-01: Modifications to allow the FBCA to be operated in an off-line status effective as of April 15, 2019
2.36	May 6, 2022	2022-02. Allows Federally issued PIV-I credentials to leverage cardstock used for PIV issuance, including “pre-printed,” agency seals.
3.0	October 19, 2022	2022-04: Modifications to align with recent applicable updates to Common Policy CP, to include Key Recovery Policy consolidation, updates to Audit and Archive Sections, allowance for containerized technologies, incorporation of electronic authentication capabilities, and definition of in-person antecedent processes. Changes effective as of September 1, 2023.
3.1	April 17, 2023	2023-01: Incorporates changes to multiple sections based on the comments received by the CPWG to include wildcard certificate stipulations, certificate suspension requirements, 3 rd party key recovery request handling, public key parameters, key generation specifics, and remote workstation definition. Changes effective as of September 1, 2023.
3.2	July 6, 2023	2023-03: Clarifies the audit and archive requirements for assignment of Trusted Roles. Additionally, updates certificate operational periods and key usage periods to reflect operational practices. Changes effective immediately.

Table of Contents

1. Introduction	1
1.1 Overview	1
1.1.1 FBCA Certificate Policy (CP)	1
1.1.2 Relationship between the FBCA CP and the FBCA CPS.....	1
1.1.3 Relationship between the FBCA CP and the Entity CP	1
1.1.4 Scope.....	2
1.1.5 Interaction with PKIs External to the Federal Government.....	2
1.2 Document Name and Identification	2
1.3 PKI Participants.....	4
1.3.1 PKI Authorities	4
1.3.1.1 Federal Chief Information Officers Council	4
1.3.1.2 Federal PKI Policy Authority (FPKIPA)	5
1.3.1.3 FPKI Management Authority (FPKIMA)	5
1.3.1.4 FPKI Management Authority Program Manager	5
1.3.1.5 Entity PKI Policy Management Authority	5
1.3.2 Certification Authorities	6
1.3.2.1 Entity Cross-Certified Certification Authority (CA).....	6
1.3.2.2 Federal Bridge Certification Authority (FBCA)	6
1.3.3 Card Management System (CMS)	7
1.3.4 Registration Authority (RA)	7
1.3.5 Certificate Status Servers.....	7
1.3.6 Key Recovery Authorities.....	7
1.3.6.1 Key Escrow Database.....	8
1.3.6.2 Data Decryption Server	8
1.3.6.3 Key Recovery Agent	8
1.3.6.4 Key Recovery Official.....	8
1.3.7 Key Recovery Requestors.....	8
1.3.7.1 Internal Third-Party Requestor.....	8
1.3.7.2 External Third-Party Requestor.....	9
1.3.8 Subscribers	9
1.3.9 Affiliated Organizations.....	9
1.3.10 Relying Parties	9

1.3.11 Other Participants.....	9
1.4 Certificate Usage	10
1.4.1 Appropriate Certificate Uses.....	10
1.4.2 Prohibited Certificate Uses	11
1.5 Policy Administration.....	11
1.5.1 Organization Administering the Document	11
1.5.2 Contact Person	11
1.5.3 Person Determining CPS Suitability for the Policy	11
1.5.4 CPS Approval Procedures.....	12
1.6 Definitions and Acronyms.....	12
2. Publication and Repository Responsibilities.....	13
2.1 Repositories	13
2.2 Publication of Certification Information	13
2.2.1 Publication of Certificates and Certificate Status	13
2.2.2 Publication of CA Information	14
2.3 Time or Frequency of Publication	14
2.4 Access Controls on Repositories	14
3. Identification and Authentication.....	15
3.1 Naming	15
3.1.1 Types of Names	15
3.1.1.1 Subject Names	15
3.1.1.2 Subject Alternative Names	16
3.1.2 Need for Names to Be Meaningful	17
3.1.3 Anonymity or Pseudonymity of Subscribers	17
3.1.4 Rules for Interpreting Various Name Forms	17
3.1.5 Uniqueness of Names	17
3.1.6 Recognition, Authentication, and Role of Trademarks	18
3.2 Initial Identity Validation	18
3.2.1 Method to Prove Possession of Private Key	18
3.2.2 Authentication of Organization Identity	18
3.2.3 Authentication of Individual Identity.....	19
3.2.3.1 Authentication of Human Subscribers	19
3.2.3.2 Authentication of Human Subscribers for Role-based Certificates	22

3.2.3.3	Authentication of Human Subscribers for Group Certificates	23
3.2.3.4	Authentication of Devices	23
3.2.4	Non-verified Subscriber Information.....	24
3.2.5	Validation of Authority	24
3.2.6	Criteria for Interoperation	24
3.3	Identification and Authentication for Re-key Requests	24
3.3.1	Identification and Authentication for Routine Re-key.....	24
3.3.2	Identification and Authentication for Re-key after Revocation.....	25
3.4	Identification and Authentication for Revocation Requests.....	25
3.5	Identification and Authentication for Key Recovery Requests.....	25
3.5.1	KRA Authentication	25
3.5.2	KRO Authentication	26
3.5.3	Subscriber Authentication.....	26
3.5.4	Third-Party Requestor Authentication	26
3.5.5	Data Decryption Server Authentication.....	26
4.	Certificate Life-Cycle Operational Requirements.....	27
4.1	Certificate Application	27
4.1.1	Who Can Submit a Certificate Application	27
4.1.2	Enrollment Process and Responsibilities	27
4.2	Certificate Application Processing	28
4.2.1	Performing Identification and Authentication Functions	28
4.2.2	Approval or Rejection of Certificate Applications	28
4.2.3	Time to Process Certificate Applications	28
4.3	Certificate Issuance	29
4.3.1	CA Actions During Certificate Issuance.....	29
4.3.2	Notification to Subscriber by the CA of Issuance of Certificate	29
4.4	Certificate Acceptance	29
4.4.1	Conduct Constituting Certificate Acceptance.....	29
4.4.2	Publication of the Certificate by the CA.....	29
4.4.3	Notification of Certificate Issuance by the CA to Other Entities	30
4.5	Key Pair and Certificate Usage	30
4.5.1	Subscriber Private Key and Certificate Usage.....	30
4.5.2	Relying Party Public Key and Certificate Usage	30

4.6	Certificate Renewal	30
4.6.1	Circumstance for Certificate Renewal	30
4.6.2	Who May Request Renewal.....	31
4.6.3	Processing Certificate Renewal Requests	31
4.6.4	Notification of New Certificate Issuance to Subscriber	31
4.6.5	Conduct Constituting Acceptance of a Renewal Certificate.....	31
4.6.6	Publication of the Renewal Certificate by the CA	31
4.6.7	Notification of Certificate Issuance by the CA to Other Entities	31
4.7	Certificate Re-key.....	32
4.7.1	Circumstance for Certificate Re-key	32
4.7.2	Who May Request Certification of a New Public Key	32
4.7.3	Processing Certificate Re-keying Requests	32
4.7.4	Notification of New Certificate Issuance to Subscriber	32
4.7.5	Conduct Constituting Acceptance of a Re-keyed Certificate	32
4.7.6	Publication of the Re-keyed Certificate by the CA	33
4.7.7	Notification of Certificate Issuance by the CA to Other Entities	33
4.8	Certificate Modification	33
4.8.1	Circumstance for Certificate Modification	33
4.8.2	Who May Request Certificate Modification.....	33
4.8.3	Processing Certificate Modification Requests	33
4.8.4	Notification of New Certificate Issuance to Subscriber	34
4.8.5	Conduct Constituting Acceptance of Modified Certificate	34
4.8.6	Publication of the Modified Certificate by the CA	34
4.8.7	Notification of Certificate Issuance by the CA to Other Entities	34
4.9	Certificate Revocation and Suspension	34
4.9.1	Circumstances for Revocation	34
4.9.2	Who Can Request Revocation	35
4.9.3	Procedure for Revocation Request.....	36
4.9.4	Revocation Request Grace Period	36
4.9.5	Time within which CA must Process the Revocation Request.....	36
4.9.6	Revocation Checking Requirements for Relying Parties.....	37
4.9.7	CRL Issuance Frequency	37
4.9.8	Maximum Latency for CRLs	38

4.9.9	On-line Revocation/Status Checking Availability	38
4.9.10	On-line Revocation Checking Requirements.....	38
4.9.11	Other Forms of Revocation Advertisements Available	38
4.9.12	Special Requirements Related to Key Compromise	38
4.9.13	Circumstances for Suspension	39
4.9.14	Who Can Request Suspension	39
4.9.15	Procedure for Suspension Request.....	39
4.9.16	Limits on Suspension Period	39
4.10	Certificate Status Services	40
4.10.1	Operational Characteristics	40
4.10.2	Service Availability	40
4.10.3	Optional Features	40
4.11	End Of Subscription	40
4.12	Key Escrow and Recovery	40
4.12.1	Key Escrow and Recovery Policy and Practices	40
4.12.1.1	Key Escrow Process and Responsibilities.....	41
4.12.1.2	Key Recovery Process and Responsibilities	41
4.12.1.2.1	Key Recovery Through KRA.....	42
4.12.1.2.2	Automated Self-Recovery	42
4.12.1.2.3	Key Recovery During Token Issuance.....	42
4.12.1.2.4	Key Recovery by Data Decryption Server	43
4.12.1.3	Who Can Submit a Key Recovery Application.....	43
4.12.1.3.1	Requestor Authorization Validation.....	43
4.12.1.3.2	Subscriber Authorization Validation.....	43
4.12.1.3.3	KRA Authorization Validation	44
4.12.1.3.4	KRO Authorization Validation	44
4.12.1.3.5	Data Decryption Server Authorization Validation	44
4.12.2	Session Key Encapsulation and Recovery Policy and Practices	44
5.	Facility, Management, and Operations Controls.....	45
5.1	Physical Controls.....	45
5.1.1	Site Location and Construction.....	45
5.1.2	Physical Access.....	45
5.1.2.1	Physical Access for CA Equipment	45

5.1.2.2	Physical Access for RA Equipment	46
5.1.2.3	Physical Access for CSS Equipment	46
5.1.2.4	Physical Access for CMS Equipment	47
5.1.2.5	Physical Access for KED Equipment.....	47
5.1.2.6	Physical Access for DDS Equipment	47
5.1.2.7	Physical Access for KRA and KRO Equipment	47
5.1.3	Power and Air Conditioning	47
5.1.4	Water Exposures	47
5.1.5	Fire Prevention and Protection.....	47
5.1.6	Media Storage	47
5.1.7	Waste Disposal.....	47
5.1.8	Off-Site Backup	48
5.2	Procedural Controls	48
5.2.1	Trusted Roles	48
5.2.1.1	Certification Authority Trusted Roles	48
5.2.1.2	Registration Authority Trusted Roles.....	49
5.2.1.3	Key Recovery Trusted Roles.....	49
5.2.1.3.1	Key Recovery Agent (KRA)	49
5.2.1.3.2	Key Recovery Official (KRO)	49
5.2.2	Number of Persons Required per Task	50
5.2.3	Identification and Authentication for Each Role	50
5.2.4	Roles Requiring Separation of Duties.....	50
5.3	Personnel Controls	51
5.3.1	Qualifications, Experience, and Clearance Requirements	51
5.3.2	Background Check Procedures	52
5.3.3	Training Requirements.....	52
5.3.4	Retraining Frequency and Requirements.....	53
5.3.5	Job Rotation Frequency and Sequence	53
5.3.6	Sanctions for Unauthorized Actions	53
5.3.7	Independent Contractor Requirements	53
5.3.8	Documentation Supplied to Personnel.....	53
5.4	Audit Logging Procedures.....	53
5.4.1	Types of Events Recorded	54

5.4.2	Frequency of Processing Log.....	60
5.4.3	Retention Period for Audit Logs.....	61
5.4.4	Protection of Audit Logs.....	61
5.4.5	Audit Log Backup Procedures.....	61
5.4.6	Audit Collection System (Internal vs. External).....	62
5.4.7	Notification to Event-Causing Subject	62
5.4.8	Vulnerability Assessments.....	62
5.5	Records Archival.....	62
5.5.1	Types of Events Archived.....	63
5.5.2	Retention Period for Archive.....	65
5.5.3	Protection of Archive.....	66
5.5.4	Archive Backup Procedures.....	66
5.5.5	Requirements for Time-Stamping of Records	66
5.5.6	Archive Collection System (Internal or External)	67
5.5.7	Procedures to Obtain and Verify Archive Information.....	67
5.6	Key Changeover	67
5.7	Compromise and Disaster Recovery	67
5.7.1	Incident and Compromise Handling Procedures	68
5.7.2	Computing Resources, Software, and/or Data are Corrupted.....	68
5.7.3	Entity (CA) Private Key Compromise Procedures	69
5.7.3.1	CA Private Key Compromise Procedures	69
5.7.3.2	KRS Private Key Compromise Procedures.....	69
5.7.4	Business Continuity Capabilities after a Disaster	70
5.8	CA or RA Termination.....	70
6.	Technical Security Controls.....	71
6.1	Key Pair Generation and Installation	71
6.1.1	Key Pair Generation.....	71
6.1.1.1	CA Key Pair Generation.....	71
6.1.1.2	Subscriber Key Pair Generation	71
6.1.1.3	CSS Key Pair Generation	71
6.1.1.4	PIV-I Content Signing Key Pair Generation	72
6.1.2	Private Key Delivery to Subscriber	72
6.1.3	Public Key Delivery to Certificate Issuer	72

6.1.4	CA Public Key Delivery to Relying Parties	73
6.1.5	Key Sizes	73
6.1.6	Public Key Parameters Generation and Quality Checking	74
6.1.7	Key Usage Purposes (as per X.509 v3 Key Usage Field).....	74
6.2	Private Key Protection and Cryptographic Module Engineering Controls	75
6.2.1	Cryptographic Module Standards and Controls.....	75
6.2.1.1	Custodial Subscriber Key Stores	76
6.2.2	Private Key Multi-Person Control	76
6.2.3	Private Key Escrow.....	77
6.2.4	Private Key Backup	77
6.2.5	Private Key Archival.....	78
6.2.6	Private Key Transfer into or from a Cryptographic Module	78
6.2.7	Private Key Storage on Cryptographic Module.....	79
6.2.8	Method of Activating Private Keys	79
6.2.9	Method of Deactivating Private Keys.....	80
6.2.10	Method of Destroying Private Keys	80
6.2.11	Cryptographic Module Rating	80
6.3	Other Aspects of Key Management	80
6.3.1	Public Key Archival.....	80
6.3.2	Certificate Operational Periods and Key Usage Periods	81
6.4	Activation Data.....	82
6.4.1	Activation Data Generation and Installation.....	82
6.4.2	Activation Data Protection.....	82
6.4.3	Other Aspects of Activation Data	82
6.5	Computer Security Controls	82
6.5.1	Specific Computer Security Technical Requirements	82
6.5.2	Computer Security Rating.....	83
6.6	Life-Cycle Technical Controls	84
6.6.1	System Development Controls	84
6.6.2	Security Management Controls.....	84
6.6.3	Life Cycle Security Controls	84
6.7	Network Security Controls	85
6.8	Time Stamping	85

7. Certificate, CRL, and OCSP Profiles	86
7.1 Certificate Profile	86
7.1.1 Version Number(s).....	86
7.1.2 Certificate Extensions	86
7.1.3 Algorithm Object Identifiers.....	87
7.1.4 Name Forms.....	88
7.1.5 Name Constraints.....	88
7.1.6 Certificate Policy Object Identifier	89
7.1.7 Usage of Policy Constraints Extension.....	89
7.1.8 Policy Qualifiers Syntax and Semantics	89
7.1.9 Processing Semantics for the Critical Certificate Policy Extension	89
7.1.10 Inhibit Any Policy Extension.....	90
7.2 CRL Profile	90
7.2.1 Version Number(s).....	90
7.2.2 CRL and CRL Entry Extensions.....	90
7.3 OCSP Profile	90
7.3.1 Version Number(s).....	90
7.3.2 OCSP Extensions	90
8. Compliance Audit and Other Assessments	91
8.1 Frequency of Audit or Assessments	91
8.2 Identity/Qualifications of Assessor	92
8.3 Assessor's Relationship to Assessed Entity	92
8.4 Topics Covered by Assessment.....	92
8.5 Actions Taken as a Result of Deficiency	92
8.6 Communication of Results	93
9. Other Business and Legal Matters	94
9.1 Fees.....	94
9.1.1 Certificate Issuance/Renewal Fees	94
9.1.2 Certificate Access Fees	94
9.1.3 Revocation or Status Information Access Fee	94
9.1.4 Fees for other Services.....	94
9.1.5 Refund Policy.....	94
9.2 Financial Responsibility	94

9.2.1	Insurance Coverage.....	94
9.2.2	Other Assets	94
9.2.3	Insurance or Warranty Coverage for End-Entities.....	94
9.3	Confidentiality of Business Information	94
9.3.1	Scope of Confidential Information	95
9.3.2	Information not within the Scope of Confidential Information	95
9.3.3	Responsibility to Protect Confidential Information	95
9.4	Privacy of Personal Information.....	95
9.4.1	Privacy Plan	95
9.4.2	Information Treated as Private.....	95
9.4.3	Information not Deemed Private.....	95
9.4.4	Responsibility to Protect Private Information.....	95
9.4.5	Notice and Consent to Use Private Information	96
9.4.6	Disclosure Pursuant to Judicial/Administrative Process.....	96
9.4.7	Other Information Disclosure Circumstances	96
9.5	Intellectual Property Rights.....	96
9.6	Representations and Warranties	96
9.6.1	CA Representations and Warranties	96
9.6.2	RA Representations and Warranties	97
9.6.3	Subscriber Representations and Warranties.....	97
9.6.4	Relying Party Representations and Warranties.....	97
9.6.5	Representations and Warranties of Affiliated Organizations	97
9.6.6	Representations and Warranties of Other Participants	97
9.7	Disclaimers Of Warranties	97
9.8	Limitations of Liability	97
9.9	Indemnities	98
9.10	Term and Termination.....	98
9.10.1	Term.....	98
9.10.2	Termination.....	98
9.10.3	Effect of Termination and Survival	98
9.11	Individual Notices and Communications with Participants	98
9.12	Amendments.....	98
9.12.1	Procedure for Amendment.....	98

9.12.2 Notification Mechanism and Period	98
9.12.3 Circumstances under which OID must be Changed	98
9.13 Dispute Resolution Provisions	99
9.14 Governing Law	99
9.15 Compliance with Applicable Law	99
9.16 Miscellaneous Provisions	99
9.16.1 Entire Agreement	99
9.16.2 Assignment	99
9.16.3 Severability	99
9.16.4 Enforcement (Attorneys' Fees and Waiver of Rights)	99
9.16.5 Force Majeure	99
9.17 Other Provisions	99
Appendix A: PIV-Interoperable Smart Card Definition	100
Appendix B: Card Management System Requirements	102
Appendix C: In-Person Antecedent	104
Appendix D: References	106
Appendix E: Acronyms and Abbreviations	109
Appendix F: Glossary	113

1. INTRODUCTION

This Certificate Policy (CP) defines a number of distinct certificate policies for use by the Federal Bridge Certification Authority (FBCA) to facilitate interoperability between cross-certified Entity PKI domains in a peer-to-peer fashion. The FBCA certificates issued to Entity CAs define trust through use of the *policyMappings* extension in the certificates.

Each policy defines an assurance level which refers to the strength of the binding between the public key and the subject of the certificate, the mechanisms used to control the use of the private key, and the security provided by the PKI itself.

Where a specific policy is not stated, the requirements in this CP apply equally to all policies.

In this document, the term “device” means a non-person entity, i.e., a hardware device or software application.

A Key Recovery System (KRS) may be supported by Entity CAs that issue key management certificates. The KRS provides the computer system hardware, software, staff, and procedures to escrow private keys securely and recover them when appropriate.

Any use of or reference to this CP beyond the context of the Federal PKI (FPKI) is at the risk of the relying party.

This CP follows the RFC 3647 framework.

1.1 OVERVIEW

1.1.1 FBCA Certificate Policy (CP)

FBCA certificates contain one or more registered certificate policy object identifiers (OID), which may be used by a relying party to decide whether a certificate is trusted for a particular purpose. Each OID corresponds to a specific level of assurance established by this Certificate Policy (CP).

1.1.2 Relationship between the FBCA CP and the FBCA CPS

This CP states the requirements for the issuance and management of certificates issued by the FBCA, and requirements for the operation of the FBCA. The FBCA Certification Practice Statement (CPS) states how the FBCA implements the requirements.

1.1.3 Relationship between the FBCA CP and the Entity CP

This CP establishes criteria for cross-certification with Entity CAs. The FPKI Policy Authority maps Entity CP(s) to one or more of the policies in the FBCA CP. The relationship between an Entity CP and the FBCA CP is asserted in the *policyMappings* extension of the CA certificates issued to the Entity CA by the FBCA.

Entities may undertake a similar mapping process and issue a cross-certificate to the FBCA asserting the relationship of their policies to the policies defined in this CP.

1.1.4 Scope

The FBCA exists to facilitate trusted electronic business transactions for Federal organizations. To facilitate the missions of the organizations, interoperability is offered to non-Federal entities. The generic term “entity” applies equally to Federal organizations and other organizations owning or operating PKI domains. As used in this CP, Entity PKI or Entity CA may refer to an organization’s PKI, a PKI provided by a commercial service, or a bridge CA serving a community of interest.

1.1.5 Interaction with PKIs External to the Federal Government

The FBCA will extend interoperability to non-Federal entities only when it is beneficial to the Federal Government.

1.2 DOCUMENT NAME AND IDENTIFICATION

This is the X.509 Certificate Policy for the FBCA.

Certificates issued by the FBCA will assert at least one of the following OIDs in the *certificatePolicies* extension. Entity CAs may assert these OIDs only in *policyMappings* extensions of certificates issued to the FBCA.

id-fpki-certpcy-rudimentaryAssurance	::= {2 16 840 1 101 3 2 1 3 1}
id-fpki-certpcy-basicAssurance	::= {2 16 840 1 101 3 2 1 3 2}
id-fpki-certpcy-mediumAssurance	::= {2 16 840 1 101 3 2 1 3 3}
id-fpki-certpcy-mediumHardware	::= {2 16 840 1 101 3 2 1 3 12}
id-fpki-certpcy-medium-CBP	::= {2 16 840 1 101 3 2 1 3 14}
id-fpki-certpcy-mediumHW-CBP	::= {2 16 840 1 101 3 2 1 3 15}
id-fpki-certpcy-mediumDevice	::= {2 16 840 1 101 3 2 1 3 37}
id-fpki-certpcy-mediumDeviceHardware	::= {2 16 840 1 101 3 2 1 3 38}
id-fpki-certpcy-highAssurance	::= {2 16 840 1 101 3 2 1 3 4}
id-fpki-certpcy-pivi-hardware	::= {2 16 840 1 101 3 2 1 3 18}
id-fpki-certpcy-pivi-cardAuth	::= {2 16 840 1 101 3 2 1 3 19}
id-fpki-certpcy-pivi-contentSigning	::= {2 16 840 1 101 3 2 1 3 20}

Human Subscriber Certificates

Certificates valid for the following policies are issued to Human Subscribers:

PIV-I Authentication certificate	id-fpki-certpcy-pivi-hardware
Digital Signature certificate with the private key generated on a PIV-I credential	id-fpki-certpcy-mediumHardware
Key Management certificate associated with a PIV-I credential	id-fpki-certpcy-mediumAssurance id-fpki-certpcy-mediumHardware
All other hardware-based certificates	id-fpki-certpcy-mediumHW-CBP id-fpki-certpcy-mediumHardware id-fpki-certpcy-highAssurance*
All software-based certificates	id-fpki-certpcy-rudimentaryAssurance id-fpki-certpcy-basicAssurance id-fpki-certpcy-medium-CBP id-fpki-certpcy-mediumAssurance

* reserved for U.S. Federal government entity PKI operation and use

The requirements associated with id-fpki-certpcy-pivi-hardware are identical to id-fpki-certpcy-mediumHardware except where specifically noted in the text and further described in Appendix A.

The requirements associated with the id-fpki-certpcy-medium-CBP (commercial best practice) policy are identical to those defined for the id-fpki-certpcy-mediumAssurance policy except for personnel security requirements (see Section 5.3.1).

The requirements associated with the id-fpki-certpcy-mediumHardware policy are identical to those defined for the id-fpki-certpcy-mediumAssurance policy except for subscriber cryptographic module requirements (see Section 6.2.1).

The requirements associated with the id-fpki-certpcy-mediumHW-CBP policy are identical to those defined for the id-fpki-certpcy-mediumHardware policy except for personnel security requirements (see Section 5.3.1).

Personal Identity Verification Interoperable (PIV-I) Device Subscriber Certificates

Certificates valid for the following policies are issued to Device Subscribers and are limited to use with PIV-I credentials by this policy.

Card Authentication certificate with the private key on a PIV-I credential	id-fpki-certpcy-pivi-cardAuth
Content Signing certificate used to sign PIV-I data objects	id-fpki-certpcy-pivi-contentSigning

The requirements associated id-fpki-certpcy-pivi-contentSigning are identical to id-fpki-certpcy-mediumHardware except where specifically noted in the text and further described in Appendix A.

In addition, the id-fpki-certpcy-pivi-contentSigning policy is reserved for certificates used by the Card Management System (CMS) to sign the PIV-I card security objects.

Additional Device Subscriber Certificates

FIPS 140 Level 2 or higher hardware cryptographic modules	id-fpki-certpcy-mediumDeviceHardware
FIPS 140 Level 1 or higher cryptographic modules	id-fpki-certpcy-mediumDevice

The requirements associated with the id-fpki-certpcy-mediumDevice and id-fpki-certpcy-mediumDeviceHardware policies are identical to those defined for the id-fpki-certpcy-mediumAssurance and id-fpki-certpcy-mediumHardware policies, respectively, except for identity proofing, re-key, and activation data.

1.3 PKI PARTICIPANTS

The following are roles relevant to the administration and operation of the FBCA and the relationships with cross-certified Entities.

1.3.1 PKI Authorities

1.3.1.1 Federal Chief Information Officers Council

The Federal Chief Information Officer (CIO) Council comprises the Chief Information Officers of all cabinet level departments and other independent agencies. The Federal CIO Council has established the framework for the interoperable Federal PKI (FPKI) and oversees the operation of the organizations responsible for governing and promoting its use. In particular, this CP was established under the authority and approval of the Federal CIO Council.

1.3.1.2 Federal PKI Policy Authority (FPKIPA)

The Federal Public Key Infrastructure Policy Authority (FPKIPA) is a sub-council comprised of U.S. Federal Government agency representatives and is chartered under the Federal Chief Information Security Officer (CISO) Council, under the Federal CIO Council. The FPKIPA owns this certificate policy and represents the interest of the Federal CIOs and Federal CISOs.

The FPKIPA is responsible for:

- Maintaining this CP,
- Approving applications from Entities requesting cross-certification with the FBCA,
- Ensuring the legitimacy of the applicant organization and the authority of designated individuals to act on behalf of the Entity,
- Determining the mappings between certificates issued by applicant Entity CAs and the policies defined in the FBCA CP (which will include objective and subjective evaluation of the respective CP contents and any other facts deemed relevant by the FPKIPA), and
- After an Entity is cross-certified with the FBCA, ensuring continued conformance.

The FPKIPA will execute a Memorandum of Agreement (MOA) with each cross-certified Entity setting forth the respective responsibilities and obligations of both parties and the mappings between the applicable certificate policies contained in this CP and those in the Entity CP.

1.3.1.3 FPKI Management Authority (FPKIMA)

The FPKIMA is the government program that operates and maintains the Federal PKI operational environment on behalf of the U.S. Government.

1.3.1.4 FPKI Management Authority Program Manager

The Program Manager is the individual within the FPKIMA who has principal responsibility for overseeing the operation of the Federal Bridge CA, including the required repository, and selecting the FPKIMA staff. For additional personnel security controls associated with this role see Section 5.3.1.

1.3.1.5 Entity PKI Policy Management Authority

Entity PKIs that are cross-certified with the Federal Bridge CA must identify an individual or group that is responsible for maintaining the entity PKI CP and for ensuring that all Entity PKI components are operated in compliance with the entity PKI CP. Cross-certified Bridges must ensure member PKIs are operated comparably with the Bridge PKI CP.

The Entity PKI PMA is responsible for notifying the FPKIPA of any change to the infrastructure that has the potential to affect the FPKI operational environment at least two weeks prior to implementation; all new artifacts (CA certificates, Certificate Revocation List Distribution Point (CRLDP), Authority Information Access (AIA) and/or Subject Information Access (SIA) URLs, etc.) produced as a result of the change must be provided to the FPKIPA within 24 hours following implementation.

1.3.2 Certification Authorities

The CA is the collection of hardware, software and operating personnel that create, sign, and issue public key certificates to Subscribers. The CA is responsible for issuing and managing certificates including:

- The certificate manufacturing process
- Publication of certificates
- Revocation of certificates
- Generation and destruction of CA signing keys
- Ensuring that all aspects of the CA services, operations, and infrastructure related to certificates issued under this CP are performed in accordance with the requirements, representations, and warranties of this CP.

CA and related applications (e.g., OCSP, CMS, and KRS) may be hosted on one or more system software layers. Operational and technical security controls including audit logging requirements specified in this CP apply to all system software layers, where appropriate and applicable.

1.3.2.1 Entity Cross-Certified Certification Authority (CA)

The Entity designates at least one CA within its PKI to receive a cross-certificate from the FBCA. This document refers to this CA as the Entity cross-certified CA. In addition, this CP may refer to CAs that are “subordinate” to the Entity cross-certified CA. The use of the term “subordinate CA” shall encompass any CA under the control of the Entity that is subordinate to the cross-certified CA.

The Entity must ensure that no CA under its PKI shall have more than one trust path to the FBCA.

1.3.2.2 Federal Bridge Certification Authority (FBCA)

The FBCA is operated by the FPKIMA and is authorized by the FPKIPA to create, sign, and issue public key certificates. As operated by the FPKIMA, the FBCA is responsible for all aspects of the issuance and management of a certificate including:

- The certificate manufacturing process,
- Publication of certificates,
- Revocation of certificates,
- Re-key of FBCA signing material, and
- Ensuring that all aspects of the FBCA services and FBCA operations and infrastructure related to certificates issued under this CP are performed in accordance with the requirements, representations, and warranties of this CP.

1.3.3 Card Management System (CMS)

The Card Management System is responsible for managing smart card token content. In the context of this policy, the CMS requirements are associated with the PIV-I policies only. Entity CAs issuing PIV-I certificates are responsible for ensuring that all CMSs meet the requirements described in this document, including all requirements specified in Appendix B. In addition, the CMS must not be issued any certificates that express the id-fpki-certpcy-pivi-hardware or id-fpki-certpcy-pivi-cardAuth policy OID.

1.3.4 Registration Authority (RA)

A Registration Authority (RA) is an entity authorized by the CA to collect, verify, and submit information provided by potential Subscribers for the purpose of issuing public key certificates. The term RA refers to hardware, software, and individuals that may collectively perform this function. Individuals performing RA functions are acting in a Trusted Role, and are considered Officers as defined in Section 5.2.1. The RA is responsible for:

- Control over the registration process.
- The identification and authentication process.

The FPKIPA acts as the Trusted Agent for the FBCA. Entity CAs designate their own RAs.

A Trusted Agent is authorized by a CA to act on its behalf and may record information from and verify biometrics (e.g., photographs) on presented credentials on behalf of an RA for Applicants who cannot appear in person. Trusted Agents are not Trusted Roles.

1.3.5 Certificate Status Servers

PKIs may optionally include an authority that provides status information about certificates on behalf of a CA through online transactions. PKIs may include Online Certificate Status Protocol (OCSP) responders to provide online status information. Such an authority is termed a Certificate Status Server (CSS). Where the CSS is identified in certificates as an authoritative source for revocation information, the operations of that authority are considered within the scope of this CP. Examples include OCSP servers that are identified in the AIA extension. OCSP servers that are locally trusted, as described in RFC 6960, are not covered by this policy. Entity CAs that issue PIV-I certificates must provide an OCSP responder.

1.3.6 Key Recovery Authorities

For organizations that have implemented Key Recovery, the applicable requirements for physical, personnel, and procedural security controls, technical security controls, and Compliance Audit apply as follows:

- CA requirements apply to the KED and to the DDS
- RA requirements apply to the KRA and KRA automated systems
- RA requirements apply to the KRO and KRO automated systems, when the KRO has privileged access to the KED

1.3.6.1 Key Escrow Database

The KED is defined as the function, system, or subsystem that maintains the key escrow repository and responds to key registration requests. The KED also responds to key recovery requests from two or more KRAs or self-recovery by a current subscriber.

Section 5.2.1.2 contains the description of Trusted Roles required to operate the KED.

1.3.6.2 Data Decryption Server

A DDS is an automated system that has the capability to obtain subscriber private keys from the KED or another DDS for data monitoring or other purposes (e.g., email inspection). DDSs do not provide keys to Subscribers or other Third-Party Requestors. A DDS has access to escrowed key management keys and must meet all security requirements of the KED as outlined in this policy.

Implementation of a DDS is optional based on organizational operations.

1.3.6.3 Key Recovery Agent

A KRA is an individual who is authorized, as specified in the applicable Practice Statement (KRPS or CPS), to recover an escrowed key. The KRAs send the recovered key to the KRO or directly to the Requestor. The KRAs have high level, sensitive access to the KED and are considered Trusted Roles (see Section 5.2.1). KRAs can recover large numbers of keys, the number and location of KRAs should be closely controlled.

KRAs may additionally conduct requestor identity verification and authorization validation when KROs are not used.

1.3.6.4 Key Recovery Official

A Key Recovery Official (KRO) may optionally be used to support identity verification and authorization validation tasks.

1.3.7 Key Recovery Requestors

A Requestor is the person or DDS that requests the recovery of a decryption private key. A Requestor may be the Subscriber or a third-party (e.g., supervisor, corporate officer, or law enforcement officer) authorized to request recovery of a Subscriber's escrowed key on behalf of the Subscriber or on behalf of the organization. Any individual who can demonstrate a verifiable authority and a need to obtain a recovered key may be considered a Requestor.

1.3.7.1 Internal Third-Party Requestor

An Internal Third-Party Requestor is any Requestor who is in the Subscriber's supervisory chain or otherwise authorized to obtain the Subscriber's key for the Issuing Organization (i.e., the organization on behalf of which the CA issues certificates to subscribers).

1.3.7.2 External Third-Party Requestor

An External Third-Party Requestor is someone (e.g., investigator) outside the Issuing Organization with a court order or other legal instrument to obtain the decryption private key of the Subscriber.

1.3.8 Subscribers

A Subscriber is the entity whose name appears as the subject in a certificate. The term “Subscriber” as used in this document refers only to those who request certificates for uses other than signing and issuing certificates or certificate status information. A Subscriber may be referred to as an “Applicant” after applying for a certificate, but before the certificate issuance procedure is completed.

There is a subset of Human Subscribers who will be issued role-based certificates. These certificates identify a specific role on behalf of which the Subscriber is authorized to act rather than the Subscriber’s name. These certificates are issued in the interest of supporting accepted business practices. The role-based certificate can be used in situations where non-repudiation is desired. Normally, it will be issued in addition to an individual Subscriber certificate. A specific role may be identified in certificates issued to multiple Subscribers; however, the key pair will be unique to each individual role-based certificate. For example, there may be four individuals with a certificate issued in the role of “Watch Commander”. However, each of the four certificates will have unique keys and certificate serial numbers.

1.3.9 Affiliated Organizations

Subscriber certificates may be issued on behalf of an organization, other than the organization operating the Entity PKI, that has a relationship with the subscriber; this is termed affiliation. The organizational affiliation will be indicated in the certificate. Affiliated Organizations are responsible for verifying the affiliation at the time of certificate application and requesting revocation of the certificate if the affiliation is no longer valid.

1.3.10 Relying Parties

A relying party is the entity that relies on the validity of the binding of the Subscriber’s identity to a public key. The relying party is responsible for deciding whether or how to check the validity of the certificate by checking the appropriate certificate status information. The relying party can use the certificate to verify the integrity of a digitally signed message, to identify the creator of a message, or to establish confidential communications with the holder of the certificate’s private key. A relying party may use information in the certificate (such as certificate policy identifiers, key usage, or extended key usage) to determine its appropriate usage.

For this certificate policy, the relying party may be any entity that wishes to validate the binding of a public key to the name of a Subscriber.

1.3.11 Other Participants

CAs may require the services of other security, community, and application authorities, such as compliance auditors.

1.4 CERTIFICATE USAGE

1.4.1 Appropriate Certificate Uses

Subscriber certificates issued by Entity CAs may be used for authentication, key management, signature, and confidentiality requirements. The sensitivity of the information processed or protected using certificates issued by FBCA or an Entity CA will vary significantly. To provide sufficient granularity, this CP specifies security requirements at six different levels of assurance: Rudimentary, Basic, Medium, PIV-I Card Authentication, Medium Hardware, and High.

Relying Parties make risk-informed decisions when certificates are used to manage the identities of systems and users by evaluating the environment, associated threats, and vulnerabilities. This evaluation is done by the relying party and is not controlled by this CP. The following table provides additional guidance for determining which policy may be most appropriate based on the sensitivity of the information processed or protected using these certificates. These descriptions are intended as guidance and are not binding.

Assurance Level	Appropriate Certificate Uses
Rudimentary	This level provides the lowest degree of assurance concerning identity of the individual. One of the primary functions of this level is to provide data integrity to the information being signed. This level is relevant to environments in which the risk of malicious activity is considered to be low. It is not suitable for transactions requiring authentication, and is generally insufficient for transactions requiring confidentiality, but may be used for the latter where certificates having higher levels of assurance are unavailable.
Basic	This level provides a basic level of assurance relevant to environments where there are risks and consequences of data compromise, but they are not considered to be of major significance. This may include access to private information where the likelihood of malicious access is not high. It is assumed at this security level that users are not likely to be malicious.
Medium	This level is relevant to environments where risks and consequences of data compromise are moderate. This may include transactions having substantial monetary value or risk of fraud, or involving access to private information where the likelihood of malicious access is substantial. This level of assurance includes the following certificate policies: Medium, Medium CBP, and Medium Device.
PIV-I Card Authentication	This level is relevant to environments where risks and consequences of data compromise are moderate. This may include contactless smart card readers where use of an activation PIN is not practical.

Assurance Level	Appropriate Certificate Uses
Medium Hardware	This level is relevant to environments where threats to data are high or the consequences of the failure of security services are high. This may include very high value transactions or high levels of fraud risk. This level of assurance includes the following certificate policies: Medium Hardware, Medium Hardware CBP, Medium Device Hardware, PIV-I Hardware, and PIV-I Content Signing.
High	This level is reserved for cross-certification with government entities and is appropriate for those environments where the threats to data are high, or the consequences of the failure of security services are high. This may include very high value transactions or high levels of fraud risk.

Federal relying parties should review more detailed guidance governing the use of electronic signatures (which include the use of digital certificates) issued by the Office of Management and Budget, as well as more detailed subordinate guidance issued by other agencies pursuant to OMB direction (such as NIST Federal Information Processing Standards and Special Publications).

1.4.2 Prohibited Certificate Uses

Certificates that map to id-fpki-certpcy-pivi-cardAuth must be used only to authenticate the hardware token containing the associated private key and must not be interpreted as authenticating the presenter or holder of the token.

1.5 POLICY ADMINISTRATION

1.5.1 Organization Administering the Document

The FPKIPA is responsible for all aspects of this CP.

1.5.2 Contact Person

Contact information for the support and co-chairs for the FPKIPA is fpki@gsa.gov.

1.5.3 Person Determining CPS Suitability for the Policy

The Certification Practices Statement must conform to the corresponding Certificate Policy. The FPKIPA is responsible for asserting whether the FBCA CPS conforms to this CP. Entities must designate the person or organization that asserts that their CPS(s) conforms to their CP(s).

In each case, the determination of suitability must be based on an independent compliance auditor's results and recommendations. See Section 8 for further details.

1.5.4 CPS Approval Procedures

The FPKIMA submits the FBCA CPS and the results of a compliance audit to the FPKIPA for approval. The FBCA must meet all facets of the policy. The FPKIPA does not issue waivers.

Entity CAs must submit their CPS and the results of their compliance audit to the appropriate authority (See Section 1.5.3) for approval. An Entity CA's CPS is required to meet all facets of its policy. Waivers, while discouraged, may be permitted in order to meet urgent unforeseen operational requirements. Any waivers issued by Entity CAs are considered changes to the corresponding CP and may result in revocation of the cross-certificate by the FPKIPA.

1.6 DEFINITIONS AND ACRONYMS

See Appendix D and Appendix E.

2. PUBLICATION AND REPOSITORY RESPONSIBILITIES

2.1 REPOSITORIES

The publicly accessible repository system must be designed and implemented to provide 99% availability overall and limit scheduled down-time to 0.5% annually.

2.2 PUBLICATION OF CERTIFICATION INFORMATION

2.2.1 Publication of Certificates and Certificate Status

CA and End Entity certificates must contain valid Uniform Resource Identifiers (URIs) that are publicly accessible, for the purposes of certification path building and for revocation checking.

All CAs that issue CA certificates must publish all CA certificates it issues in a file available via a publicly accessible HTTP URI. This URI must be asserted in the Subject Information Access (SIA) extension in all valid certificates issued to the CA. The file must be a certs-only Cryptographic Message Syntax file that has an extension of .p7c.

With the exception of self-signed certificates, all CA certificates must be published by the Subject CA in a file available via a publicly accessible HTTP URI. This URI must be asserted in the Authority Information Access (AIA) extension in all valid certificates issued by the Subject CA. The file must be:

- a certs-only Cryptographic Message Syntax file that has an extension of .p7c, or
- a single DER encoded certificate that has an extension of .cer

The certs-only Cryptographic Message Syntax format is preferred as it allows flexibility for inclusion of multiple certificates.

CAs must publish the latest CRL covering all unexpired certificates via a publicly accessible HTTP URI until such time as all issued certificates have expired. This URI must be asserted in the CRL distribution point extension of all certificates issued by that CA, except for OCSP responder certificates that include the id-pkix-ocsp-nocheck extension.

A CSS provides status information about certificates on behalf of a CA through on-line transactions.

CAs that support PIV-I must include a CSS in the form of a delegated Online Certificate Status Protocol (OCSP) service, as described in [RFC 6960], to provide on-line status information for Subscriber certificates via a publicly accessible HTTP URI in the AIA extension. The operations of the OCSP service are within the scope of this CP.

Pre-generated OCSP responses may be created by the CSS and distributed to OCSP servers. OCSP responses, like CRLs, are publicly distributable data. OCSP servers that lack OCSP response signing capability have the same security requirements as a repository hosting CRLs.

OCSP services that are locally trusted, as described in [RFC 6960], are not covered by this policy.

2.2.2 Publication of CA Information

This CP, the FBCA CPS and the annual PKI Compliance Audit Letter for the FBCA are publicly available on <https://www.idmanagement.gov/governance/fpkiaudit/>.

Entity CPs must be available in public repositories.

2.3 TIME OR FREQUENCY OF PUBLICATION

This CP and any subsequent changes are made publicly available within thirty (30) days of approval.

Publication requirements for CRLs are provided in Sections 4.9.7 and 4.9.12.

2.4 ACCESS CONTROLS ON REPOSITORIES

Repositories hosting CA certificates, CRLs, and pre-generated OCSP responses (if implemented) must be publicly accessible. Information not intended for public dissemination or modification must be protected.

Posted certificates, CRLs, and pre-generated OCSP responses may be replicated in additional repositories for performance enhancement.

3. IDENTIFICATION AND AUTHENTICATION

3.1 NAMING

3.1.1 Types of Names

This CP establishes requirements for both subject distinguished names and subject alternative names.

CA certificates must contain a non-null subject Distinguished Name (DN). All RA certificates must include a non-NULL subject DN. This CP does not restrict the types of names that can be used.

The table below specifies the naming requirements that apply to each level of assurance.

Assurance Level	Naming Requirements
Rudimentary	Non-Null Subject Name, or Null Subject Name if Subject Alternative Name is populated and marked critical
Basic	Non-Null Subject Name, and optional Subject Alternative Name if marked non-critical
Medium (all policies)	Non-Null Subject Name, and optional Subject Alternative Name if marked non-critical
PIV-I Card Authentication	Non-Null Subject Name, and Subject Alternative Name
High	Non-Null Subject Name, and optional Subject Alternative Name if marked non-critical

3.1.1.1 Subject Names

Certificates issued to Subscribers must include distinguished names that are comprised of a base distinguished name (Base DN) and additional relative distinguished names (RDNs). The Entity CP must define the permitted Base DN(s).

A Device Subscriber name must be a unique name for the device and must not take the form of a Human Subscriber name.

Role-based and group certificates may be issued under any non-PIV-I human subscriber policy.

- Role-based certificates identify a specific role on behalf of which one or more subscribers are authorized to act rather than the subscriber's name. Where the organization is implicit in the role, it may be omitted. Where the role alone is ambiguous, the organization must be present in the DN.

- The subjectName DN in a group certificate must not imply that the subject is a single individual, e.g., by inclusion of a human name form

For PIV-I Card Authentication subscriber certificates, use of the subscriber's common name is prohibited, instead a serialNumber=UUID is required.

The UUID must be encoded within the serialNumber attribute using the UUID string representation defined in Section 3 of RFC 4122.

PIV-I Hardware certificates may be issued to individuals external to the entity operating the CA. Such individuals may or may not be affiliated with an organization. In these cases, the PIV-I Hardware certificates must indicate whether or not the Subscriber is associated with an Affiliated Organization by taking one of the following forms:

For PIV-I Hardware certificates with an Affiliated Organization:

cn=Subscriber's full name, ou=Affiliated Organization Name, {Base DN}

For PIV-I cardAuth certificates with an Affiliated Organization:

serial number=UUID, ou=Affiliated Organization Name, {Base DN}

For PIV-I Hardware certificates with no Affiliated Organization:

cn=Subscriber's full name, ou=Unaffiliated, ou=Entity CA's Name, {Base DN}

For PIV-I cardAuth certificates with no Affiliated Organization:

serial number=UUID, ou=Unaffiliated, ou=Entity CA's Name, {Base DN}

This requirement does not apply to CAs that issue PIV-I certificates only to a single organization, designated in the CA issuer name.

PIV-I Content Signing certificates must clearly indicate the organization administering the CMS.

3.1.1.2 Subject Alternative Names

PIV-I Hardware and PIV-I Card Authentication certificates must include a subject alternate name extension, containing a UUID value encoded as a URI as specified in Section 3 of [RFC 4122].

PIV-I Card Authentication certificates must not include any other name in the subject alternative name extension.

Subscriber certificates that contain id-kp-emailProtection in the EKU must include a subject alternative name extension that includes a rfc822Name.

For Device Subscriber certificates that assert serverAuth in the Extended Key Usage, wildcard domain names are permitted in the dNSName value only if all sub-domains covered by the

wildcard fall within the same application, cloud service, or system boundary within the scope of the sponsoring organization.

3.1.2 Need for Names to Be Meaningful

Names used in the certificates issued by CAs must identify the person or object to which they are assigned in a meaningful way.

The common name in the distinguished name must represent the Subscriber in a way that is easily understandable for humans. For Human Subscribers, this will typically be a legal name.

When DNs are used, the directory information tree must accurately reflect organizational structures.

When DNs are used, the common name must respect name space uniqueness requirements and must not be misleading. This does not preclude the use of pseudonymous certificates as defined in Section 3.1.3. The subject name in CA certificates must match the issuer name in certificates issued by the CA, as required by [RFC 5280].

3.1.3 Anonymity or Pseudonymity of Subscribers

CA certificates must not contain anonymous or pseudonymous identities.

The FBCA does not issue anonymous certificates. Pseudonymous certificates may be issued by the FBCA to support internal operations.

DNs in subscriber certificates issued by Entity CAs may contain a pseudonym (such as a large number) as long as name space uniqueness requirements are met.

CAs may issue role-based or group certificates that identify subjects by their organizational roles. Each identified 'role' or 'group' must meet name space uniqueness requirements.

3.1.4 Rules for Interpreting Various Name Forms

Rules for interpreting distinguished name forms are specified in [X.501].

Rules for interpreting e-mail addresses are specified in [RFC 5322].

Rules for interpreting PIV-I certificate UUID names are specified in [RFC 4122].

Entity CAs may specify additional rules for interpreting names in Subscriber certificates in the Entity CP or a referenced certificate profile. (The rules may be simply a description of naming conventions.)

3.1.5 Uniqueness of Names

Name uniqueness must be enforced by the CA.

Each CA and its associated RAs must enforce name uniqueness within the X.500 namespace. When other name forms are used, they too must be allocated such that name uniqueness is ensured for certificates issued by that CA.

Practice Note: For distinguished names, name uniqueness is enforced for the entire name rather than a particular attribute (e.g., the common name).

The FPKIPA is responsible for ensuring name uniqueness in certificates issued by the FBCA. Entity CAs must identify the authority that is responsible for ensuring name uniqueness in certificates issued by the entity CA. Name uniqueness is not violated when multiple certificates are issued to the same entity.

3.1.6 Recognition, Authentication, and Role of Trademarks

The FPKIPA resolves any name collisions or disputes regarding FBCA-issued certificates brought to its attention. Consistent with Federal Policy, the FBCA will not knowingly use trademarks in names unless the subject has the rights to use that name.

Entity CPs must identify the use and role of trademarks within their PKI environments.

3.2 INITIAL IDENTITY VALIDATION

3.2.1 Method to Prove Possession of Private Key

In all cases where the party named in a certificate generates its own keys that party must prove possession of the private key that corresponds to the public key in the certificate request.

Practice Note: For signature keys, this may be done by the entity using its private key to sign a value and providing that value to the CA. The CA must then validate the signature using the party's public key. The Federal PKI Policy Authority may allow other mechanisms that are at least as secure as those cited here.

In the case where key generation is performed under the CA or RA's direct control, proof of possession is not required (e.g., key management certificates generated in a system allowing key escrow).

3.2.2 Authentication of Organization Identity

Requests for CA certificates must include the organization name, address, and documentation of the existence of the organization. Before issuing CA certificates, an authority for the issuing CA must verify the information, in addition to the authenticity of the requesting representative and the representative's authorization to act in the name of the organization.

Before issuing subscriber certificates on behalf of an affiliated organization, the issuing CA must verify the authority of requesting representatives.

3.2.3 Authentication of Individual Identity

For each certificate issued, the CA must authenticate the identity of the individual requestor.

In addition to the processes described below, Subscriber certificates may be issued on the basis of an electronically authenticated request, using a valid signature or authentication certificate and associated private key, with the following restrictions:

- The assurance level of the new certificate must be the same or lower than the assurance level of the certificate used to authenticate the request;
- Identity information in the new certificate must match the identity information from the signature or authentication certificate;
- The expiration date of the new certificate shall not exceed the next required initial identity authentication date associated with the certificate used to authenticate the request.
- The next required initial identity authentication date remains unchanged in the event of a new certificate issuance based on electronic authentication.

3.2.3.1 Authentication of Human Subscribers

For Subscribers, the FPKIMA or Entity CA, and/or associated RAs must ensure that the applicant's identity information is verified in accordance with the process established by the applicable CP and CPS. Process information depends upon the certificate level of assurance and must be addressed in the applicable CPS.

The CAs and/or RAs must record the information set forth below for issuance of each certificate:

- The identity of the person performing the identification and either;
 - A signed declaration by that person that he or she verified the identity of the applicant as required using the format set forth at 28 U.S.C. 1746 (declaration under penalty of perjury) or comparable procedure under local law.
 - An auditable record linking the authentication of the person performing the identification to their verification of each Applicant.
- If in-person or supervised remote¹ identity proofing is done, a unique identifying number(s) from the ID(s) of the applicant, or a facsimile of the ID(s);

¹ The minimum requirements associated with supervised remote identity proofing are described in NIST SP 800-63A, *Digital Identity Guidelines: Enrollment and Identity Proofing*, Section 5.3.3. In addition, the supervised remote process for PIV-I policies must have the capability of capturing an approved biometric.

- If electronic authentication is done, a unique identifying number(s) from the signature or authentication certificate must be retained (e.g., certificate, serial number, thumbprint, SKI, public key, etc.)
- The date of the verification; and either:
 - An auditable record indicating the applicant accepted the certificate; or
 - A declaration of identity signed by the applicant using a handwritten signature or appropriate digital signature (see Practice Note) and performed in the presence of the person performing the identity authentication, using the format set forth at 28 U.S.C. 1746 (declaration under penalty of perjury) or comparable procedure under local law.

Practice Note: In those cases, in which the individual is in possession of a valid digital signature credential of equal or higher level of assurance or the signature certificate is generated immediately upon authentication of the applicant's identity, the applicant may sign the declaration of identity and certificate of acceptance using the digital credential. In the latter case, if the applicant fails to sign the declaration of identity, then the certificate must be revoked.

The table below summarizes the identification requirements for each level of assurance.

Assurance Level	Identification Requirements
Rudimentary	No identification requirement; applicant may apply and receive a certificate by providing his or her e-mail address
Basic	Identity may be established by in-person proofing before a Registration Authority or Trusted Agent; or remotely verifying information provided by applicant including ID number and account number through record checks either with the applicable agency or institution or through credit bureaus or similar databases, and confirms that: name, date of birth, address and other personal information in records are consistent with the application and sufficient to identify a unique individual. Address confirmation: a) Issue credentials in a manner that confirms the address of record supplied by the applicant; or b) Issue credentials in a manner that confirms the ability of the applicant to receive telephone communications at a number associated with the applicant in records, while recording the applicant's voice.

Assurance Level	Identification Requirements
Medium (all policies)	Identity must be established by in-person or supervised remote proofing before the Registration Authority, Trusted Agent or an entity certified by a State or Federal Entity as being authorized to confirm identities; information provided must be verified to ensure legitimacy. A trust relationship between the Trusted Agent and the applicant which is based on an in-person antecedent may suffice as meeting the in-person identity proofing requirement. Credentials required are one Federal Government-issued Picture I.D., one REAL ID Act compliant picture ID², or two Non-Federal Government I.D.s, one of which must be a photo I.D. Any credentials presented must be unexpired. PIV-I identity must be verified in accordance with the requirements specified for issuing PIV in Section 2.7 of [FIPS 201] For PIV-I, the use of an in-person antecedent is not applicable.
High	Identity established by in-person appearance before the Registration Authority or Trusted Agent; information provided must be checked to ensure legitimacy Credentials required are either one Federal Government-issued Picture I.D., one REAL ID Act compliant picture ID., or two Non-Federal Government I.D.s, one of which must be a photo I.D. (e.g., Driver's License)

A CPS must indicate what actors, roles, responsibilities and activities are leveraged when relying on in-person antecedent to support identity proofing (e.g., agreement with a professional organization to use a member identification number and associated provided point of contact information as antecedent, or electronic authentication using a medium or above certificate being traced back to the initial identity proofing event).

For All Levels except PIV-I: If an applicant is unable to perform face-to-face, either in-person or supervised remote, registration (e.g., a network device), the applicant may be represented by a trusted person already issued a digital certificate by the Entity. The trusted person will present information sufficient for registration at the level of the certificate being requested, for both himself/herself and the applicant who the trusted person is representing.

² REAL ID Act compliant IDs are identified by the presence of the DHS REAL ID star

For the Basic and Medium Assurance Levels: An entity certified by a State or Federal Entity as being authorized to confirm identities may perform in-person authentication on behalf of the RA and may be considered a Trusted Agent. The certified entity forwards the information collected from the applicant directly to the RA in a secure manner. Packages secured in a tamper-evident manner by the certified entity satisfy this requirement; other secure methods are also acceptable. Such authentication does not relieve the RA of its responsibility to verify the presented data.

For PIV-I Certificates: PIV-I Hardware certificates must be issued only to human subscribers. The following biometric data must be collected during the identity proofing and registration process, and must be formatted in accordance with [NIST SP 800-76-2] (see Appendix A):

- An electronic facial image used for printing facial image on the card, as well as for performing visual authentication during card usage;
- Two electronic fingerprints to be stored on the card for automated authentication during card usage; and

In the event an applicant is denied a credential based on the results of the identity proofing process, the Entity must provide a mechanism for appeal or redress of the decision.

3.2.3.2 Authentication of Human Subscribers for Role-based Certificates

Roles for which role-based certificates may be issued are limited to those that uniquely identify a specific role within an organization (e.g., *Chief Information Officer* is a unique role whereas *Program Analyst* is not). Role-based certificates must not be shared, but must be issued to individual subscribers and protected in the same manner as individual certificates.

CAs must record the information identified in Section 3.2.3.1 for a sponsor associated with the role before issuing a role-based certificate. The sponsor must hold an individual certificate in his/her own name issued by the same Entity at the same or higher assurance level as the role-based certificate.

The procedures for issuing role-based tokens must comply with all other stipulations of this CP (e.g., key generation, private key protection, and Subscriber obligations).

For pseudonymous certificates that identify subjects by their organizational roles, the CA must validate that the individual either holds that role or has been delegated the authority to sign on behalf of the role.

Practice Note: When determining whether a role-based certificate is warranted, consider whether the role carries inherent authority beyond the job title. Role-based certificates may also be used for individuals on temporary assignment, where the temporary assignment carries an authority not shared by the individuals in their usual occupation, for example: “*Shift Lead, Security Operations Center*”.

3.2.3.3 Authentication of Human Subscribers for Group Certificates

Normally, a certificate is issued to a single Subscriber. For cases where there are several entities acting in one capacity, and where non-repudiation for transactions is not required, a certificate may be issued that corresponds to a private key that is shared by multiple Subscribers. CAs and/or RAs must record the information identified in Section 3.2.3.1 for a sponsor from the Information Systems Security Office or equivalent before issuing a group certificate.

In addition to the authentication of the sponsor, the following applies:

- The Information Systems Security Office or equivalent is responsible for ensuring control of the private key, including maintaining a list of Subscribers who have access to use of the private key, and accounting for which Subscriber had control of the key at what time.
- The subjectName DN must not imply that the subject is a single individual, e.g., by inclusion of a human name form;
- The list of those with access to the shared private key must be provided to, and retained by, the applicable CA or its designated representative; and
- The procedures for issuing tokens for use in shared key applications must comply with all other stipulations of this CP (e.g., key generation, private key protection, and Subscriber obligations).

3.2.3.4 Authentication of Devices

Some computing and communications devices (routers, firewalls, servers, etc.) will be named as certificate subjects. In such cases, the device must have a human sponsor. The sponsor is responsible for the security of the private key and for providing the following registration information:

- Equipment identification (e.g., serial number) or service name (e.g., DNS name) or unique software application name
- Equipment or software application public keys
- Equipment or software application authorizations and attributes (if any are to be included in the certificate)
- Contact information to enable the CA or RA to communicate with the sponsor when required

In the case a human sponsor is changed, the new sponsor must review the status of each device under his/her sponsorship to ensure it is still authorized to receive certificates. The CPS must describe procedures to ensure that certificate accountability is maintained.

The registration information must be verified to an assurance level commensurate with the certificate assurance level being requested. For certificates that assert a certificate policy mapped to the id-fpki-certpcy-mediumDevice or id-fpki-certpcy-mediumDeviceHardware policies, registration information must be verified commensurate with the Medium assurance

level. Acceptable methods for performing this authentication and integrity checking include, but are not limited to:

- Verification of digitally signed messages sent from the sponsor (using certificates of equivalent or greater assurance than that being requested).
- In person or supervised remote registration by the sponsor, with the identity of the sponsor confirmed in accordance with the requirements of Section 3.2.3.1.

3.2.4 Non-verified Subscriber Information

Except for the rudimentary assurance level, all Subscriber information included in certificates must be verified.

3.2.5 Validation of Authority

For cross-certification, the FPKIPA validates the representative's authorization to act in the name of the organization.

Entity CAs must validate the requestor's authority to act in the name of the organization before issuing organizational certificates.

3.2.6 Criteria for Interoperation

The FPKIPA determines the criteria for cross-certification with the FBCA. See also the Federal Public Key Infrastructure Bridge Application Process Overview document [BRIDGE PROCESS] and the Federal Public Key Infrastructure Annual Review Requirements [AUDIT] document. Entity CAs must not have more than one intentional trust path to the FBCA.

Note: Multiple trust paths created as a result of certificate renewal or CA rekey do not violate the single trust path requirement above.

3.3 IDENTIFICATION AND AUTHENTICATION FOR RE-KEY REQUESTS

3.3.1 Identification and Authentication for Routine Re-key

If an Entity CA cross-certified with the FBCA performs a re-key, it must request a new cross-certificate from the FPKIPA.

Subscribers of Entity CAs must identify themselves for the purpose of re-keying as required in table below.

Assurance Level	Routine Re-key Identity Requirements for Subscriber Signature, Authentication and Encryption Certificates
Rudimentary	Identity may be established through use of current signature key.

Assurance Level	Routine Re-key Identity Requirements for Subscriber Signature, Authentication and Encryption Certificates
Basic	Identity may be established through use of current signature key, except that identity must be reestablished through initial identity validation process at least once every 15 years from the time of initial registration.
Medium (all policies) and PIV-I Card Authentication	Identity may be established through use of current signature key, except that identity must be established through initial identity validation process at least once every twelve (12) years from the time of initial registration. For certificates asserting policies mapped to id-fpki-certpcy-mediumDevice or id-fpki-certpcy-mediumDeviceHardware, identity may be established through the use of the device's current signature key or the signature key of the device's human sponsor.
High	Identity may be established through use of current signature key, except that identity must be established through initial identity validation process at least once every three years from the time of initial registration.

3.3.2 Identification and Authentication for Re-key after Revocation

After a certificate has been revoked other than during a renewal or update action, the subscriber is required to go through the initial registration process described in Section 3.2 to obtain a new certificate, unless identity can be verified through the use of biometrics on file through the chain of trust defined in [FIPS 201].

3.4 IDENTIFICATION AND AUTHENTICATION FOR REVOCATION REQUESTS

Revocation requests must be authenticated. Requests to revoke a certificate may be authenticated using that certificate's public key, regardless of whether or not the associated private key has been compromised.

3.5 IDENTIFICATION AND AUTHENTICATION FOR KEY RECOVERY REQUESTS

This section is applicable only for those Entity CAs that support key escrow and recovery of private keys.

3.5.1 KRA Authentication

The KRA must authenticate to the KED or DDS directly or using a public key certificate issued by the associated PKI. The assurance level of the certificate must be the same as or greater than that of the certificate whose corresponding private key is being recovered and must meet the requirements of an RA credential.

3.5.2 KRO Authentication

The KRO must authenticate to the KRA using a public key certificate issued by the associated PKI. The assurance level of the certificate must be the same as or greater than that of the certificate whose corresponding private key is being recovered and must meet the requirements of an RA credential.

3.5.3 Subscriber Authentication

The Subscriber identity must be established as specified in Section 3.3.1 above. Alternatively, if the authentication cannot be verified using the public key certificates issued by the associated PKI and for at least the given certificate policy assurance level, then the identity validation can use the steps outlined in Section 3.2.3.1.

For automated self-recovery, the Subscriber must be authenticated to the KED using a valid public key certificate. The assurance level of the Subscriber certificate must be equal to or greater than that of the certificate whose corresponding private key is being recovered.

3.5.4 Third-Party Requestor Authentication

The KRA or KRO must verify the identity and authorization of the Requestor prior to initiating the key recovery request.

Third-Party Requestor identity authentication must be commensurate with the assurance level of the certificate associated with the key being recovered. Identity must be established using one of the following methods:

- Procedures specified in Section 3.2.3 for authentication of an individual identity during initial registration for the specified certificate policy assurance level (an assurance level equal to or greater than the assurance level of the certificate whose corresponding private key is being recovered).
- Certificate-based authentication (e.g., digitally signed e-mail or client-authenticated TLS) that can be verified using current, valid (i.e., un-revoked) public key certificates at the requested certificate policy assurance level (an assurance level equal to or greater than the assurance level of the certificate whose corresponding private key is being recovered).

3.5.5 Data Decryption Server Authentication

The DDS must authenticate to the KED directly using a public key certificate issued by the associated PKI. The assurance level of the certificate must be the same as or greater than that of the highest assurance level encryption certificates issued by the associated PKI.

4. CERTIFICATE LIFE-CYCLE OPERATIONAL REQUIREMENTS

4.1 CERTIFICATE APPLICATION

The Certificate application process must provide sufficient information to:

- Establish the Applicant's authorization by the employing or sponsoring agency to obtain a certificate. See Section 3.2.3 for requirements.
- Establish and record the identity of the Applicant. See Section 3.2.3 for requirements.
- Obtain the Applicant's public key and verify the Applicant's possession of the private key. See Section 3.2.3 for requirements.
- Verify the information included in the certificate.

These steps may be performed in any order, but all must be completed before certificate issuance.

This section specifies requirements for initial application for certificate issuance.

Entities seeking to cross-certify with the FBCA must fulfill the application requirements as specified in the U.S. Government Public Key Infrastructure Cross-Certification Criteria and Methodology. The FPKIPA acts on the application and, upon making a determination to issue a certificate establishes an MOA with the Entity. The FPKIPA identifies the Entity's authorized representatives, provides the appropriate certificate policy mappings and authorizes the FPKIMA to issue the cross-certificate to the Entity.

The FBCA may issue Subscriber certificates to trusted personnel where necessary for the internal operations of the FBCA. The FBCA does not issue Subscriber certificates for any other reasons.

4.1.1 Who Can Submit a Certificate Application

For the FBCA, the certificate application must be submitted to the FPKIPA by an authorized representative of the Entity CA.

For Entity CAs, this CP makes no stipulations regarding submission of certificate applications beyond those in Section 4.1 above.

4.1.2 Enrollment Process and Responsibilities

All communications supporting the certificate application and issuance process must be authenticated and protected from modification. Communications may be electronic or out-of-band.

Any electronic communication of shared secrets must be protected.

Where electronic communications are used, cryptographic mechanisms commensurate with the strength of the public/private key pair must be used.

Out-of-band communications must protect the confidentiality and integrity of the data.

Subscribers are responsible for providing accurate information on their certificate applications.

Entities applying for cross-certification are responsible for providing accurate information on their certificate applications. Upon issuance, each certificate issued by the FBCA is manually checked to ensure each field and extension is properly populated with the correct information before the certificate is delivered to the Entity.

For Entity CAs Subscribers are responsible for providing accurate information on their certificate applications.

If databases or other sources are used to confirm Subscriber attributes, then these sources and associated information sent to a CA require:

- An auditable chain of custody be in place when information is obtained through one or more information sources.
- All data received be protected and securely exchanged in a confidential and tamper evident manner and protected from unauthorized access.

4.2 CERTIFICATE APPLICATION PROCESSING

Information in certificate applications must be verified as accurate before certificates are issued. Entity CPs must specify procedures to verify information in certificate applications.

4.2.1 Performing Identification and Authentication Functions

For the FBCA, the identification and authentication of the applicant is performed by the FPKIPA.

For Entity CAs, the identification and authentication of the Subscriber must meet the requirements specified for Subscriber authentication as specified in Sections 3.2 and 3.3 of this CP. The Entity CP must identify the components of the Entity PKI (e.g., CA or RA) that are responsible for authenticating the Subscriber's identity in each case.

4.2.2 Approval or Rejection of Certificate Applications

For the FBCA, the FPKIPA may approve or reject a certificate application. See Section 1.1.5.

For Entity CAs, the Entity CP shall identify the person or organizational body that may accept or reject a certificate application.

This CP makes no other stipulation regarding Approval or Rejection of Certificate Applications in Entity PKIs.

4.2.3 Time to Process Certificate Applications

Certificate applications must be processed and a certificate issued within 90 days of identity verification.

4.3 CERTIFICATE ISSUANCE

4.3.1 CA Actions During Certificate Issuance

The FPKIMA verifies the source of a certificate request before issuance. CA certificates created by the FBCA are checked to ensure that all fields and extensions are properly populated.

Upon receiving the request, Entity CAs/RAs must:

- Verify the identity of the requestor.
- Verify the authority of the requestor and the integrity of the information in the certificate request.
- Verify all attribute information received from a Subscriber before inclusion in a certificate.
- Build and sign a certificate if all certificate requirements have been met (in the case of an RA, have the CA sign the certificate).
- Make the certificate available to the Subscriber after confirming that the Subscriber has formally acknowledged the obligations described in Section 9.6.3.

4.3.2 Notification to Subscriber by the CA of Issuance of Certificate

The FPKIMA notifies the Entity CA of certificate issuance.

Practice Note: Where notification is not an integral component of the issuance process, CAs should proactively notify subscribers that certificates have been generated.

For PIV-I, Entity CAs must inform the Subscriber of the creation of a certificate and make the certificate available to the Subscriber.

4.4 CERTIFICATE ACCEPTANCE

Before a subscriber can make effective use of its private key, the subscriber must accept the responsibilities defined in Section 9.6.3 by accepting the Subscriber agreement.

4.4.1 Conduct Constituting Certificate Acceptance

For the FBCA, failure to object to the certificate or its contents constitutes acceptance of the certificate.

For certificates issued by an Entity CP, certificate acceptance is governed by the Entity CP.

4.4.2 Publication of the Certificate by the CA

As specified in Section 2.2.1, all CA certificates must be published in a PKI repository accessible over the Internet.

PIV-I authentication and card authentication certificates must not be distributed via public repositories.

This specification makes no other stipulation regarding publication of Subscriber certificates.

4.4.3 Notification of Certificate Issuance by the CA to Other Entities

For the FBCA, notification of certificate issuance will be provided to all cross-certified entities.

For Entity CAs, the FPKIPA must be notified at least two weeks prior to the issuance of a new CA certificate or issuance of new inter-organizational CA cross-certificates. In addition, all new artifacts (CA certificates, CRL DP, AIA and/or SIA URLs, etc.) produced as a result of the CA certificate issuance must be provided to the FPKIPA within 24 hours following issuance.

Practice Note: The process for notifying the FPKIPA is included in the MOA.

4.5 KEY PAIR AND CERTIFICATE USAGE

4.5.1 Subscriber Private Key and Certificate Usage

Subscribers must protect their private keys from access by other parties.

Restrictions in the intended scope of usage for a private key are specified through certificate extensions, including the key usage and extended key usage extensions, in the associated certificate.

4.5.2 Relying Party Public Key and Certificate Usage

Certificates specify restrictions on use through critical certificate extensions, including the basic constraints and key usage extensions. CAs issue CRLs specifying the current status of all unexpired certificates. Relying parties should process certificate and status information as specified in [X.509] when relying on certificates.

4.6 CERTIFICATE RENEWAL

Renewing a certificate means creating a new certificate with a new serial number where all certificate subject information, including the subject public key and subject key identifier, remain unchanged.

The new certificate may have an extended validity period and may include new issuer information (e.g., different CRL distribution point, AIA and/or be signed with a different issuer key).

Once renewed, the old certificate may or may not be revoked, but must not be used for requesting further renewals, re-keys, or modifications.

4.6.1 Circumstance for Certificate Renewal

A certificate may be renewed if the public key has not reached the end of its validity period, the associated private key has not been compromised, and the Subscriber name and attributes are

unchanged. In addition, the validity period of the certificate must meet the requirements specified in Section 6.3.2.

PIV-I certificates must not be renewed, except during recovery from CA key compromise (see Section 5.7.3). In such cases, the renewed certificate must expire as specified in the original Subscriber certificate.

CA certificates and Delegated OCSP responder certificates may be renewed so long as the aggregated lifetime of the private key does not exceed the requirements specified in Section 6.3.2.

4.6.2 Who May Request Renewal

For the FBCA, the Entity or FPKIMA may request renewal of an Entity CA's cross-certificate.

For other CA certificates and Delegated OCSP responder certificates, the corresponding operating authority may request renewal.

For Entity CAs that support renewal, subscriber renewal requests must be accepted only from certificate subjects, PKI sponsors or RAs. Additionally, a CA may perform renewal of its subscriber certificates without a corresponding request, such as when the CA re-keys.

4.6.3 Processing Certificate Renewal Requests

For the FBCA, certificate renewal for reasons other than re-key of the FBCA must be approved by the FPKIPA.

When a CA re-keys, it may renew the certificates it has issued.

When certificates are renewed as a result of CA key compromise, as described in Section 4.6.1, the CA or RA must verify all certificates issued since the date of compromise were issued appropriately. If the certificate cannot be verified, then it must not be renewed.

4.6.4 Notification of New Certificate Issuance to Subscriber

As specified in Section 4.3.2.

4.6.5 Conduct Constituting Acceptance of a Renewal Certificate

As specified in Section 4.4.1.

4.6.6 Publication of the Renewal Certificate by the CA

As specified in Section 4.4.2.

4.6.7 Notification of Certificate Issuance by the CA to Other Entities

As specified in Section 4.4.3.

4.7 CERTIFICATE RE-KEY

Re-key is identical to renewal except the new certificate must have a different subject public key (and serial number).

Subscribers of Entity CAs must identify themselves for the purpose of re-keying as required in Section 3.3.1.

Once re-keyed, the old certificate may or may not be revoked, but must not be reused for requesting further re-keys, renewals, or modifications.

4.7.1 Circumstance for Certificate Re-key

Circumstances requiring certificate re-key include nearing the maximum usage period of a private key, certificate expiration, loss or compromise, issuance of a new hardware token, and hardware token failure.

The FBCA will issue new cross-certificates to Entity CAs when they have generated a new key pair and a valid and unexpired MOA exists between the FPKIPA and the Entity PKI.

Section 6.3.2 establishes maximum usage periods for private keys for both CAs and Subscribers.

4.7.2 Who May Request Certification of a New Public Key

The FPKIMA may request certification of a new FBCA public key from currently cross-certified Entity CAs.

For Entity CA certificates and Delegated OCSP responder certificates, the corresponding operating authority may request re-key of its own certificate.

Subscribers with a currently valid certificate may request re-key of the certificate. CAs and RAs may request certification of a new public key on behalf of a Subscriber. The human sponsor of a device may request re-key of the device certificate.

4.7.3 Processing Certificate Re-keying Requests

Before performing re-key, the CA must identify and authenticate the requestor by performing the identification processes defined in Section 3.2 or Section 3.3.

Digitally signed Subscriber re-key requests must be validated before the re-key requests are processed.

4.7.4 Notification of New Certificate Issuance to Subscriber

As specified in Section 4.3.2.

4.7.5 Conduct Constituting Acceptance of a Re-keyed Certificate

As specified in Section 4.4.1.

4.7.6 Publication of the Re-keyed Certificate by the CA

As specified in Section 4.4.2.

4.7.7 Notification of Certificate Issuance by the CA to Other Entities

As specified in Section 4.4.3.

4.8 CERTIFICATE MODIFICATION

Modifying a certificate means creating a new certificate that has the same or a different key and a different serial number, and that differs in one or more other fields from the old certificate. Once modified, the old certificate may or may not be revoked, but must not be reused for requesting further renewals, re-keys, or modifications.

4.8.1 Circumstance for Certificate Modification

CA certificates and Delegated OCSP responder certificates whose characteristics have changed (e.g., assert new policy OID) may be modified. The new certificate may have the same or a different subject public key.

A certificate associated with a Subscriber whose characteristics have changed (e.g., name change due to marriage) may be modified. The new certificate must have a different subject public key.

4.8.2 Who May Request Certificate Modification

The FPKIMA or the Entity may request certificate modification for current cross-certificates.

For Entity CA certificates and Delegated OCSP responder certificates, the corresponding operating authority may request modification.

Subscribers with a currently valid certificate may request modification of the certificate. The human sponsor of a device may request modification of the device certificate. CAs and RAs may request certificate modification on behalf of a Subscriber.

4.8.3 Processing Certificate Modification Requests

The FPKIMA performs certificate modification at the direction of the FPKIPA. The FPKIMA may also perform certificate modification at the request of the Entity CA for the following reasons:

- Modification of SIA extension; or
- Minor name changes (e.g., change CA1 to CA2) as part of key rollover procedures.

For Entity CAs, proof of all subject information changes must be provided to the RA or other designated agent and verified before the modified certificate is issued. If the modified certificate is issued with a new (different) public key, the additional requirements specified in Section 4.7.3 must also apply.

If an individual's authorizations or privileges change, such that the modified certificate indicates a reduction in privileges and authorizations, the old certificate must be revoked.

4.8.4 Notification of New Certificate Issuance to Subscriber

As specified in Section 4.3.2.

4.8.5 Conduct Constituting Acceptance of Modified Certificate

As specified in Section 4.4.1.

4.8.6 Publication of the Modified Certificate by the CA

As specified in Section 4.4.2.

4.8.7 Notification of Certificate Issuance by the CA to Other Entities

As specified in Section 4.4.3.

4.9 CERTIFICATE REVOCATION AND SUSPENSION

Revocation requests must be authenticated. Requests to revoke a certificate may be authenticated using that certificate's associated private key, regardless of whether or not the private key has been compromised.

For High, PIV-I, Medium Hardware, Medium, and Basic Assurance, all CAs must publish CRLs.

CAs must notify the FPKIPA at least two weeks prior to the revocation of a CA certificate, whenever possible. For emergency revocation, CAs must follow the notification procedures in Section 5.7.

4.9.1 Circumstances for Revocation

A certificate must be revoked when the binding between the subject and the subject's public key defined within the certificate is no longer considered valid. Examples of circumstances that invalidate the binding are:

- Identifying information or affiliation components of any names in the certificate becomes invalid. Examples include
 - Subscriber no longer affiliated with sponsoring entity
 - A wild card certificate has been issued with a name where PKI Sponsor does not exercise control of the entire namespace associated with the wild card certificate.
- Privilege attributes asserted in the Subscriber's certificate are reduced.
- The Subscriber can be shown to have violated the stipulations of its Subscriber agreement.
- There is reason to believe the private key has been compromised.
- The Subscriber or other authorized party (as defined in the CPS) asks for his/her certificate to be revoked.
- The failure of a CA to adequately adhere to the requirements of its CP or the approved CPS.

There are three circumstances under which certificates issued by the FBCA will be revoked:

- The FPKIPA requests an FBCA-issued certificate be revoked.
- The FPKIMA receives an authenticated request from a previously designated official of the Entity responsible for the CA.
- The FBCA Operational personnel determine that an emergency has occurred that may impact the integrity of the certificates issued by the FBCA. Under such circumstances, the following individuals may authorize immediate certificate revocation:
 - FPKIPA Co-chair, or
 - Other personnel as designated by a FPKIPA Co-chair.

The FPKIPA must meet as soon as practicable to review the emergency revocation.

CAs must, at a minimum, revoke certificates for the reason of key compromise upon receipt of an authenticated request from an appropriate entity.

For certificates that express an organizational affiliation, Entity CAs must require that the organization inform the Entity CA of any changes in the subscriber affiliation. If the affiliated organization no longer authorizes the affiliation of a Subscriber, the Entity CA must revoke any certificates issued to that Subscriber containing the organizational affiliation. If an organization terminates its relationship with an Entity CA such that it no longer provides affiliation information, the Entity CA must revoke all certificates affiliated with that organization.

If it is determined that revocation is required, the associated certificate must be revoked and placed on the CRL. Revoked certificates must be included on all new publications of the certificate status information until the certificates expire.

4.9.2 Who Can Request Revocation

A CA may summarily revoke certificates it has issued. A written notice and brief explanation for the revocation must subsequently be provided to the Subscriber.

A Subscriber or sponsor of device certificates may request revocation of their own certificates.

The RA or other authorized agency officials may request the revocation of a Subscriber's certificate.

An FBCA issued certificate may be revoked upon direction of the FPKIPA or upon an authenticated request by a designated official of the Entity responsible for the CA named in the certificate.

Entity CAs must, at a minimum, accept revocation requests from subscribers. Entity CAs that issue certificates in association with Affiliated Organizations must accept revocation requests from the Affiliated Organization named in the certificate. Requests for certificate revocation from other parties may be supported by Entity CAs. Note that an Entity may always revoke certificates it has issued to the FBCA without any FPKIPA action.

4.9.3 Procedure for Revocation Request

Upon receipt of a revocation request involving an FBCA-issued certificate, the FPKIMA must authenticate the request and apprise the FPKIPA.

If a revocation is due to a certificate or systems compromise or an Entity CA violation of the Memorandum of Agreement with the FPKIPA, the FPKIPA will notify previously designated officials of all cross-certified entities.

Entity CAs must revoke certificates upon receipt of sufficient evidence of compromise or loss of the subscriber's corresponding private key. Where subscribers use hardware tokens, but excluding PIV-I certificates, revocation is optional if all the following conditions are met:

- the revocation request was not for key compromise;
- the cryptographic module does not permit the user to export the signature private key;
- the Subscriber surrendered the token to the PKI;
- the token was zeroized or destroyed promptly upon surrender;
- the token has been protected from malicious use between surrender and zeroization or destruction.

For PIV-I and in all other cases not identified above, revocation of the certificates is mandatory. Even where all the above conditions have been met, revocation of the associated certificates is recommended.

Entity CAs (or delegate) must collect and destroy PIV-I Cards from Subscribers whenever the cards are no longer valid, whenever possible. Entity CAs (or delegate) must record destruction of PIV-I Cards.

If it is determined that a private key used to authorize the issuance of one or more certificates may have been compromised, all certificates directly or indirectly authorized by that private key since the date of actual or suspected compromise must be revoked or must be verified as appropriately issued.

4.9.4 Revocation Request Grace Period

The revocation request grace period is the time available to the subscriber within which the subscriber must make a revocation request after reasons for revocation have been identified.

In the case of key compromise, Entity CAs are required to request revocation within one hour of confirmation of the compromise.

4.9.5 Time within which CA must Process the Revocation Request

CA certificates are revoked once all necessary notification periods have elapsed.

Entity CAs will revoke subscriber certificates as quickly as practical upon receipt of a proper revocation request. Revocation requests must be processed before the next CRL is published, excepting those requests validated within two hours of CRL issuance. Revocation requests

validated within two hours of CRL issuance must be processed before the following CRL is published.

4.9.6 Revocation Checking Requirements for Relying Parties

Relying parties are expected to verify the validity of certificates as specified in [RFC 5280].

Practice Note: Use of revoked certificates could have damaging or catastrophic consequences. The matter of how often new revocation data should be obtained is a determination to be made by the Relying Party, considering the risk, responsibility, and consequences for using a certificate whose revocation status cannot be guaranteed.

4.9.7 CRL Issuance Frequency

For this CP, CRL issuance encompasses both CRL generation and publication.

CRLs must be issued periodically, even if there are no changes to be made, to ensure timeliness of information. The table below specifies the issuing frequency of routine CRLs. CRLs may be issued more frequently than specified below.

CRL Issuance Frequency

Assurance Level	Maximum Interval for Routine CRL Issuance	
	Online	Offline*
Rudimentary	No stipulation	No Stipulation
All other policies	24 hours	35 Days

*An offline CA may incorporate locally attached network equipment such as an HSM or storage array. The CA system and any such locally attached network equipment must be completely isolated (air-gapped) from all other networks and computing systems.

CAs may be operated in an offline manner if the CA only issues:

- CA certificates
- (optionally) CSS certificates,
- (optionally) end user certificates solely for the administration of the Entity CA, and
- (optionally) end user certificates that contain the contentSigning EKU.

However, the interval between routine CRL issuance must never exceed 35 days.

4.9.8 Maximum Latency for CRLs

For CAs that operate online, CRLs must be published within 4 hours of generation.

For CAs that operate offline, pre-generated CRLs intended for publication more than 4 hours after generation must be protected in the same manner as the CA. All pre-generated CRLs not yet published must be securely destroyed whenever the CA revokes any certificate. The CPS must describe protections and processes used for generation and protection of any pre-generated CRLs.

Furthermore, each CRL must be published no later than the time specified in the nextUpdate field of the previously issued CRL for same scope.

Note: If pre-generation of CRLs is implemented, the thisUpdate field will be the date of generation. The nextUpdate value will be beyond the date of planned publication.

4.9.9 On-line Revocation/Status Checking Availability

If on-line revocation/status checking is supported by an Entity CA, the latency of certificate status information must meet or exceed the requirements for CRL issuance stated in 4.9.7.

OCSP services must be designed and implemented so as to provide 99% availability overall and limit scheduled down-time to 0.5% annually, with resources sufficient to provide a response time of ten (10) seconds or less under normal operating conditions.

For PIV-I certificates, CAs must support on-line status checking via OCSP [RFC 6960].

4.9.10 On-line Revocation Checking Requirements

On-line revocation status checking is optional for relying parties. For certificates where revocation status online checking is not available, CRLs must be used.

4.9.11 Other Forms of Revocation Advertisements Available

A CA may use other methods to publicize the certificates it has revoked. Any alternative method must meet the following requirements:

- The alternative method must be described in the CA's approved CPS.
- The alternative method must provide authentication and integrity services commensurate with the assurance level of the certificate being verified.
- The alternative method must meet the issuance and latency requirements for CRLs stated in Sections 4.9.7 and 4.9.8.

4.9.12 Special Requirements Related to Key Compromise

In the event of an Entity CA private key compromise or loss, the FPKIMA must revoke the cross-certificate, publish an emergency CRL as soon as feasible, and notify the FPKPA and all cross-certified entities.

For Entity CAs, when a CA certificate is revoked or subscriber certificate is revoked because of compromise, or suspected compromise, of a private key, an emergency CRL must be published as specified below:

Assurance Level	Maximum Latency for Emergency CRL Issuance
Rudimentary	No stipulation
Basic	24 hours after notification
Medium (all policies)	18 hours after notification
PIV-I Card Authentication	18 hours after notification
High	6 hours after notification

4.9.13 Circumstances for Suspension

Suspension is not supported by the FBCA.

Entity CAs may support certificate suspension and restoration for Subscriber certificates. If suspension and restoration are supported by the Entity CA, the CPS must describe under what circumstances certificates may be suspended and provide details for the corresponding sections below.

4.9.14 Who Can Request Suspension

For Entity CAs that support suspension, those authorized to request suspension of a certificate must be identified.

4.9.15 Procedure for Suspension Request

For Entity CAs that support suspension, all suspended certificate serial numbers must be populated on a full CRL within a timeframe specified in Section 4.9.7. The reason code CRL entry extension shall be populated with “certificateHold.”

For Entity CAs that support suspension, a request to suspend a certificate must include:

- authentication of the requestor,
- identification of the certificate to be suspended, and
- explanation of explain the reason for suspension

4.9.16 Limits on Suspension Period

For Entity CAs that support suspension, the maximum time period a certificate may be suspended must be specified. The CPS must describe in detail how this maximum suspension period is enforced. If the subscriber has not removed the certificate from hold (suspension)

within that period, the certificate must be revoked. Certificates must not be published on a CRL with a reason code of “certificateHold” beyond the expiration date of the certificate.

Practice Note: In order to mitigate the threat of unauthorized person removing the certificate from hold, the identity of the RA or authorized individual removing the suspension should be authenticated using a mechanism equivalent or higher than the assurance level of the certificate being unsuspended.

4.10 CERTIFICATE STATUS SERVICES

See Section 4.9.9 for OCSP.

If additional certificate status services are supported, they must be described in the CPS.

4.10.1 Operational Characteristics

Where applicable this must be described in the CPS.

4.10.2 Service Availability

Where applicable this must be described in the CPS.

4.10.3 Optional Features

Where applicable this must be described in the CPS.

4.11 END OF SUBSCRIPTION

No stipulation.

4.12 KEY ESCROW AND RECOVERY

The FBCA does not support key escrow and recovery.

The following sections are applicable for those Entity CAs that support key escrow and recovery.

4.12.1 Key Escrow and Recovery Policy and Practices

CA private keys are never escrowed.

Subscriber key management keys may be escrowed to provide key recovery.

When implemented, key recovery requirements must be documented in a Key Recovery Policy (KRP). The KRP may be a separate document or may be combined with the CP.

Key Recovery policies and practices must satisfy privacy and security requirements for CAs issuing and managing digital certificates under the Entity’s CP.

Practice Note: Escrowed keys must be protected at no less than the level of security in which they are generated, delivered, and protected by the subscriber.

Under no circumstances will a subscriber signature key be escrowed.

4.12.1.1 *Key Escrow Process and Responsibilities*

If escrow is supported, subscriber private keys (i.e., decryption private keys) associated with a key management certificate must be securely escrowed by the KED. The CA must ensure that the keys are escrowed successfully prior to issuance of the key management certificates.

Subscriber private keys must be protected during transit and storage using cryptography at least as strong as the key being escrowed.

Subscribers must be notified that the private keys associated with their encryption certificates will be escrowed.

4.12.1.2 *Key Recovery Process and Responsibilities*

Communications between the various key recovery participants (KED, DDS, KRA, KRO, Requestor, and Subscriber) must be secured from protocol threats such as disclosure, modification, replay, and substitution. The strength of all cryptographic protocols must be equal to or greater than that of the keys they protect.

During delivery, escrowed keys must be protected against disclosure to any party except the Requestor.

When any mechanism that includes a shared secret (e.g., a password) is used to protect the key in transit, the mechanism must ensure that the Requestor and the transmitting party are the only holders of this shared secret.

Subscribers may use electronic or manual means to request their own escrowed keys from the KRS. The Subscriber may submit the request to the KED, KRA or KRO. If the request is made electronically, the subscriber must digitally sign the request or authenticate to a recovery service using an associated authentication or signature certificate with an assurance level equal to or greater than that of the escrowed key. Manual requests must be made in person, and include proper identity verification by the KRA in accordance with Section 3.2.3.1.

Third-Party Requestors may use electronic or manual means to request the Subscribers' escrowed keys. The Requestor must submit the request to the KRA or KRO. If the request is made electronically, the Requestor must digitally sign the request using a trusted authentication or signature certificate, as determined by the recovering organization, with an assurance level equal to or greater than that of the escrowed key. Manual requests must include proper identity verification by the KRA in accordance with Section 3.2.3.1.

DDSs must use electronic means to request Subscribers' escrowed keys. Requests must be authenticated as specified in Section 3.5.5.

Third party key recovery in and of itself does not require revocation of a subscriber certificate. This does not prohibit Subscribers from requesting revocation of their own certificates for any reason.

4.12.1.2.1 Key Recovery Through KRA

The KRA must provide access to a copy of an escrowed key only in response to a properly authenticated and authorized key recovery request. Such access requires the actions of at least two KRAs. All copies of escrowed keys must be protected using two-person control procedures during recovery and delivery to the authenticated and authorized Requestor. Split key or password procedures are considered adequate two-person controls, provided they comply with technical controls in Section 6.2.2.

Practice Note: A combination of physical, procedural, and technical security controls can be used to enforce continuous two-person control during recovery and delivery of escrowed keys. The KRS should be designed to maximize the ability to enforce two-person control technically.

The KRA is not required to notify subscribers of a third-party key recovery.

4.12.1.2.2 Automated Self-Recovery

A current Subscriber's escrowed keys may be provided directly to the Subscriber without imposition of two-person control requirements. The KED must only provide escrowed keys to current Subscribers without two-person control upon:

- Verifying that the authenticated identity of the Requestor is the same as the Subscriber associated with the escrowed keys being requested;
- Sending notification to the Subscriber of all attempts (successful or unsuccessful) to recover the Subscriber's escrowed keys that are made by entities claiming to be the subscriber. If the KED does not have information (e.g., an e-mail address) necessary to send notification to the Subscriber of a key recovery request, then the KED must not provide the Subscriber with the requested key material using the automated recovery process

Practice Note: Where possible, the e-mail address will be from the subject alternative name field of the certificate being recovered.

- Ensuring that the escrowed keys are being sent only to the authenticated Subscriber associated with the escrowed keys; and
- Ensuring that the escrowed keys are encrypted during transmission using cryptography of equal or greater strength than provided by the escrowed keys.

4.12.1.2.3 Key Recovery During Token Issuance

When a Subscriber (individual and/or group/role sponsor or member) is issued a new certificate on a hardware token, private key management keys for the Subscriber may be recovered as part of the issuance process as long as the KED uses secure means, such as Global Platform Secure Channel Protocol, to inject the key history onto the hardware token directly.

The hardware token must meet FIPS 140 Level 2 hardware requirements and the key must be injected into the token such that it is not thereafter exportable.

4.12.1.2.4 Key Recovery by Data Decryption Server

A DDS must be under two-person control, as is required for any CA or KED. A DDS is permitted to automatically recover keys from the KED. The KED must perform the following activities prior to releasing the key:

- Authenticating the Requestor as a legitimate DDS;
- Verifying that the DDS is authorized to recover the escrowed key for the Issuing Organization to which the key belongs;
- Ensuring that the escrowed keys are protected during transmission using cryptography or other means of equal or greater strength than provided by the escrowed keys.

In order to prevent any individual KRA, KRO or another trusted role from accessing subscriber encryption keys, a combination of physical, procedural, and technical security controls must be used to enforce continuous two-person control on the DDSs. The DDSs must be designed to maximize the ability to enforce two-person control technically.

4.12.1.3 Who Can Submit a Key Recovery Application

Subscribers may request recovery of their own escrowed keys. Key recovery may also be requested by internal Third-Party Requestor permitted by the Issuing Organization policy, and by authorized external Third-Party Requestors (e.g., law enforcement personnel with a court order from a competent court).

4.12.1.3.1 Requestor Authorization Validation

The KRA or the KRO, as an intermediary for the KRA, must validate the authorization of the Requestor. KRAs should consult with Issuing Organization management and/or legal counsel, as appropriate.

Issuing Organizations must determine internal notification requirements for External Third-Party key recovery requests and account for situations where the law requires the KED to release the Subscriber's private key without organizational notification.

Nothing in this document is intended to change the current procedures for obtaining information about individuals in connection with such requests.

4.12.1.3.2 Subscriber Authorization Validation

Current Subscribers are authorized to recover their own escrowed key material.

4.12.1.3.3 KRA Authorization Validation

The KED must verify that the KRA has appropriate privileges to obtain the keys for the identified Subscriber's organization.

4.12.1.3.4 KRO Authorization Validation

The KED or KRA must verify that the KRO is authorized to request keys for the identified Subscriber.

4.12.1.3.5 Data Decryption Server Authorization Validation

The KED must verify that the DDS recovery request falls within the organizational scope for which the DDS was established.

4.12.2 Session Key Encapsulation and Recovery Policy and Practices

The FBCA does not support session key encapsulation and recovery.

CAs that support session key encapsulation and recovery must identify the document describing the practices in the associated CP.

5. FACILITY, MANAGEMENT, AND OPERATIONS CONTROLS

5.1 PHYSICAL CONTROLS

CA equipment must be protected from unauthorized access while the cryptographic module is installed and activated. The CA must implement physical access controls to reduce the risk of equipment tampering even when the cryptographic module is not installed and activated. CA cryptographic tokens must be protected against theft, loss, and unauthorized use.

All the physical control requirements specified below apply equally to all CAs, and any remote workstations used to administer the CAs except where specifically noted.

5.1.1 Site Location and Construction

The location and construction of the facility housing CA equipment, as well as sites housing remote workstations used to administer the CAs, must be consistent with facilities used to house high value, sensitive information. The site location and construction, when combined with other physical security protection mechanisms such as guards, high security locks, and intrusion sensors, must provide robust protection against unauthorized access to all CA equipment and records.

5.1.2 Physical Access

5.1.2.1 Physical Access for CA Equipment

The CA equipment, to include remote workstations used to administer the CAs, must always be protected from unauthorized access. The security mechanisms must be commensurate with the level of threat in the equipment environment. Since the FBCA must plan to issue certificates at all levels of assurance, it is operated and controlled on the presumption that it will be issuing at least one High Assurance certificate.

The physical security requirements pertaining to CAs that issue only Basic Assurance certificates are:

- Ensure no unauthorized access to the hardware is permitted.
- Ensure all removable media and paper containing sensitive plain-text information is stored in secure containers.

In addition to those requirements, the following requirements apply to CAs that issue Medium, Medium Hardware, or High assurance certificates:

- Ensure manual or electronic monitoring for unauthorized intrusion at all times.
- Ensure an access log is maintained and inspected periodically.
- Require two-person physical access control to both the cryptographic module and computer systems.

Practice Note: Multiparty physical access control to CA equipment can be achieved by any combination of two or more trusted roles (see Section 5.2.2) as long as the tasks being conducted are segregated in accordance with the requirements and duties defined for each trusted role. As an example, an Auditor and an Operator might access the site housing the CA equipment to perform a tape backup, but only the Operator may perform the tape backup.

Removable cryptographic modules, activation information used to access or enable cryptographic modules, and other sensitive CA equipment must be placed in secure containers when not in use. Activation data must be either memorized, or recorded and stored in a manner commensurate with the security afforded the cryptographic module, and must not be stored with the cryptographic module or removable hardware associated with remote workstations used to administer the CA.

A security check of the facility housing the CA equipment or remote workstations used to administer the CAs (operating at the Basic Assurance level or higher) must occur if the facility is to be left unattended. At a minimum, the check must verify the following:

- The equipment is in a state appropriate to the current mode of operation (e.g., that cryptographic modules are in place when “open”, and secured when “closed”; and for offline CAs, that all equipment other than the repository is shut down).
- Any security containers are properly secured.
- Physical security systems (e.g., door locks, vent covers) are functioning properly.
- The area is secured against unauthorized access.

A person or group of persons must be made explicitly responsible for making such checks. When a group of persons is responsible, a log identifying the person performing a check at each instance must be maintained. If the facility is not continuously attended, the last person to depart must initial a sign-out sheet that indicates the date and time, and asserts that all necessary physical protection mechanisms are in place and activated.

5.1.2.2 Physical Access for RA Equipment

RA equipment must be protected from unauthorized access while the cryptographic module is installed and activated. The RA must implement physical access controls to reduce the risk of equipment tampering even when the cryptographic module is not installed and activated. These security mechanisms must be commensurate with the level of threat in the RA equipment environment.

5.1.2.3 Physical Access for CSS Equipment

Physical access control requirements for CSS equipment that has signing capability must meet the CA physical access requirements specified in Section 5.1.2.1. CSS equipment that does not have a private signing key and only distribute pre-generated OSCP responses are not required to meet these requirements.

5.1.2.4 Physical Access for CMS Equipment

Physical access control requirements for CMS equipment containing a PIV-I Content Signing key must meet the CA physical access requirements specified in Section 5.1.2.1.

5.1.2.5 Physical Access for KED Equipment

Physical access control requirements for KED equipment that store private keys must meet the CA physical access requirements specified in Section 5.1.2.1.

5.1.2.6 Physical Access for DDS Equipment

Physical access control requirements for DDS equipment that store or use private keys must meet the CA physical access requirements specified in Section 5.1.2.1.

5.1.2.7 Physical Access for KRA and KRO Equipment

KRA and KRO equipment must be protected from unauthorized access while the cryptographic module is installed and activated. The KRA and KRO must implement physical access controls to reduce the risk of equipment tampering even when the cryptographic module is not installed and activated. These security mechanisms must be commensurate with the level of threat in the equipment environment.

5.1.3 Power and Air Conditioning

The CA must have sufficient alternative power supply in the event of a primary power source failure to either maintain CA operations or, at a minimum, prevent loss of data. The repositories (containing CA certificates, CRLs, and pre-generated OCSP responses) must be provided with uninterrupted power sufficient for a minimum of six (6) hours operation in the absence of commercial power, to maintain availability and avoid denial of service.

5.1.4 Water Exposures

CA equipment must be installed such that it is not in danger of exposure to water (e.g., on tables or elevated floors).

Water exposure from fire prevention and protection measures (e.g., sprinkler systems) are excluded from this requirement.

5.1.5 Fire Prevention and Protection

The CA must comply with local commercial building codes for fire prevention and protection.

5.1.6 Media Storage

Sensitive CA media must be stored to protect it from accidental damage (water, fire, electromagnetic) and unauthorized physical access.

5.1.7 Waste Disposal

Sensitive media and documentation that are no longer needed for operations must be destroyed in a secure manner. For example, sensitive paper documentation must be shredded, burned, or otherwise rendered unrecoverable.

5.1.8 Off-Site Backup

CA backups sufficient to recover from system failure must be made on a periodic schedule. Backups must be performed and stored off-site not less than once per week. At least one full backup copy must be stored at an off-site location separate from the CA equipment. Only the latest full backup need be retained. The backup must be stored at a site with physical and procedural controls commensurate to that of the operational CA.

For offline CAs, the backup must be performed each time the system is turned on or once per week, whichever is less frequent.

Requirements for CA private key backup are specified in Section 6.2.4.

5.2 PROCEDURAL CONTROLS

Unless stated otherwise, the requirements in this section apply equally to the FBCA and Entity CAs.

5.2.1 Trusted Roles

A trusted role is one whose incumbent performs functions that can introduce security problems if not carried out properly, whether accidentally or maliciously. The personnel selected to fill these roles must be extraordinarily responsible or the integrity of the CA is weakened. The functions performed in these roles form the basis of trust the entire PKI. Two approaches are taken to increase the likelihood that these roles can be successfully carried out. The first ensures that the person filling the role is trustworthy and properly trained. The second distributes the functions among more than one person, so that any malicious activity would require collusion. An auditable record must be created identifying when personnel are added or removed from a trusted role, as well as who added or removed them from the role. The individual who authorized the role assignment, or any series of role assignments over a given period of time, must also be traceable via audit and archive records.

Trusted Role appointments must be documented and archived as defined in Section 5.4 and Section 5.5.

5.2.1.1 Certification Authority Trusted Roles

The requirements of this policy are defined in terms of four roles; implementing organizations may define additional roles provided the following separation of duties are enforced.

1. *Administrator* – authorized to install, configure, and maintain the CA, or, optionally, KED or DDS; establish and maintain system accounts; configure audit parameters; and generate PKI component keys.
2. *Officer* – authorized to request or approve certificate issuance and revocations.
3. *Auditor* – authorized to review, maintain, and archive audit logs.
4. *Operator* – authorized to perform system backup and recovery.

Administrators do not issue certificates to subscribers.

These four roles are employed at the CA, CMS, KRS, and CSS locations as appropriate. Separation of duties must comply with Section 5.2.4, and requirements for two-person control with Section 5.2.2, regardless of the titles and numbers of Trusted Roles.

5.2.1.2 Registration Authority Trusted Roles

An RA may be considered an Officer as defined in Section 5.2.1.1 and is responsible for:

- verifying initial identity, as described in Section 3.2;
- entering Subscriber information, and verifying correctness;
- securely communicating requests to and responses from the CA;
- receiving and distributing Subscriber certificates;

The RA role is highly dependent on implementation and local requirements. The responsibilities and controls for RAs shall be explicitly described in the CPS of a CA if the CA uses an RA.

5.2.1.3 Key Recovery Trusted Roles

Due to the security implications and impacts to confidentiality services associated with key recovery, the number and location of Key Recovery Trusted Roles should be closely controlled.

Some PKIs may leverage the RAs to fulfill Key Recovery functions.

5.2.1.3.1 Key Recovery Agent (KRA)

Entity PKIs that support key escrow and recovery must define what trusted roles cover the following responsibilities to ensure that the following functions occur according to the stipulations of the applicable policy:

- Authorized to authenticate requests and recover copies of escrowed keys; and
- Authorized to distribute copies of recovered keys to Requestor, with protection as described in Section 4.12.1.2.1.

5.2.1.3.2 Key Recovery Official (KRO)

Entity PKIs that support key escrow and recovery may have KROs defined as Trusted Roles if they have privileged access to the KED.

A KRO's responsibilities are to ensure that the following functions occur according to the stipulations of the applicable policy:

- Authorized to verify a Requestor's identity and authorization as stated by this policy;
- Authorized to build key recovery requests on behalf of authorized Requestor;
- Authorized to securely communicate key recovery requests to and responses from the KRA; and

- Authorized to participate in distribution of escrowed keys to the Requestor, as described by the associated practice statement (CPS or KRPS).

5.2.2 Number of Persons Required per Task

Only one person is required per task for CAs operating at the Rudimentary and Basic Levels of Assurance.

Two or more persons are required for CAs operating at the Medium (all policies) or High Levels of Assurance for the following tasks:

- CA, KED, or DDS key generation.
- CA signing key activation.
- CA, KED, or DDS private key backup.

Where multiparty control is required, at least one of the participants must be an Administrator. All participants must serve in a trusted role as defined in Section 5.2.1. Multiparty control for logical access must not be achieved using personnel that serve in the Auditor Trusted Role.

5.2.3 Identification and Authentication for Each Role

At all assurance levels other than Rudimentary, an individual must identify and authenticate him/herself before being permitted to perform any actions set forth above for that role or identity.

5.2.4 Roles Requiring Separation of Duties

Requirements for the separation of roles, and limitations on use of procedural mechanisms to implement role separation, are described below for each level of assurance:

Assurance Level	Role Separation Rules
Rudimentary	No stipulation.
Basic	Individual personnel must be specifically designated to the four roles defined in Section 5.2.1 above. Individuals may assume more than one role; however, no one individual shall assume both the Officer and Administrator roles. This may be enforced procedurally. No individual shall be assigned more than one identity.
Medium (all policies) PIV-I Card Authentication	Individual personnel must be specifically designated to the four roles defined in Section 5.2.1 above. Individuals may assume only one of the Officer, Administrator, and Auditor roles, but any individual may assume the Operator role. The CA, CMS, and RA software and hardware must identify and authenticate its users and must ensure that no user identity can assume both an Administrator and an Officer role, assume both the Administrator and Auditor

Assurance Level	Role Separation Rules
	roles, or assume both the Auditor and Officer roles. No individual may have more than one identity.
High	Individual personnel must be specifically designated to the four roles defined in Section 5.2.1 above. Individuals may assume only one of the Officer, Administrator and Auditor roles. Individuals designated as Officer or Administrator may assume the Operator role. An auditor may not assume any other role. The CA and RA software and hardware must identify and authenticate its users and must enforce these roles. No individual shall have more than one identity.

The FBCA operates at the High Assurance level.

5.3 PERSONNEL CONTROLS

5.3.1 Qualifications, Experience, and Clearance Requirements

All persons filling trusted roles must be selected on the basis of loyalty, trustworthiness, and integrity. For the FBCA and Federal Agency PKIs, regardless of the assurance level, all trusted roles must be held by U.S. citizens. For PKIs operated at Medium Assurance and Medium Hardware, each person filling a trusted role must satisfy at least one of the following:

- The person must be a citizen of the country where the CA is located; or
- For PKIs operated on behalf of multinational governmental organizations, the person must be a citizen of one of the member countries; or
- For PKIs located within the European Union, the person must be a citizen of one of the member States of the European Union; or
- For PKIs other than the FBCA and Federal Agency PKIs, the person must have a security clearance equivalent to U.S. Secret or higher issued by a NATO member nation or major non-NATO ally as defined by the International Traffic in Arms Regulation (ITAR) – 22 CFR 120.32; or
- For RA personnel only, in addition to the above, the person may be a citizen of the country where the RA is located.

For PKIs, other than the FBCA and Federal Agency PKIs, only operated at Rudimentary, Basic, Medium-CBP and Medium Hardware-CBP, there is no citizenship requirement or security clearance specified.

The FPKIMA Program Manager must hold a TOP SECRET security clearance.

5.3.2 Background Check Procedures

FPKIMA personnel acting in trusted roles must, at a minimum, undergo procedures necessary to be cleared at the TOP SECRET level.

CA personnel must receive a favorable adjudication after undergoing a background investigation covering the following areas:

- Employment;
- Education;
- Place of residence;
- Law Enforcement; and
- References.

The period of investigation must cover at least the last five years for each area, excepting the residence check which must cover at least the last three years. Regardless of the date of award, the highest educational degree must be verified.

Adjudication of the background investigation must be performed by a competent adjudication authority using a process consistent with [Executive Order 12968] or equivalent.

If a formal clearance is the basis for background check, the background refresh must be in accordance with the corresponding formal clearance. Otherwise, the background check must be refreshed every ten years.

Practice Note for federal agencies: A successfully adjudicated National Agency Check with Written Inquires (NACI) or National Agency Check with Law Enforcement Check (NACLC) on record is deemed to have met the minimum standards specified above.

Practice Note for nongovernmental partners: The qualifications of the adjudication authority and procedures utilized to satisfy these requirements must be demonstrated before cross certification with the FBCA.

5.3.3 Training Requirements

All personnel performing duties with respect to the operation of the CA or RA must receive comprehensive.

Training must be conducted in the following areas:

- CA (or RA) security principles and mechanisms;
- Key Recovery System security principles and mechanisms;
- All PKI software versions in use on the CA (or RA) system;

- All PKI duties they are expected to perform;
- Disaster recovery and business continuity procedures; and
- Stipulations of the applicable CP and CPS.

Documentation must be maintained identifying all personnel who received training and the level of training completed.

5.3.4 Retraining Frequency and Requirements

Individuals responsible for PKI roles must be aware of changes in the CA operation. Any significant change to the operations must have a training (awareness) plan, and the execution of such plan must be documented. Examples of such changes are CA software or hardware upgrade, changes in automated security systems, and relocation of equipment.

Documentation must be maintained identifying all personnel who received retraining and the level of retraining completed.

5.3.5 Job Rotation Frequency and Sequence

Job rotation is optional. Any job rotation frequency and sequencing procedures must provide for continuity and integrity of the CA services.

Job rotation must not violate role separation. All access rights associated with a previous role must be terminated.

All job rotations must be documented. Individuals assuming an auditor role must not audit their own work from a previous role.

5.3.6 Sanctions for Unauthorized Actions

A CA must take appropriate administrative and disciplinary actions against personnel who have performed actions involving the CA or its RAs that are not authorized in the corresponding CP, CPS, or other documented procedures.

5.3.7 Independent Contractor Requirements

Contractors fulfilling Trusted Roles must be subject to all personnel requirements stipulated in the corresponding policy.

PKI vendors who provide any services must establish procedures to ensure that any subcontractors perform in accordance with the CP and the CPS.

5.3.8 Documentation Supplied to Personnel

Documentation sufficient to define duties and procedures for each trusted role must be provided to the personnel filling that role.

5.4 AUDIT LOGGING PROCEDURES

The objective of audit log processing is to review all actions to ensure they are made by authorized parties and for legitimate reasons.

At a minimum, audit records must be generated for all applicable events identified in Section 5.4.1 of this policy and must be available during audit reviews and third-party audits. For CAs operated in a virtual environment, audit records must be generated for all applicable events on application software and all system software layers.

Where possible, the security audit logs must be automatically collected. Where this is not possible, a logbook, paper form, or other physical mechanism must be used. All security audit logs, both electronic and non-electronic, must be retained and made available during compliance audits. Implementation and documentation of automated tools must describe how relevant events and anomalies are recorded.

Audit record reviews should be performed using an automated process, and must include verification that the logs have not been tampered with, an inspection of log entries, and a root cause analysis for any alerts or irregularities.

A record of the review, all significant events, and any actions taken as a result of these reviews must be explained in an audit log summary. This review summary must be retained as part of the long-term archive.

When Key escrow and Recovery is supported, all KED audit records of unsuccessful key recoveries must be analyzed to determine the cause and to ensure that the KRS is operating correctly and securely, and is not vulnerable to unauthorized use.

Real-time alerts are neither required nor prohibited by this policy.

5.4.1 Types of Events Recorded

All security auditing capabilities of CA operating system and CA applications required by this CP must be enabled during installation. At a minimum, each audit record must include the following (either recorded automatically or manually for each auditable event):

- What type of event occurred;
- Date and time when the event occurred;
- Where the event occurred (e.g., on what systems or in what physical locations);
- Source of the event;
- Outcome of the event to include success or failure; and
- Identity of any individuals, subjects, or objects/entities associated with the event.

Any request or action requiring the use of a private key controlled by the CA is an auditable event.

If out-of-band processes are used for authorization of certificate issuance, external artifacts from the process (e.g., forms, emails, etc.) must be recorded.

Practice Note: Events related to CA certificate issuance may be different from those related to subscriber certificate issuance.

The CA and KRS must record the events identified in the table below, where applicable to the application, environment, or both. Where these events cannot be electronically logged, electronic audit logs must be supplemented with physical logs as necessary.

Auditable Event	Rudimentary	Basic	Medium (all policies), PIV-I Card Authentication & High
SECURITY AUDIT			
Any changes to the Audit parameters, e.g., audit frequency, type of event audited		X	X
Any attempt to delete or modify the Audit logs		X	X
IDENTIFICATION AND AUTHENTICATION			
Platform or CA application level authentication attempts		X	X
The value of maximum authentication attempts is changed		X	X
The number of unsuccessful authentication attempts exceeds the <i>maximum authentication attempts</i> during user login		X	X
An Administrator unlocks an account that has been locked as a result of unsuccessful authentication attempts		X	X
An Administrator changes the type of authenticator, e.g., from smart card login to password		X	X

Auditable Event	Rudimentary	Basic	Medium (all policies), PIV-I Card Authentication & High
DATA ENTRY AND OUTPUT			
Any additional event that is relevant to the security of the CA (such as remote or local data entry or data export); must be documented		X	X
KEY GENERATION			
Whenever the CA generates a key. (Not mandatory for single session or one-time use symmetric keys)	X	X	X
PRIVATE KEY LOAD AND STORAGE			
The loading of CA, RA, CSS, CMS, or other keys used by the CA in the lifecycle management of certificates	X	X	X
All access to certificate subject private keys retained within the CA for key recovery purposes	X	X	X
TRUSTED PUBLIC KEY ENTRY, DELETION AND STORAGE			
Any changes to public keys used by components of the CA to authenticate other components or authorize certificate lifecycle requests (e.g., RA or CMS trust stores)	X	X	X
PRIVATE AND SECRET KEY EXPORT			
The export of private and secret keys (keys used for a single session or message are excluded)	X	X	X
CERTIFICATE REGISTRATION			
All records related to certificate request authorization, approval and	X	X	X

Auditable Event	Rudimentary	Basic	Medium (all policies), PIV-I Card Authentication & High
signature, whether generated directly on the CA or generated by a related external system or process			
CERTIFICATE REVOCATION			
All records related to certificate revocation request authorization, approval and execution, whether generated directly on the CA or generated by a related external system or process		X	X
CERTIFICATE STATUS CHANGE APPROVAL			
All records related to certificate status change request authorization, approval and execution, whether generated directly on the CA or generated by a related external system or process		X	X
CA CONFIGURATION			
Any security-relevant changes to the configuration of the CA. The specific configuration items relevant to the environment in which the CA operates must be identified and documented.		X	X
ACCOUNT ADMINISTRATION			
Roles and users are added or deleted	X	X	X
The access control privileges of a user account or a role are modified	X	X	X
CERTIFICATE PROFILE MANAGEMENT			
All changes to the certificate profile	X	X	X

Auditable Event	Rudimentary	Basic	Medium (all policies), PIV-I Card Authentication & High
CERTIFICATE REVOCATION LIST PROFILE MANAGEMENT			
All changes to the certificate revocation list profile		X	X
MISCELLANEOUS			
Record of an individual being added or removed from a trusted role, and who added or removed them from the role	X	X	X
Installation of the Operating System		X	X
Installation of the CA		X	X
Installing hardware cryptographic modules			X
Removing hardware cryptographic modules			X
Destruction of cryptographic modules		X	X
System Startup		X	X
Logon Attempts to CA Applications		X	X
Receipt of Hardware/Software			X
Attempts to set passwords		X	X
Attempts to modify passwords		X	X
Backing up CA internal database		X	X
Restoring CA internal database		X	X
Records of manipulation of critical files (e.g., creation, renaming, moving), critical files will vary			X

Auditable Event	Rudimentary	Basic	Medium (all policies), PIV-I Card Authentication & High
between installation, and must be identified in the relevant documentation			
The date and time any CA artifact is posted to a public repository			X
Access to CA internal database			X
All certificate compromise notification requests		X	X
Loading tokens with certificates			X
Shipment and receipt of tokens containing key material, or tokens that allow access to key material (e.g., HSM operator cards)			X
Zeroizing tokens		X	X
Re-key of the CA	X	X	X
Configuration changes to the CA server involving:			
- Hardware		X	X
- Software		X	X
- Operating System		X	X
- Patches		X	X
- Security Profiles			X
PHYSICAL ACCESS / SITE SECURITY			
Personnel Access to room housing CA			X

Auditable Event	Rudimentary	Basic	Medium (all policies), PIV-I Card Authentication & High
Access to the CA server			X
Known or suspected violations of physical security		X	X
ANOMALIES			
Software Error conditions		X	X
Software check integrity failures		X	X
Equipment failure	X	X	X
Electrical power outages			X
Uninterruptible Power Supply (UPS) failure			X
Network service or access failures that could affect certificate trust			X
Violations of Certificate Policy	X	X	X
Violations of Certification Practice Statement	X	X	X
Resetting Operating System clock		X	X

5.4.2 Frequency of Processing Log

Audit records must be reviewed at least once every month for online CAs that issue certificates at Basic or above. For offline CAs, the audit logs must be reviewed when the system is activated or every 30 days, whichever is later. CSS, CMS, IDMS and KRS audit log processing frequency shall align with the CA audit log processing frequency.

Assurance Level	Review Audit Log
Rudimentary	Only required for cause
Basic	At least once per month

Assurance Level	Review Audit Log
Medium (all policies) & PIV-I Card Authentication	At least once per month
High	At least once per month

5.4.3 Retention Period for Audit Logs

At all assurance levels other than Rudimentary audit records must be accessible until reviewed, in addition to specific records being archived as described in Section 5.5

Practice Note: OMB M-21-31 requires Federal agencies maintain all audit records in active storage for a minimum of 12 months from generation.

5.4.4 Protection of Audit Logs

System configuration and operational procedures must be implemented together to ensure that only authorized individuals may move or archive audit records and that audit records are not modified.

Collection of the audit records from the CA system must be performed by, witnessed by or under the control of trusted roles who are different from the individuals who, in combination, command the CA signature key.

For RA systems, the individual authorized to move or archive records may not hold an RA Trusted Role.

Procedures must be implemented to protect audit records from deletion or destruction before they are reviewed. as described in Section 5.4.2. To protect the integrity of audit records, they must be transferred to a backup environment distinct from the environment where the audit records are generated.

5.4.5 Audit Log Backup Procedures

Audit records and audit summaries must be backed up at least monthly.

If audit records are stored locally in the system where the events occur, they must be transferred to a backup environment and protected as described in Section 5.4.4. The backup procedure may be automated or manual, but must occur no less frequently than the audit log review described in Section 5.4.2.

The process for transferring the audit records to the backup environment must be documented.

5.4.6 Audit Collection System (Internal vs. External)

The audit log collection system may or may not be external to the CA system or KRS. Automated audit processes must be invoked at system (or application) startup, and cease only at system (or application) shutdown. Audit collection systems must be configured such that security audit data is protected against loss (e.g., overwriting or overflow of automated log files). If an automated audit system has failed, and the integrity of the system or confidentiality of the information protected by the system is at risk, operations must be suspended until the problem has been remedied.

5.4.7 Notification to Event-Causing Subject

There is no requirement to notify a subject that an event was audited. Real-time alerts are neither required nor prohibited by this policy.

5.4.8 Vulnerability Assessments

CAs must perform routine vulnerability assessments of the security controls described in the applicable policy.

For Federal Agencies operating under this policy, self-assessment of controls and control effectiveness (e.g., FISMA) must be performed in accordance with the frequency determined by the risk rating of the CA.

Automated vulnerability scans, if executed, should be run no less frequently than required by the risk rating of the component.

The methodology, tools and frequency of the vulnerability assessment must be documented.

Practice Note: The security audit data should be reviewed by the security auditor for events such as repeated failed actions, requests for privileged information, attempted access of system files, requests for escrowed keys, attempted access of escrowed keys, unauthenticated responses, and other suspicious or unusual activity. Security Auditors should check for continuity of the security audit data.

5.5 RECORDS ARCHIVAL

CAs and KRSs must comply with their respective records retention policies in accordance with whatever laws apply to those entities.

The primary objective of the CA archive is to prove the validity of any certificate (including those revoked or expired) issued by the CA in the event of dispute regarding the use of the certificate.

The primary objective of the KRS archive is reconstruction of key recovery activities, in case of dispute. Examples of disputes may include:

- Validation of key recovery requests
- Validation of the identity of the recipient of an escrowed key;
- Verification of authorization to obtain the escrowed key copy;
- Verification of transfer of custody of escrowed keys to an authorized Requestor; and
- Establishment of the circumstances under which a copy of the escrowed key was provided.

5.5.1 Types of Events Archived

At a minimum, the following data must be recorded for archive as specified for each assurance level:

Data To Be Archived	Rudimentary	All Other Policies
Certificate Policy	X	X
Certification Practice Statement / Key Recovery Practice Statement	X	X
Contractual obligations	X	X
Other agreements concerning operations of the CA or KRS	X	X
System and equipment configuration	X	X
Modifications and updates to system or configuration	X	X
All records related to certificate request authorization, approval and signature, whether generated directly on the CA or generated as part of a related external system or process	X	X
All records related to certificate revocation, whether generated directly on the CA or generated as part of a related external system or process		X
Subscriber identity Authentication data as per Section 3.2.3		X

Data To Be Archived	Rudimentary	All Other Policies
Documentation of receipt and acceptance of certificates (if applicable)		X
Subscriber Agreements		X
Documentation of receipt of tokens		X
All certificates issued or published	X	X
Record of CA Re-key	X	X
Other data or applications to verify archive contents		X
Audit summary reports generated by internal reviews and documentation generated during third party audits		X
Any changes to the Audit parameters, e.g., audit frequency, type of event audited		X
Any attempt to delete or modify the Audit logs		X
Whenever the CA generates a key. (Not mandatory for single session or one-time use symmetric keys)	X	X
All access to certificate subject private keys retained for key recovery purposes	X	X
Changes to trusted public keys used or published by the CA including certificates used for trust between the CA and other components such as CMS, RA, etc	X	X

Data To Be Archived	Rudimentary	All Other Policies
The export of private and secret keys (keys used for a single session or message are excluded)	X	X
The approval or rejection of a certificate status change request		X
Record of an individual being added or removed from a trusted role, and who added or removed them from the role_(to include KRA/KRO)	X	X
Destruction of cryptographic modules		X
All certificate compromise notifications		X
Remedial action taken as a result of violations of physical security		X
Violations of Certificate Policy	X	X
Violations of Certification Practice Statement	X	X

5.5.2 Retention Period for Archive

Archive retention periods begin at the key generation event for any CA. For CAs that leverage key-rollover procedures a new retention period begins for each subsequent key generation event.

CAs will maintain all archived records related to that CA, in an accessible fashion, for 3 years after CA expiration or CA termination.

Individual RA records associated with certificate request authorization, certificate revocation, subscriber authentication, or subscriber certificate acceptance must be maintained for a minimum of 3 years after the subject certificate expiration date. Issuance of new certificates with extended validity periods (i.e., renewal, rekey or modification) supported by existing subscriber authentication records (i.e., authentication using an existing valid certificate) will result in a new retention period for those initial records, based on the new certificate expiration date.

Practice Note: RA archive records can be retained for as long as business purposes require; however, this policy does not waive any organizational policies that may require the destruction of such records or otherwise limit their retention periods.

Practice Note: If the archive records are maintained separately from the CA, communication processes may be required to determine when archive records are no longer needed based on related public certificates.

National Archives and Records Administration General Records Schedules [NARA GRS], 5.6 Item 120, defines required enrollment chain-of-trust records, and archive retention periods related to credentials issued in support of HSPD-12.

RA system operations audit records, that include any IT resources that facilitate RA functions, must maintain relevant archives for a minimum of 3 years after RA system replacement or termination.

5.5.3 Protection of Archive

Only Auditors, as described in Section 5.2, or other personnel specifically authorized by the CA, are permitted to add or delete records from the archive. Deletion of records identified in Section 5.5.1 before the end of the retention period is not permitted under any circumstances. The contents of the archive must not be released except in accordance with Sections 9.3 and 9.4.

Archive media must be stored in a safe, secure storage facility geographically separate from the CA in accordance with its records retention policies. The transfer process between the backup environment and archive location must be documented.

In order to ensure that records in the archive may be referenced when required, the CA must do one of the following:

- Maintain the hardware or software required to process or read the archive records, or
- Define a process to transfer records to a new format or medium when the old format or medium becomes obsolete and verify the integrity of the records after transfer

5.5.4 Archive Backup Procedures

If a cross-certified entity chooses to backup its archive records, the CPS or a referenced document must describe how the records are backed up and managed.

5.5.5 Requirements for Time-Stamping of Records

CA archive records must have accurate timestamps when they are added to the archive.

The time precision must be such that the sequence of events can be determined.

The CPS or KRPS must describe how system clocks used for timestamping are maintained in synchrony with an authoritative time standard.

5.5.6 Archive Collection System (Internal or External)

Archive data may be collected in any expedient manner, but must be documented in the associated CPS/KRPS.

5.5.7 Procedures to Obtain and Verify Archive Information

Procedures detailing how to create, verify, package, transmit, and store archive information must be included in the CP, KRP, CPS, or KRPS.

Copies of records of individual transactions may be released upon request of any subscribers involved in the transaction or their legally recognized agents.

5.6 KEY CHANGEOVER

Each CA's signing key must have a validity period as described in Section 6.3.2.

Prior to the end of a CA's signing key validity period, a new CA must be established or a re-key on the existing CA must be performed. This is referred to as key changeover. From that time on, only the new key is used to sign CA and Subscriber certificates. The old private key may continue to be used to sign CRLs and OCSP Responder certificates. If the old private key is used to sign OCSP Responder certificates or CRLs that cover certificates signed with that key, the old key must be retained and protected.

After all certificates signed with the old key have expired or been revoked, the CA may issue a final long-term CRL using the old key, with a nextUpdate time past the validity period of all issued certificates. This final CRL must be available for all relying parties until the validity period of all issued certificates has passed. Once the last CRL has been issued, the old private signing key of the CA may be destroyed.

When a CA performs a key changeover and thus generates a new public key, the CA must notify all CAs, RAs, and Subscribers that rely on the CA's certificate that it has been changed. The CA must do one of the following:

- Generate key rollover certificate, where the new public key is signed by the old private key, and vice versa or
- Obtain a new CA certificate for the new public key from each issuer of the current CA certificate(s).

5.7 COMPROMISE AND DISASTER RECOVERY

CAs must have an incident handling process, which documents any security incidents. Security incidents may include violation or threat of violation to the system, improper usage, malicious or anomalous activity and violations of the CPS or CP.

5.7.1 Incident and Compromise Handling Procedures

The FPKIPA must be notified within 24 hours if the FBCA or an Entity CA experiences the following:

- suspected or detected compromise of the CA systems;
- physical or electronic penetration of CA systems;
- successful denial of service attacks on CA components;
- any incident preventing the CA from issuing a CRL prior to the nextUpdate time of the previous CRL;
- suspected or detected compromise of a CSS;
- suspected or detected compromise of an RA.

The notification must include preliminary remediation analysis.

Once the incident has been resolved, the organization operating the CA must provide notification directly to the FPKIPA which includes detailed measures taken to remediate the incident. The notice must include the following:

1. Which CA components were affected by the incident
2. The CA's interpretation of the incident
3. Who is impacted by the incident
4. When the incident was discovered
5. A complete list of all certificates that may have been issued erroneously or are not compliant with the CP/CPS as a result of the incident
6. A statement that the incident has been fully remediated

5.7.2 Computing Resources, Software, and/or Data are Corrupted

When computing resources, software, and/or data are corrupted, the CAs must respond as follows:

- Before returning to operation, ensure that the system's integrity has been restored
- If the CA signature keys are not destroyed, CA operation must be reestablished, giving priority to the ability to generate certificate status information within the CRL issuance schedule specified in Section 4.9.7.
- If the CA signature keys are destroyed, CA operation must be reestablished as quickly as possible, giving priority to the generation of a new CA key pair.

In the event of an incident as described above, the Entity CA must post a notice on its web page identifying the incident and provide notification to the FPKIPA. See Section 5.7.1 for contents of the notice.

5.7.3 Entity (CA) Private Key Compromise Procedures

5.7.3.1 CA Private Key Compromise Procedures

In the event of a CA private key compromise, the following operations must be performed:

- The CA must immediately inform the FPKIPA and any entities known to be distributing the CA certificate (e.g., in a root store).
- The CA must request revocation of any certificates issued to the compromised CA.
- The CA must generate new keys in accordance with Section 6.1.1.1.

If the CA distributed the public key in a Trusted Certificate, the CA must perform the following operations:

- Generate a new Trusted Certificate.
- Securely distribute the new Trusted Certificate as specified in Section 6.1.4.
- Initiate procedures to notify Subscribers of the compromise.

Subscriber certificates issued prior to compromise of the CA private key may be renewed automatically by the CA under the new key pair (see Section 4.6) or the CA may require Subscribers to repeat the initial certificate application process.

The CA governing body is encouraged to also investigate and report to the FPKIPA what caused the compromise or loss.

5.7.3.2 KRS Private Key Compromise Procedures

In the event that the KED or DDS is compromised or is suspected to be compromised, the following operations must be performed:

- Notify the FPKIPA of the compromise
- Provide detail concerning the root cause, operational impact, and initial remediation actions
- Determine the extent of the compromise
- Gain concurrence from the FPKIPA on planned resolution. This may include revocation of certificates associated with the compromised private keys stored in the KED or DDS.

If a KRA or KRO certificate is revoked due to compromise, the potential exists for some Subscribers' escrowed keys to have been exposed during a recovery process, the following operations must be performed:

- Audit record review by the audit administrator to identify all potentially exposed escrowed keys.
- Revocation of each of the potentially exposed escrowed keys, according to procedures specified in Section 4.9.3, to include Subscriber notification of the revocation

- Reissuance of the KRA or KRO authentication certificate

5.7.4 Business Continuity Capabilities after a Disaster

The CA repository system must be deployed to provide 24-hour, 365 day per year availability with high levels of repository reliability.

CAs must have recovery procedures in place to reconstitute the CA after failure.

In the case of a disaster whereby the CA installation is physically damaged and all copies of the CA signature key are destroyed as a result, the FPKIPA must be notified at the earliest feasible time, and the FPKIPA must take whatever action it deems appropriate.

5.8 CA OR RA TERMINATION

In the event the decision is made to terminate FBCA operations, of termination of the FBCA operation, the following must be accomplished prior to termination:

- Notify all cross-certified Entities.
- Revoke any issued certificates that have not expired
- Generate and publish a final long term CRL with a nextUpdate time past the validity period of all issued certificates. This final CRL must be available for all relying parties until the validity period of all issued certificates has passed.
- Once the last CRL has been issued, destroy the private signing key(s) of the FBCA.
- Transfer all archive data to an archival facility.

Entities will be given as much advance notice as circumstances permit, and attempts to provide alternative sources of interoperation will besought.

Whenever possible, the FPKIPA must be notified at least two weeks prior to the termination of any Entity CA. For emergency termination, CAs must follow the notification procedures in Section 5.7.

6. TECHNICAL SECURITY CONTROLS

6.1 KEY PAIR GENERATION AND INSTALLATION

6.1.1 Key Pair Generation

Key generation must be performed using a FIPS approved method or equivalent international standard, with the exception of subscriber rudimentary keys. Key generation events should use the configuration that was the basis of the FIPS or other approved standard (e.g., FIPS mode). If the required keys cannot be generated while in an approved configuration, the specific configuration and reason for use of a different method should be documented by the CA.

6.1.1.1 CA Key Pair Generation

Cryptographic keying material used to sign certificates, CRLs or status information must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1 or modules validated under equivalent international standards. Multiparty control is required for CA key pair generation, as specified in Section 6.2.2.

CA key pair generation must create a verifiable audit trail that the security requirements for procedures were followed. For all levels of assurance, the documentation of the procedure must be detailed enough to show that appropriate role separation was used.

For High, Medium Hardware, and Medium Assurance, an independent third party must validate the execution of the key generation procedures either by witnessing the key generation or by examining the signed and documented record of the key generation.

6.1.1.2 Subscriber Key Pair Generation

Subscriber key pair generation may be performed by the subscriber, CA, or RA. If the CA or RA generates subscriber key pairs, the requirements for key pair delivery specified in Section 6.1.2 must also be met.

For PIV-I, all keys, except for key management, must be generated on the card. (See Appendix A.)

For all other certificates at the High and Medium Hardware assurance levels, subscriber key generation must be performed using a validated hardware cryptographic module as specified in Section 6.2.1. For Medium and Basic assurance, either validated software or validated hardware cryptographic modules must be used for key generation as specified in Section 6.2.1.

6.1.1.3 CSS Key Pair Generation

Cryptographic keying material used by CSSs to sign status information must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1.

6.1.1.4 PIV-I Content Signing Key Pair Generation

Cryptographic keying material used by PIV-I issuing systems or devices for PIV-I Content Signing must be generated in [FIPS 140] validated cryptographic modules as specified in Section 6.2.1.

6.1.2 Private Key Delivery to Subscriber

If subscribers generate their own key pairs, then there is no need to deliver private keys, and this section does not apply.

When CAs or RAs generate keys on behalf of the Subscriber, then the private key must be delivered securely to the Subscriber. Private keys may be delivered electronically or may be delivered on a hardware cryptographic module. In all cases, the following requirements must be met:

- Anyone who generates a private signing key for a Subscriber must not retain any copy of the key after delivery of the private key to the Subscriber.
- The private key must be protected from activation, compromise, or modification during the delivery process.
- The Subscriber must acknowledge receipt of the private key(s).
- Delivery must be accomplished in a way that ensures that the correct tokens and activation data are provided to the correct Subscribers.
 - For hardware modules, accountability for the location and state of the module must be maintained until the Subscriber accepts possession of it.
 - For electronic delivery of private keys, the key material must be encrypted using a cryptographic algorithm and key size at least as strong as the private key. Activation data must be delivered using a separate secure channel.
 - For shared key applications, organizational identities, and network devices, see also Section 3.2.

The CA must maintain a record of the subscriber acknowledgement of receipt of the token.

6.1.3 Public Key Delivery to Certificate Issuer

For CAs issuing certificates that assert policies other than Rudimentary, the following requirements apply:

- Where key pairs are generated by the Subscriber or RA, the public key and the Subscriber's identity must be delivered securely to the CA for certificate issuance.
- The delivery mechanism must bind the Subscriber's verified identity to the public key. If cryptography is used to achieve this binding, it must be at least as strong as the Subscriber key pair.

For Rudimentary Assurance, no stipulation.

6.1.4 CA Public Key Delivery to Relying Parties

Self-signed root CA certificates must be conveyed to relying parties in a secure fashion to preclude substitution attacks. Acceptable methods include:

- Secure distribution of the certificate through secure out-of-band mechanisms;
- Download the certificate from a Federal Government operated web site secured with a currently valid certificate and subsequent comparison of the hash of the certificate against a hash value made available via authenticated out-of-band sources (note that hashes posted in-band along with the certificate are not acceptable as an authentication mechanism)

Practice Note: Other methods that preclude substitution attacks may be considered acceptable.

6.1.5 Key Sizes

This CP requires use of RSA PKCS #1, RSASSA-PSS, or ECDSA signatures; additional restrictions on key sizes and hash algorithms are detailed below. Certificates must contain 2048-, 3072-, or 4096-bit RSA keys, or 256- or 384-bit elliptic curve keys.

	CA certificates that expire on or before December 31, 2030	CA certificates that expire after December 31, 2030
Minimum Key Size	RSA: 2048 Elliptic Curve: 256	RSA: 3072 Elliptic Curve: 256
Hash Algorithm	SHA-256, SHA-384, or SHA-512	SHA-256, SHA-384, or SHA-512

	Subscriber certificates that expire on or before December 31, 2030	Subscriber certificates that expire after December 31, 2030
Minimum Key Size	RSA: 2048 Elliptic Curve: 256	RSA: 3072 Elliptic Curve: 256
Hash Algorithm	SHA-256, SHA-384, or SHA-512	SHA-256, SHA-384, or SHA-512

All Subscriber certificates associated with PIV-I must contain public keys and algorithms that conform to [NIST SP 800-78].

Use of Transport Layer Security (TLS) or another protocol providing similar security to accomplish any of the requirements of this CP must require at a minimum AES (128 bits) or equivalent for the symmetric key, and at least 2048-bit RSA or equivalent for the asymmetric keys. After December 31, 2030, use of TLS or another protocol providing similar security to accomplish any of the requirements of this CP must require at a minimum AES (128 bits) or equivalent for the symmetric key, and at least 3072-bit RSA or equivalent for the asymmetric keys.

KED and DDS keys must be at equal to or stronger than the keys being escrowed.

6.1.6 Public Key Parameters Generation and Quality Checking

For RSA, the CA shall perform partial public key validation as specified in NIST SP 800-89 (section 5.3.3).

For ECC, public keys must fall within curves defined in Section 7.1.3. Additionally, the CA should confirm the validity of all keys using either the ECC Full Public Key Validation Routine or the ECC Partial Public Key Validation Routine as specified in NIST SP 800-56A (Sections 5.6.2.3.3, or 5.6.2.3.4).

6.1.7 Key Usage Purposes (as per X.509 v3 Key Usage Field)

Public keys that are bound into certificates must be certified for use in signing or encrypting, but not both, except as specified below. The use of a specific key is determined by the key usage extension in the X.509 certificate.

All certificates must include a critical Key Usage extension

- Certificates to be used only for authentication must set only the digitalSignature bit.
- Certificates to be used by Human Subscribers for digital signatures must set the digitalSignature and nonRepudiation bits.
- Certificates that have the nonRepudiation bit set, must not have keyEncipherment bit or keyAgreement bit set.
- Certificates to be used for encryption (RSA) must set the keyEncipherment bit.
- Certificates to be used for key agreement (ECC) must set the keyAgreement bit.
- CA certificates must set only cRLSign and keyCertSign bits.

Keys associated with CA certificates must be used only for signing certificates and CRLs.

Keys associated with Device Subscriber certificates may be used for digital signature (including authentication), encryption, or both. Except for OCSP Responder certificates, device certificates must not assert the nonRepudiation bit.

Rudimentary, Basic, and Medium Assurance Level certificates may include a single key for use with encryption and signature in support of legacy applications. Such dual-use certificates must be generated and managed in accordance with their respective signature certificate requirements,

except where otherwise noted in this CP. Such dual-use certificates must never assert the non-repudiation key usage bit, and must not be used for authenticating data that will be verified on the basis of the dual-use certificate at a future time. Entities are encouraged at all levels of assurance to issue Subscribers two key pairs, one for key management and one for digital signature and authentication.

For all Subscriber certificates issued after June 30, 2019, the Extended Key Usage extension must always be present. Extended Key Usage OIDs must be consistent with key usage bits asserted. The Extended Key Usage extension must not contain *anyExtendedKeyUsage* {2.5.29.37.0}.

PIV-I Content Signing certificates must include a critical Extended Key Usage extension that asserts only *id-fpki-pivi-content-signing* {2.16.840.1.101.3.8.7} (see [PIV-I Profile]).

PIV-I Card Authentication certificates must include a critical Extended Key Usage extension that asserts *id-piv-cardAuth* {2.16.840.1.101.3.6.8}

6.2 PRIVATE KEY PROTECTION AND CRYPTOGRAPHIC MODULE ENGINEERING CONTROLS

6.2.1 Cryptographic Module Standards and Controls

The relevant standard for cryptographic modules is [FIPS 140], *Security Requirements for Cryptographic Modules*. A FIPS 140 Level 1 or higher validated cryptographic module must be used for all cryptographic operations.

Cryptographic modules must be minimally validated to the FIPS 140 level identified in this section. Additionally, the FPKIPA reserves the right to review technical documentation associated with any cryptographic modules under consideration for use by the FBCA.

Practice Note: The Federal PKI Policy Authority may determine that other comparable validation, certification, or verification standards are sufficient when cross-certifying with non-U.S. government PKIs.

The table below summarizes the minimum FIPS 140 requirements for cryptographic modules; higher levels may be used.

Assurance Level	CA	CMS & CSS	Subscriber	RA
Rudimentary	Level 1	Level 1	N/A	Level 1
Basic	Level 2	Level 2	Level 1	Level 1
Medium	Level 3 (Hardware)	Level 2 (Hardware)	Level 1	Level 2 (Hardware)

Assurance Level	CA	CMS & CSS	Subscriber	RA
PIV-I Card Authentication	Level 3 (Hardware)	Level 2 (Hardware)	Level 2 (Hardware)	Level 2 (Hardware)
Medium Hardware	Level 3 (Hardware)	Level 2 (Hardware)	Level 2 (Hardware)	Level 2 (Hardware)
High	Level 3 (Hardware)	Level 2 (Hardware)	Level 2 (Hardware)	Level 2 (Hardware)

PIV-I Cards must be issued using card stock that has been tested and approved by the FIPS 201 Evaluation Program and listed on the GSA Approved Products List (APL). Card stock that has been removed from the APL may continue to be issued for no more than one year after GSA approved replacement card stock is available. PIV-I cards issued using the deprecated card stock may continue to be used until the current subscriber certificates expire, unless otherwise notified by the FPKIPA/FPKIMA.

For hardware tokens associated with PIV-I, see Appendix A for additional requirements.

Any pseudo-random numbers used for key generation material must be generated using a FIPS-validated cryptographic module.

6.2.1.1 Custodial Subscriber Key Stores

Custodial Subscriber Key Stores hold keys for a number of Subscriber certificates in one location. When a collection of private keys for Subscriber certificates are held in a single location, there is a higher risk associated with compromise of that cryptographic module than that of a single Subscriber.

Cryptographic modules for Custodial Subscriber Key Stores at the Rudimentary Assurance Level must be no less than FIPS 140 Level 1 (Hardware or Software). For all other levels, the cryptographic module must be no less than FIPS 140 Level 2 Hardware.

In addition, authentication to the Cryptographic Device in order to activate the private key associated with a given certificate requires authentication commensurate with the assurance level of the certificate.

6.2.2 Private Key Multi-Person Control

Use of the FBCA private signing key requires action by multiple persons as set forth in Section 5.2.2 of this CP.

Use of the Entity CA private signing key and CSS private signing key must require action by multiple persons at Medium, Medium Hardware, and High Assurance as set forth in Section 5.2.2 of this CP.

PIV-I Content Signing key activation must require the same multiparty control established for the Entity CA (see Section 5.2.2).

6.2.3 Private Key Escrow

CA private keys are never escrowed.

Human Subscriber key management keys may be escrowed to provide key recovery as described in Section 4.12.1.

Subscriber private signature keys must not be escrowed.

Subscriber private dual use keys must not be escrowed. If a device has a separate key management key certificate, the key management private key may be escrowed.

6.2.4 Private Key Backup

All backups of CA, CSS, and PIV-I Content Signing private signature keys must be accounted for and protected under the same multi-person control as the original signature key. At least one copy of the CA private signature key must be stored off site.

For all other keys, backup, when permitted, must provide security controls consistent with the protection provided by the original cryptographic module. Backed up private signature key(s) must not be exported or stored in plaintext form outside the cryptographic module.

Private Key	Backup
CA all applicable policies	Required
CSS all applicable policies	Optional
PIV-I Content Signing id-fpki-certpcy-pivi-contentSigning	Optional
Hardware Signature and Authentication - id-fpki-certpcy-highAssurance - id id-fpki-certpcy-pivi-cardAuth - id-fpki-certpcy-pivi-hardware	Not Permitted
Hardware Subscriber Key Management - id-fpki-certpcy-mediumHardware - id-fpki-certpcy-mediumHW-CBP	Optional

Hardware Device id-fpki-certpcy-mediumDeviceHardware	Optional
Software Signature and Authentication - id-fpki-certpcy-rudimentaryAssurance - id-fpki-certpcy-basicAssurance - id-fpki-certpcy-mediumAssurance - id-fpki-certpcy-medium-CBP	Optional *
Software Subscriber Key Management - id-fpki-certpcy-rudimentaryAssurance - id-fpki-certpcy-basicAssurance - id-fpki-certpcy-mediumAssurance - id-fpki-certpcy-medium-CBP	Optional
Software Device id-fpki-certpcy-mediumDevice	Optional

* Software Subscriber private signature keys may be backed up or copied, but must be held in the Subscriber's control.

6.2.5 Private Key Archival

CA private signature keys and Subscriber private signature keys must not be archived.

CAs may maintain an archive of escrowed Subscriber private key management keys. Such archives must be protected in accordance with Sections 4.12, 5.1, 5.2, and 6.2.1.

6.2.6 Private Key Transfer into or from a Cryptographic Module

A CA private key must not exist in plain text outside the cryptographic module.

CA, CSS and PIV-I Content Signing private signature keys may be exported from the cryptographic module only to perform CA key backup procedures as described in Section 6.2.4.

If any private key is transported from one cryptographic module to another, the private key must be protected using a FIPS approved algorithm and at a bit strength commensurate with the key being transported. Private keys must never exist in plaintext form outside the cryptographic module boundary.

Private or symmetric keys used to encrypt other private keys for transport must be protected from disclosure.

6.2.7 Private Key Storage on Cryptographic Module

No stipulation beyond that specified in [FIPS-140].

6.2.8 Method of Activating Private Keys

Cryptographic modules must be protected from unauthorized access.

Subscriber private key activation requirements are detailed in the following table:

Mapped Policy	Activation Requirements
id-fpki-certpcy-basicAssurance id-fpki-certpcy-mediumAssurance id-fpki-certpcy-medium-CBP id-fpki-certpcy-mediumHardware id-fpki-certpcy-mediumHW-CBP id-fpki-certpcy-pivi-hardware id-fpki-certpcy-highAssurance	Passphrases, PINs, or biometrics. When passphrases or PINs are used, they must be a minimum of six (6) characters. Entry of activation data must be protected from disclosure (i.e., the data should not be displayed while it is entered).
id-fpki-certpcy-mediumDevice id-fpki-certpcy-mediumDeviceHardware	May be configured to activate the private key without requiring a human sponsor or authorized administrator to authenticate to the cryptographic token. The appropriate physical and logical access controls must be implemented for the device and its cryptographic token.

id-fpki-certpcy-pivi-contentSigning	May be configured to activate the private key without requiring a human sponsor or authorized administrator to authenticate to the cryptographic token. The appropriate physical and logical access controls must be implemented for content signing operations conformant with PIV issuance requirements (see [FIPS 201]). The strength of the security controls must be commensurate with the level of threat in the PIV-I credential issuance system's environment, and must protect the hardware, software, and the cryptographic token and its activation data from compromise.
id-fpki-certpcy-pivi-cardAuth	None.

6.2.9 Method of Deactivating Private Keys

After use, the cryptographic module must be deactivated via a manual logout procedure, or automatically after a period of inactivity as defined in the applicable CPS. CA Hardware cryptographic modules must be physically secured per requirements in Section 5.1 when not in use.

6.2.10 Method of Destroying Private Keys

Individuals in trusted roles must destroy all copies of CA, RA and CSS private signature keys and activation data (e.g., operator card set or tokens) when they are no longer needed. Subscribers either must surrender their cryptographic modules to CA/RA personnel for destruction or destroy their private signature keys when they are no longer needed, or when the certificates to which they correspond expire or are revoked.

6.2.11 Cryptographic Module Rating

See Section 6.2.1.

6.3 OTHER ASPECTS OF KEY MANAGEMENT

6.3.1 Public Key Archival

Public key archival must be in accordance with Section 5.5.

6.3.2 Certificate Operational Periods and Key Usage Periods

A CA private key may be used to sign CRLs and OCSP responder certificates for the entire usage period. All certificates signed by a specific CA key pair must expire before the end of that key pair's usage period.

Key	Private Key	Certificate
Root CA certificate (self-signed)	30 years	30 years
Federal Bridge CA certificate	10 years	10 years
Intermediate/Signing CA certificate	10 years	10 years
Subscriber Authentication	3 years	3 years
Subscriber Signature	3 years	3 years
Subscriber Encryption	Unrestricted	3 years
PIV-I Card Authentication	3 years	3 years
PIV-I Content Signing	3 years	9 years*
Code Signing	3 years	8 years
OCSP Responder	3 years	120 days
Device	3 years	3 years

* Expiration of the Content Signing certificate must be later than the expiration of the Subscriber certificates on the same PIV-I credential.

Subscriber certificates on a PIV-I card must expire no later than the expiration date of the PIV-I hardware token on which they reside.

The validity period of the subscriber certificate must not exceed the routine re-key Identity Requirements as specified in Section 3.3.1.

Practice Note: CA signing key usage is determined in the context of the length of the validity periods of the certificates issued to and by the CA.

6.4 ACTIVATION DATA

6.4.1 Activation Data Generation and Installation

The activation data used to unlock CA or subscriber private keys, in conjunction with any other access control, must have an appropriate level of strength for the keys or data to be protected. If the activation data must be transmitted, it must be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module. Where the CA uses passwords as activation data for the CA signing key, at a minimum the activation data must be changed upon CA re-key.

For Medium Assurance and above, RA and Subscriber activation data may be user-selected. The strength of the activation data must meet or exceed the requirements for authentication mechanisms stipulated for Level 2 in [FIPS 140]. If the activation data must be transmitted, it must be via an appropriately protected channel, and distinct in time and place from the associated cryptographic module.

For PIV-I, in the event activation data must be reset, a successful biometric 1:1 match of the applicant against the biometrics collected in Section 3.2.3.1 is required. This biometric 1:1 match must be conducted by an RA, self-service portal that authenticates the user via the biometric, a trusted agent of the issuer.

6.4.2 Activation Data Protection

Data used to unlock private keys must be protected from disclosure by a combination of cryptographic and physical access control mechanisms. Activation data must be:

- memorized
- biometric in nature, or
- recorded and secured at the level of assurance associated with the activation of the cryptographic module, and must not be stored with the cryptographic module.

The protection mechanism must include a facility to temporarily lock the account, or terminate the application, after a predetermined number of failed login attempts as set forth in the respective CP.

6.4.3 Other Aspects of Activation Data

CAs must define any other aspects of Activation Data in its CPS.

6.5 COMPUTER SECURITY CONTROLS

6.5.1 Specific Computer Security Technical Requirements

For CAs, KEDs, and DDSs the computer security functions listed below are required. These functions may be provided by the operating system, or through a combination of operating system, software, and physical safeguards. The CA and its ancillary parts must include the following functionality (these functions pertain to all system software layers, where applicable):

- authenticate the identity of users before permitting access to the system or applications;
- manage privileges of users to limit users to their assigned roles;
- generate and archive audit records for all transactions; (see Section 5.4)
- enforce domain integrity boundaries for security critical processes;
- require use of cryptography for session communication and database security;
- require self-test security-related CA services;
- require a trusted path for identification of all users;
- provide residual information protection; and
- require recovery from key or system failure.

For CSS, the computer security functions listed below are required (these functions pertain to all system software layers, where applicable):

- authenticate the identity of users before permitting access to the system or applications;
- manage privileges of users to limit users to their assigned roles;
- enforce domain integrity boundaries for security critical processes;
- provide residual information protection; and
- require recovery from key or system failure.

For remote workstations used to administer the CAs, KEDs, and DDSs, the computer security functions listed below are required:

- authenticate the identity of users before permitting access to the system or applications;
- manage privileges of users to limit users to their assigned roles;
- generate and archive audit records for all transactions; (see Section 5.4)
- enforce domain integrity boundaries for security critical processes;
- provide residual information protection; and
- require recovery from system failure.

All communications between any PKI trusted role and the CA must be authenticated and protected from modification.

6.5.2 Computer Security Rating

For the FBCA, not applicable.

Entity CAs must identify any Computer Security Rating requirements.

6.6 LIFE-CYCLE TECHNICAL CONTROLS

6.6.1 System Development Controls

The System Development Controls for CAs (including any remote workstations used to administer the CA) and RAs at the Basic Assurance level and above are as follows:

- Where open source software has been utilized, the applicant must demonstrate that security requirements were achieved through software verification and validation and structured development/life-cycle management.
- Hardware and software used to administer or operate the CA must be procured and shipped in a fashion to reduce the likelihood that any component was tampered with (e.g., by ensuring the equipment was randomly selected at time of purchase).
- Custom hardware and software must be developed in a controlled environment, and the development process must be defined and documented. This requirement does not apply to commercial off-the-shelf hardware or software.
- The CA hardware and software, including all system software layers, must be dedicated to operating and supporting the CA (i.e., the systems and services dedicated to the issuance and management of certificates). There must be no other applications, hardware devices, network connections, or component software installed which are not part of the CA operation, administration, monitoring and security compliance of the system. CA hardware and system software layers may support multiple CAs and their supporting systems, provided all systems have comparable security controls and are dedicated to the support of the CA in compliance of the same CP.
- Proper care must be taken to prevent malicious software from being loaded onto the CA equipment. All applications required to perform the operation of the CA must be obtained from documented sources. Except for Offline CAs, CA and RA hardware and software must be scanned for malicious code on first use and periodically thereafter.
- Hardware and software updates must be purchased or developed in the same manner as original equipment, and be installed by trusted and trained personnel in a defined manner.

6.6.2 Security Management Controls

The configuration of the CA system as well as any modifications and upgrades must be documented and controlled. There must be a mechanism for detecting unauthorized modification to CA software or configuration. The CA software, when first loaded, must be verified as being that supplied from the vendor, with no modifications, and be the version intended for use. The CA must periodically verify the integrity of the software.

The FBCA verifies the integrity of the software when the CA is powered on.

6.6.3 Life Cycle Security Controls

CAs must identify any life cycle security control requirements in the applicable CP.

6.7 NETWORK SECURITY CONTROLS

This section does not apply to offline CAs.

A network guard, firewall, or filtering router must protect network access to CA and KRS equipment. The network guard, firewall, or filtering router must limit services allowed to and from the CA and KRS equipment to those required to perform CA and KRS functions.

Protection of CA and KRS equipment must be provided against known network attacks. All unused network ports and services must be turned off. Any network software present on the CA and KRS equipment must be necessary to the functioning of the CA application.

Any boundary control devices used to protect the local area network on which PKI equipment is hosted must deny all but the necessary services to the PKI equipment.

RAs, CMSs, repositories, CSSs, and remote workstations used to administer the CAs must employ appropriate network security controls. Networking equipment must turn off unused network ports and services. Any network software present must be necessary to the function of the equipment.

Any remote workstation used to administer the CA must use a Virtual Private Network (VPN) to access the CA. The VPN must be configured for mutual authentication, encryption, and integrity. If mutual authentication is shared secret based, the shared secret must be changed at least annually, must be randomly generated, and must have entropy commensurate with the cryptographic strength of certificates issued by the PKI being administered.

The CA must permit remote administration only after successful multi-factor authentication of the Trusted Role at a level of assurance commensurate with that of the CA.

6.8 TIME STAMPING

Asserted times must be accurate to within three minutes. Electronic or manual procedures may be used to maintain system time. Clock adjustments are auditable events, see Section 5.4.1.

7. CERTIFICATE, CRL, AND OCSP PROFILES

7.1 CERTIFICATE PROFILE

PIV-I authentication, card authentication and content signing certificates must conform to the relevant profile worksheets in the [FBCA-PROF].

All other certificates must be compatible with X.509 Certificate and CRL Extensions Profile [FBCA-PROF].

7.1.1 Version Number(s)

Certificates must be of type X.509 v3 (populate version field with integer "2").

7.1.2 Certificate Extensions

For all CAs, use of standard certificate extensions must comply with [RFC 5280].

Certificates issued by the FBCA must comply with [FBCA-PROF]. Certificates issued by Federal Entity CAs operating at High, Medium Hardware, and/or Medium Assurance must comply with [FBCA-PROF].

Entity CAs that issue PIV-I Certificates must comply with relevant worksheets from [FBCA-PROF].

Practice Note: For Entity CAs that issue PIV-I certificates, the associated CSS certificates must also comply with [FBCA-PROF].

CA certificates must not include critical private extensions.

When used in Subscriber certificates, critical private extensions must be interoperable in their intended community of use.

Entity CA and Subscriber certificates may include any extensions as specified by [RFC 5280] in a certificate, but must include those extensions required by this CP. Any optional or additional extensions must not conflict with the applicable certificate and CRL profiles identified in Section 7.1

7.1.3 Algorithm Object Identifiers

Certificates issued by the FBCA and Entity CAs must identify the signature algorithm using one of the following OIDs:

Signature Algorithm	Object Identifier
sha256WithRSAEncryption	{ iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 11 } (1.2.840.113549.1.1.11)
sha384WithRSAEncryption	{ iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 12 } (1.2.840.113549.1.1.12)
sha512WithRSAEncryption	{ iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 13 } (1.2.840.113549.1.1.13)
id-RSASSA-PSS	{ iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 10 } (1.2.840.113549.1.1.10)
ecdsa-with-SHA256	{ iso(1) member-body(2) us(840) ansi-X9-62(10045) signatures(4) ecdsa-with-SHA2 (3) 2 } (1.2.840.10045.4.3.2)
ecdsa-with-SHA384	{ iso(1) member-body(2) us(840) ansi-X9-62(10045) signatures(4) ecdsa-with-SHA2(3) 3 } (1.2.840.10045.4.3.3)
ecdsa-with-SHA512	{ iso(1) member-body(2) us(840) ansi-X9-62(10045) signatures(4) ecdsa-with-SHA2(3) 4 } (1.2.840.10045.4.3.4)

The PSS padding scheme OID is independent of the hash algorithm. The hash algorithm is specified as a parameter (for details, see [PKCS#1]). The following are the approved hash algorithms:

id-sha256	{ joint-iso-itu-t(2) country(16) us(840) organization(1) gov(101) csor(3) nistalgorithm(4) hashalgs(2) 1 } (2.16.840.1.101.3.4.2.1)
id-sha384	{ joint-iso-itu-t(2) country(16) us(840) organization(1) gov(101) csor(3) nistalgorithm(4) hashalgs(2) 2 } (2.16.840.1.101.3.4.2.2)

id-sha512	{ joint-iso-itu-t(2) country(16) us(840) organization(1) gov(101) csor(3) nistalgorithm(4) hashalgs(2) 3 } (2.16.840.1.101.3.4.2.3)
-----------	--

Certificates must use the following OIDs to identify the algorithm associated with the subject key:

Public Key Algorithm	Object Identifier
rsaEncryption	{ iso(1) member-body(2) us(840) rsadsi(113549) pkcs(1) pkcs-1(1) 1 } (1.2.840.113549.1.1.1)
id-ecPublicKey	{ iso(1) member-body(2) us(840) ansi-X9-62(10045) id-publicKeyType(2) 1 } (1.2.840.10045.2.1)

Where non-CA certificates issued on behalf of federal agencies contain an elliptic curve public key, the parameters must be specified as one of the following named curves:

Curve	Object Identifier
ansip256r1	{ iso(1) member-body(2) us(840) 10045 curves(3) prime(1) 7 } (1.2.840.10045.3.1.7)
ansip384r1	{ iso(1) identified-organization(3) certicom(132) curve(0) 34 } (1.3.132.0.34)

For PIV-I, signature algorithms are limited to those identified by [NIST SP 800-78].

7.1.4 Name Forms

Where required as set forth in Section 3.1.1, the subject and issuer fields of the base certificate must be populated with an X.500 Distinguished Name. Distinguished names must be composed of standard attribute types, such as those identified in [RFC 5280].

7.1.5 Name Constraints

CA certificates issued by the FBCA have name constraints asserted that limit the name space of the Entity CAs to that appropriate for their domains.

Entity CAs may assert name constraints in CA certificates.

7.1.6 Certificate Policy Object Identifier

All certificates issued by the FBCA must include a certificate policies extension asserting one or more of the certificate policy OID(s) appropriate to the level of assurance with which it was issued. See Section 1.2 for specific OIDs.

An Entity must not assert the FBCA CP OIDs in any certificates the Entity CA issues, except in the subject Domain field of the *policyMappings* extension of the certifies issued to FBCA establishing an equivalency between an FBCA OID and an OID in the Entity CA's CP.

Entity certificates must assert at least one certificate policy OID as specified in Section 1.2 of the Entity CP in the certificate policies extension.

Certificates issued for PIV-I card authentication or PIV-I content signing must not express any other policy OIDs.

Delegated OCSP Responder certificates must assert all policy OIDs for which they are authoritative.

7.1.7 Usage of Policy Constraints Extension

The CAs may assert policy constraints in CA certificates. When this extension appears, at least one of *requireExplicitPolicy* or *inhibitPolicyMapping* must be present. When present, this extension may be marked critical.

For Subordinate CA certificates *inhibitPolicyMapping*, skip certs must be set to 0. For cross-certificates *inhibitPolicyMapping*, skip certs must be set appropriately. When *requireExplicitPolicy* is included skip certs must be set to 0.

Practice Note: *inhibitPolicyMapping*, skip certs is usually set to 1 in a cross-certificate issued to a Bridge so it can do another cross-certificate mapping to its CA members. A skip certs value of 2 may be required to allow transitive trust if that Bridge issues a cross-certificate to a CA that also allows mapping, e.g., the Federal Common Policy CA also issues cross-certificates with policy mapping. If transitive trust is not the desired behavior other constraints such as name constraints may be required to control appropriate results.

7.1.8 Policy Qualifiers Syntax and Semantics

Certificates issued by the FBCA do not contain policy qualifiers. Certificates issued by Entity PKIs may contain policy qualifiers identified in [RFC 5280].

7.1.9 Processing Semantics for the Critical Certificate Policy Extension

Certificates must contain a non-critical certificate policies extension.

7.1.10 Inhibit Any Policy Extension

The CAs may assert *inhibitAnyPolicy* in CA certificates. When present, this extension may be marked critical. Skip certs must be set to 0.

7.2 CRL PROFILE

7.2.1 Version Number(s)

CAs must issue X.509 version two (2) CRLs.

7.2.2 CRL and CRL Entry Extensions

Detailed CRL profiles addressing the use of each extension are specified in [FBCA-PROF].

7.3 OCSP PROFILE

If implemented, CSS must sign responses using algorithms designated for CRL signing.

All CSSs must accept and return SHA-1 hashes in the CertID and responderID fields. CSS may accept and return additional hash algorithms within the CertID fields. CSSs must not return any response containing a hash algorithm in the CertID that differs from the CertID in the request.

7.3.1 Version Number(s)

CSSs must use OCSP version 1.

7.3.2 OCSP Extensions

Critical OCSP extensions must not be used.

8. COMPLIANCE AUDIT AND OTHER ASSESSMENTS

All Entity CAs are subject to an annual review by the FPKIPA to ensure their policies and operations remain consistent with the policy mappings in the certificate issued to the Entity by the FBCA.

The FPKIMA must have a compliance audit mechanism in place to ensure that the requirements of this CP and the FBCA CPS are being implemented and enforced.

Entity CAs must have a compliance audit mechanism in place to ensure that the requirements of their CP/CPS are being implemented and enforced. The Entity PKI PMA is responsible for ensuring annual audits are conducted for all PKI functions regardless of how or by whom the PKI components are managed and operated.

Federal Agency PKIs must ensure they have appropriate authority to operate.

This CP does not impose a requirement for any particular assessment methodology.

8.1 FREQUENCY OF AUDIT OR ASSESSMENTS

The FPKIMA and Entity PKIs must be subject to a PKI compliance audit at least once per year for High, Medium Hardware, PIV-I Card Authentication, and Medium Assurance, and at least once every two years for Basic Assurance. The audit must include all CAs, as well as CSS, CMS & RAs, and supporting repositories. Where a status server is specified in certificates issued by a CA, the status server must be subject to the same compliance audit requirements as the corresponding CA. For example, if an OCSP server is specified in the authority information access extension in certificates issued by a CA, that server must be reviewed as part of that CA's compliance audit.

The compliance audit of CAs and RAs must be carried out in accordance with the requirements as specified in the *FPKI Annual Review Requirements* document [AUDIT].

There is no audit requirement for CAs and RAs operating at the Rudimentary level of assurance.

The Entity PMAs have the right to require periodic and aperiodic compliance audits or inspections of subordinate CA or RA operations to validate that the subordinate entities are operating in accordance with the security practices and procedures described in their respective CPS. Further, the FPKIPA has the right to require aperiodic compliance audits of Entity PKIs (and, when needed, their subordinate CAs) that interoperate with the FBCA. The FPKIPA must state the reason for any aperiodic compliance audit.

On an annual basis, for each PIV Card Issuer (PCI) configuration used (as defined by the FIPS 201 Evaluation Program), one populated, representative PIV-I card must be submitted to the FIPS 201 Evaluation Program for testing.

8.2 IDENTITY/QUALIFICATIONS OF ASSESSOR

The auditor must demonstrate competence in the field of compliance audits. At the time of the audit, the CA compliance auditor must be thoroughly familiar with the requirements which the applicable CP imposes on the issuance and management of their certificates. The compliance auditor must perform such compliance audits as a regular ongoing business activity.

For the FBCA, in addition to the previous requirements, the auditor must be a Certified Information System Auditor (CISA), IT security specialist, and a PKI subject matter specialist who can offer input regarding acceptable risks, mitigation strategies, and industry best practices. The FPKIMA must identify the compliance auditor for the FBCA.

8.3 ASSESSOR'S RELATIONSHIP TO ASSESSED ENTITY

The compliance auditor either must be a private firm, that is independent from the entity being audited, or it must be sufficiently organizationally separated from that entity to provide an unbiased, independent evaluation. An example of the latter situation may be an Agency inspector general. To ensure independence and objectivity, the compliance auditor may not have served the entity in developing or maintaining the entity's CA Facility or Certification Practices Statement.

The FPKIPA may determine whether a compliance auditor meets this requirement.

8.4 TOPICS COVERED BY ASSESSMENT

The purpose of a compliance audit of a PKI must be to verify that it is operating in accordance with a CPS that meets the requirements of the applicable CP, as well as any MOAs between the PKI and any other PKI. Components other than CAs may be audited fully or by using a representative sample.

If the auditor uses statistical sampling, all PKI components, PKI component managers and operators must be considered in the sample. The samples must vary on an annual basis.

A full compliance audit for the PKI covers all aspects within the scope identified above.

8.5 ACTIONS TAKEN AS A RESULT OF DEFICIENCY

When the compliance auditor finds a discrepancy between how the FBCA is designed or is being operated or maintained, and the requirements of this CP, the MOAs, or the applicable CPS, the following actions must be performed:

- The compliance auditor must document the discrepancy and provide a copy to the FPKIMA;
- The FPKIMA will provide a copy of the discrepancy documentation to the FPKIPA Chair;
- The FPKIMA will report findings and corrective action to the FPKIPA;

- The FPKIMA must determine what further notifications or actions are necessary to meet the requirements of this CP and the MOAs, and then proceed to make such notifications and take such actions without delay.
- Depending upon the nature and severity of the discrepancy, and how quickly it can be corrected, the FPKIPA may direct the FPKIMA to take additional actions as appropriate, including temporarily halting operation of the FBCA.

When the Entity compliance auditor finds a discrepancy between how the Entity CA is designed or is being operated or maintained, and the requirements of the Entity CP, any applicable MOAs, or the applicable CPS, the following actions must be performed:

- The compliance auditor must document the discrepancy;
- The compliance auditor must notify the responsible party promptly;
- The Entity PKI must determine what further notifications or actions are necessary to meet the requirements of the Entity CP, CPS, and any relevant MOA provisions. The Entity PKI must proceed to make such notifications and take such actions without delay.

When the FPKIPA receives a report of audit deficiency from an Entity PKI, the FPKIPA may direct the FPKIMA to take additional actions to protect the level of trust in the infrastructure.

8.6 COMMUNICATION OF RESULTS

On an annual basis, the Entity PKI PMA must submit an annual review package to the FPKIPA. This package must be prepared in accordance with the *FPKI Annual Review Requirements* document and includes an assertion from the Entity PKI PMA that all PKI components have been audited - including any components that may be separately managed and operated. The package must identify the versions of the CP and CPS used in the assessment. Additionally, where necessary, the results must be communicated as set forth in Section 8.5 above.

9. OTHER BUSINESS AND LEGAL MATTERS

9.1 FEES

The FPKIPA reserves the right to charge a fee to each Entity in order to support operations of the FPKI.

9.1.1 Certificate Issuance/Renewal Fees

CAs must make this determination.

9.1.2 Certificate Access Fees

Section 2 of this policy requires that CA certificates be publicly available. CAs must make this determination for access to subscriber certificates.

9.1.3 Revocation or Status Information Access Fee

CAs must not charge additional fees for revoking certificates or access to CRLs and OCSP status information.

9.1.4 Fees for other Services

CAs must make this determination.

9.1.5 Refund Policy

CAs must make this determination.

9.2 FINANCIAL RESPONSIBILITY

This CP contains no limits on the use of any certificates issued by the CAs. Rather, entities acting as Relying Parties must determine what financial limits, if any, they wish to impose for certificates used to complete a transaction.

9.2.1 Insurance Coverage

CAs must make this determination.

9.2.2 Other Assets

CAs must make this determination.

9.2.3 Insurance or Warranty Coverage for End-Entities

CAs must make this determination.

9.3 CONFIDENTIALITY OF BUSINESS INFORMATION

CA information identified in Section 2 not requiring protection must be made publicly available. Public access to organizational information must be determined by the respective organization. FPKIPA access to Entity information will be addressed in the MOA with that Entity.

9.3.1 Scope of Confidential Information

CAs must make this determination.

9.3.2 Information not within the Scope of Confidential Information

CAs must make this determination.

9.3.3 Responsibility to Protect Confidential Information

Confidential business information provided to the FPKI is protected in accordance with the terms of the agreements entered into between the applicable entity and the FPKI.

Each entity PKI is responsible for maintaining the confidentiality of information clearly marked or labeled as confidential that is shared with it. The entity must treat such information with the same degree of care and security as it treats its own confidential information,

9.4 *PRIVACY OF PERSONAL INFORMATION*

9.4.1 Privacy Plan

The FPKIMA must conduct a Privacy Threshold Assessment, and implement and maintain any required Privacy Impact Assessments and Privacy Plans in accordance with the requirements of the Privacy Act of 1974, as amended. The FPKIPA must approve the Privacy Plan.

Entity CAs must make this determination.

9.4.2 Information Treated as Private

The FPKIMA must protect personally identifying information for Entity personnel collected to support cross-certification and MOA requirements from unauthorized disclosure. The contents of the archives maintained by the FPKIMA are not released except as required by law.

For Entity CAs, collection of PII must be limited to the minimum necessary to validate the identity of the subscriber. This may include attributes that correlate identity evidence to authoritative sources. The RA must provide explicit notice to the subscriber regarding the purpose for collecting and maintaining a record of the PII necessary for identity proofing and the consequences for not providing the information. PII collected for identity proofing purposes must not be used for any other purpose.

9.4.3 Information not Deemed Private

Information included in certificates is not subject to protections outlined in Section 9.4.2, but may not be sold to a third party.

9.4.4 Responsibility to Protect Private Information

Sensitive information must be stored securely and may be released only in accordance with other stipulations in Section 9.4.

All information collected as part of the identity proofing process must be protected to ensure confidentiality and integrity. In the event the Entity terminates PKI activities, it must be

responsible for disposing of or destroying sensitive information, including PII, in a secure manner, and maintaining its protection from unauthorized access until destruction.

9.4.5 Notice and Consent to Use Private Information

The FPKIMA is not required to provide any notice or obtain the consent of Entity personnel in order to release private information in accordance with the stipulations of Section 9.4.

9.4.6 Disclosure Pursuant to Judicial/Administrative Process

The FPKIMA does not disclose private information to any third party unless authorized by this Policy, required by law, government rule or regulation, or order of a court of competent jurisdiction. Any request for release of information must be processed according to [41 CFR 105-60.605].

9.4.7 Other Information Disclosure Circumstances

None.

9.5 INTELLECTUAL PROPERTY RIGHTS

CAs must not knowingly violate intellectual property rights held by others.

9.6 REPRESENTATIONS AND WARRANTIES

The obligations described below pertain to the FBCA (and, by implication, the FPKIMA), and to Entity CAs, which either interoperate with the FBCA or are in a trust chain up to a CA that interoperates with the FBCA. The obligations applying to Entity CAs pertain to their activities as issuers of certificates. Further, the obligations focus on Entity CA obligations affecting interoperability with the FBCA. Thus, where the obligations include, for example, a review (or audit) by the FPKIPA or some other body of an Entity's CA operation, the purpose of that review pertains to interoperability using the FBCA, and whether the Entity is complying with the applicable MOA.

9.6.1 CA Representations and Warranties

FBCA certificates are issued and revoked at the sole discretion of the FPKIPA. When the FBCA issues a cross-certificate to a non-federal entity, it does so for the convenience of the U.S. Federal Government. Any review by the FPKIPA of a non-federal entity's certificate policy is for the use of the FPKIPA in determining whether or not interoperability is possible, and if possible, to what extent the non-federal entity's certificate policy maps to the FBCA policy.

A non-federal entity must determine whether that entity's certificate policy meets its legal and policy requirements. Review of a non-federal entity's certificate policy by the FPKIPA is not a substitute for due care and mapping of certificate policies by the non-federal entity.

For PIV-I, Entity CAs must maintain an agreement with Affiliated Organizations concerning the obligations pertaining to authorizing affiliation with Subscribers of PIV-I certificates.

9.6.2 RA Representations and Warranties

An RA that performs registration functions must comply with the stipulations of the applicable policy.

9.6.3 Subscriber Representations and Warranties

For Medium, Medium Hardware, and High Assurance levels, a Subscriber must be required to sign a document containing the requirements the Subscriber must meet respecting protection of the private key and use of the certificate before being issued the certificate. For Basic Assurance level, the Subscriber must be required to acknowledge his or her obligations respecting protection of the private key and use of the certificate before being issued the certificate.

Subscribers of Entity CAs at Basic, Medium, and High Assurance Levels must agree to the following:

- Accurately represent themselves in all communications with the PKI authorities.
- Protect their private keys at all times, in accordance with this policy, as stipulated in their certificate acceptance agreements and local procedures.
- Promptly notify the appropriate CA upon suspicion of loss or compromise of their private keys. Such notification must be made directly or indirectly through mechanisms consistent with the CA's CPS.
- Abide by all the terms, conditions, and restrictions levied on the use of their private keys and certificates.

9.6.4 Relying Party Representations and Warranties

This CP does not specify the steps a relying party should take to determine whether to rely upon a certificate. The relying party decides, pursuant to its own policies, what steps to take.

9.6.5 Representations and Warranties of Affiliated Organizations

Affiliated Organizations must authorize the affiliation of subscribers with the organization, and must inform the Entity CA of any severance of affiliation with any current subscriber.

9.6.6 Representations and Warranties of Other Participants

None.

9.7 DISCLAIMERS OF WARRANTIES

The FPKIMA may not disclaim any responsibilities described in this CP.

9.8 LIMITATIONS OF LIABILITY

The U.S. Government shall not be liable to any party, except as determined pursuant to the [Federal Tort Claims Act (FTCA), 28 U.S.C. 2671-2680], or as determined through a valid express written contract between the Government and another party.

For Entity CAs, no stipulation.

9.9 INDEMNITIES

No stipulation.

9.10 TERM AND TERMINATION

Entity CAs must describe their term and termination requirements as illustrated below.

9.10.1 Term

This CP becomes effective when approved by the FPKIPA. This CP has no specified term.

9.10.2 Termination

Termination of this CP is at the discretion of the FPKIPA.

9.10.3 Effect of Termination and Survival

The requirements of this CP remain in effect through the end of the archive period for the last certificate issued.

9.11 INDIVIDUAL NOTICES AND COMMUNICATIONS WITH PARTICIPANTS

The FPKIPA must establish appropriate procedures for communications with Entity CAs via contracts or memoranda of agreement as applicable.

For Entity CAs, any planned change to the infrastructure that has the potential to affect the FPKI operational environment must be communicated to the FPKIPA at least two weeks prior to implementation. All new artifacts (CA certificates, CRL DP, AIA and/or SIA URLs, etc.) produced as a result of the change must be provided to the FPKIPA within 24 hours following implementation.

For all other communications, no stipulation.

9.12 AMENDMENTS

9.12.1 Procedure for Amendment

The FPKIPA must review this CP at least once every year. Corrections, updates, or suggested changes to this CP must be communicated to every Entity CA. Such communication must include a description of the change, a change justification, and contact information for the person requesting the change.

9.12.2 Notification Mechanism and Period

Proposed changes to this CP must be distributed electronically to FPKIPA members and observers in accordance with the FPKIPA Charter.

9.12.3 Circumstances under which OID must be Changed

OIDs will be changed if the FPKIPA determines that a change in the CP reduces the level of assurance provided.

9.13 DISPUTE RESOLUTION PROVISIONS

Any dispute arising with respect to this policy or certificates issued under this policy shall be resolved by the Parties.

9.14 GOVERNING LAW

The construction, validity, performance, and effect of certificates issued under this CP for all purposes must be governed by United States Federal law (statute, case law or regulation).

For Entity CAs, the construction, validity, performance, and effect of certificates issued under the Entity CP for all purposes must be governed by law (statute, case law or regulation) under which the Entity operates.

Where an inter-governmental dispute occurs, resolution must be according to the terms of the MOA.

9.15 COMPLIANCE WITH APPLICABLE LAW

The FBCA and Entity CAs are required to comply with applicable law.

9.16 MISCELLANEOUS PROVISIONS

9.16.1 Entire Agreement

CAs must make this determination.

9.16.2 Assignment

CAs must make this determination.

9.16.3 Severability

Should it be determined that one section of this CP is incorrect or invalid, the other sections of this CP must remain in effect until the CP is updated. The process for updating this CP is described in Section 9.12.

9.16.4 Enforcement (Attorneys' Fees and Waiver of Rights)

CAs must make this determination.

9.16.5 Force Majeure

CAs must make this determination.

9.17 OTHER PROVISIONS

CAs must make this determination.

APPENDIX A: PIV-INTEROPERABLE SMART CARD DEFINITION

The intent of PIV-I is to enable issuers to issue cards that are technically interoperable with Federal PIV Card readers and applications, and that may be trusted for particular purposes through a decision of the relying Federal Agency. Thus, reliance on PIV-I Cards requires compliance with technical specifications and specific trust elements. This appendix defines the specific requirements of a PIV-I Card. It relies heavily on relevant specifications from the National Institute of Standards and Technology (NIST).

The following requirements must apply to PIV-I Cards:

1. To ensure interoperability with Federal systems, PIV-I Cards must use a smart card platform that is on GSA's FIPS 201 Evaluation Program Approved Product List (APL) and uses the PIV application identifier (AID).
2. PIV-I Cards must conform to [NIST SP 800-73-4³].
3. Only PIV-I Authentication certificates may assert a policy OID cross certified with the PIV-I Hardware policy OID and must conform to the [FBCA-PROF].
4. Digital signature certificates on a PIV-I credential should assert a policy mapped to mediumHardware, and key management certificates on a PIV-I credential should assert a policy mapped to either mediumAssurance or mediumHardware.
5. PIV-I Cards must contain an asymmetric X.509 Certificate for Card Authentication that:
 - a. conforms to [FBCA-PROF];
 - b. conforms to [NIST SP 800-73-4]; and
 - c. is issued under the PIV-I Card Authentication policy.
6. PIV-I Cards must contain an electronic representation (as specified in SP 800-73 and SP 800-76) of the Cardholder Facial Image printed on the card.
7. The X.509 Certificates for Digital Signature and Key Management described in [NIST SP 800-73] are optional for PIV-I Cards.
8. Visual distinction of a PIV-I Card from that of a Federal PIV Card must ensure no suggestion of attempting to create a fraudulent Federal PIV Card. Examples of allowable visual distinction includes (but is not limited to):

³ Special attention should be paid to UUID requirements for PIV-I.

- a. Printing a phrase such as PIV-Interoperable, [Company Credential],[Organization], Local Access Only, or some other phrase that makes it clear this is not a PIV on the front of the card
- b. Printing the card horizontal rather than in portrait mode,
- c. Using a colored background

For non-Federally issued PIV-I, images or logos on a PIV-I Card must not be placed entirely within Zone 11F, *Agency Seal*, as defined by [FIPS 201].

9. The PIV-I Card physical topography must include, at a minimum, the following items on the front of the card:
 - a. Cardholder facial image;
 - b. Cardholder full name;
 - c. Organizational Affiliation, if exists; otherwise, the issuer of the card; and
 - d. Card expiration date.
10. PIV-I Cards must have an expiration date not to exceed 6 years of issuance.
11. Expiration of the PIV-I Card should not be later than expiration of PIV-I Content Signing certificate on the card.
12. The digital signature certificate that is used to sign objects on the PIV-I Card (e.g., CHUID, Security Object) must contain a policy OID that has been mapped to the FBCA PIV-I Content Signing policy OID. The PIV-I Content Signing certificate must conform to [FBCA-PROF].
13. The PIV-I Content Signing certificate and corresponding private key must be managed within a trusted Card Management System as defined by Appendix B.
14. At issuance, the RA must activate and release the PIV-I Card to the subscriber only after a successful 1:1 biometric match of the applicant against the biometrics collected in Section 3.2.3.1.
15. PIV-I Cards may support card activation by the card management system to support card personalization and post-issuance card update. To activate the card for personalization or update, the card management system must perform a challenge response protocol using cryptographic keys stored on the card in accordance with [NIST SP 800-73-4]. When cards are personalized, card management keys must be set to be specific to each PIV-I Card. That is, each PIV-I Card must contain a unique card management key. Card management keys must meet the algorithm and key size requirements stated in Special Publication 800-78, Cryptographic Algorithms and Key Sizes for Personal Identity Verification. [NIST SP 800-78-4]

APPENDIX B: CARD MANAGEMENT SYSTEM REQUIREMENTS

PIV-I Cards are issued and managed through information systems called Card Management Systems (CMSs). The complexity and use of these trusted systems may vary. Nevertheless, Entity CAs have a responsibility to ensure a certain level of security from the CMSs that manage the token on which their certificates reside, and to which they issue certificates for the purpose of signing PIV-I Cards. This appendix provides additional requirements to those found above that apply to CMSs that are trusted under this Certificate Policy.

The Card Management Master Key must be maintained in a FIPS 140-2 Level 2 Cryptographic Module and conform to [NIST SP 800-78-4] requirements. Diversification operations must also occur on the Hardware Security Module (HSM). Use of these keys requires PIV-I Hardware or commensurate. Activation of the Card Management Master Key must require strong authentication of Trusted Roles. Card management must be configured such that only the authorized CMS can manage issued cards.

The PIV-I identity proofing, registration and issuance process must adhere to the principle of separation of duties to ensure that no single individual has the capability to issue a PIV-I credential without the cooperation of another authorized person.

Individual personnel must be specifically designated to the four Trusted Roles defined in Section 5.2.1. Trusted Role eligibility and Rules for separation of duties follow the requirements for Medium assurance in Section 5.

All personnel who perform duties with respect to the operation of the CMS must receive comprehensive training. Any significant change to CMS operations must have a training (awareness) plan, and the execution of such plan must be documented.

Audit log files must be generated for all events relating to the security of the CMS must be treated the same as those generated by the CA (see Sections 5.4 and 5.5).

A formal configuration management methodology must be used for installation and ongoing maintenance of the CMS. Any modifications and upgrades to the CMS must be documented and controlled. There must be a mechanism for detecting unauthorized modification to the CMS.

The CMS must have document incident handling procedures that are approved by the head of the organization responsible for operating the CMS. If the CMS is compromised, all certificates issued to the CMS must be revoked, if applicable. The damage caused by the CMS compromise must be assessed and all Subscriber certificates that may have been compromised must be revoked, and Subscribers must be notified of such revocation. The CMS must be re-established.

All Trusted Roles who operate a CMS must be allowed access only when authenticated using a method commensurate with PIV-I Hardware.

The computer security functions listed below are required for the CMS:

- authenticate the identity of users before permitting access to the system or applications;
- manage privileges of users to limit users to their assigned roles;
- generate and archive audit records for all transactions; (see Section 5.4)
- enforce domain integrity boundaries for security critical processes; and
- support recovery from key or system failure.

APPENDIX C: IN-PERSON ANTECEDENT

This Appendix describes the baseline requirements for an in-person antecedent identity proofing event. An Antecedent event is an in-person proofing event that occurred previously and may suffice as meeting the in-person identity proofing requirements for a new certificate. The requirement for antecedent is identical to in-person identity proofing in Section 3.2 with the exception of using an historical in-person ID proofing event, and reliance on an on-going relationship. Hence, a proposed antecedent process must

1. meet the thoroughness (rigor) of the in-person event,
2. provide supporting ID proofing artifacts or substantiate the applicant through an existing relationship, and
3. bind the individual to the asserted identity.

The Antecedent process may be appropriate when the applicant has no reasonable access to a Registration Authority or other Enrollment facility.

The Antecedent process requires that the applicant – an employee, member, or associate – has an on-going relationship with the Sponsor and that an equivalent in-person identity proofing event was conducted with the Sponsor on some previous date. The Sponsor must attest to the validity of the individual's claimed identity through this existing relationship and provide details concerning the antecedent identity proofing event, including the date of the event, unique applicant identity information and existing artifacts from the event, if any, to the RA.

The following outlines specific requirements for the antecedent identity proofing and credential issuance process.

1. Identity Proofing Relationships

- The Sponsor of the applicant must have a contractual relationship with the Entity PKI.
- The Sponsor must have an established relationship with the applicant. The relationship must be sufficient to enable the RA to, with a high degree of certainty, verify that the person seeking the PKI certificate is the same person that was identity proofed.
- The Sponsor's application must contain a description of the relationship with the applicant describing the initial identity proofing or qualifications and the on-going relationship.

2. Antecedent in-person identity proofing event

- The Applicant must have provided a National Government-issued Picture I.D., or two Non- National Government I.D.s, one of which was a photo I.D. (e.g., Driver's License) during the antecedent identity proofing event. The identity of the entity providing confirmation of the antecedent identity proofing process must be captured in an auditable record.

3. Registration Authority (RA)

The RA must base its decision concerning the validity of the applicant's claimed identity on the information provided via the Antecedent identity proofing process and verification that the applicant is the same individual.

- The RA must record the date of the antecedent in-person identity proofing event as provided by the Sponsor.
- The RA must obtain the historical artifacts from the Antecedent event, if any.
- The RA must be able to verify the applicant matches the individual who participated in the Antecedent proofing process.

4. Information source requirements.

- The Antecedent process must ensure that all data received by the RA from the Sponsor is validated, protected, and securely exchanged.
- All participants must store and exchange private information in a confidential and tamper evident manner protected from unauthorized access.

5. Binding the certificate request to the identity.

The process to bind the claimed identity to the specific certificate request must provide commensurate levels of assurance with the certificate being issued.

- A Sponsor for the applicant must provide the Entity PKI with initial contact information, (e.g., name, email address, phone number, sponsoring organization).
- The PKI must use the Sponsor provided information to contact the applicant.

APPENDIX D: REFERENCES

ABADSG	American Bar Association Digital Signature Guidelines http://itlaw.wikia.com/wiki/American_Bar_Association_(ABA)_Digital_Signature_Guidelines
APL	GSA Approved Products List (APL) https://www.idmanagement.gov/buy/#products
AUDIT	FPKI Annual Review Requirements https://www.idmanagement.gov/docs/fpki-annual-review-requirements.pdf
BRIDGE PROCESS	Federal Public Key Infrastructure Bridge Application Process Overview https://www.idmanagement.gov/docs/fpki-bridge-app-process.pdf
COMMON	X.509 Certificate Policy for the U.S. Federal PKI Common Policy Framework https://www.idmanagement.gov/docs/fpki-x509-cert-policy-common.pdf
COMMON-PROF	Common Policy X.509 Certificate and Certificate Revocation List (CRL) Profiles https://www.idmanagement.gov/docs/fpki-x509-cert-profile-common.pdf
Conformance Criteria	Conformance Criteria for NIST SP 800-63A Enrollment and Identity Proofing https://www.nist.gov/system/files/documents/2020/07/02/800-63A%20Conformance%20Criteria_0620.pdf
Executive Order 12968	Executive Order 12968 - Access to Classified Information https://www.govinfo.gov/content/pkg/FR-1995-08-07/pdf/95-19654.pdf
FBCA-PROF	Federal Bridge Certification Authority (FBCA) X.509 Certificate and CRL Extensions Profile https://www.idmanagement.gov/docs/fpki-x509-cert-profiles-fbca.pdf
FIPS 140	Security Requirements for Cryptographic Modules, FIPS 140-3. https://csrc.nist.gov/publications/detail/fips/140/3/final
FIPS 201	Personal Identity Verification (PIV) of Federal Employees and Contractors, FIPS 201 https://csrc.nist.gov/publications/detail/fips/201/3/final
ITMRA	40 U.S.C. 1452, Information Technology Management Reform Act of 1996.

	https://govinfo.library.unt.edu/npr/library/misc/itref.html
PACS	<i>Technical Implementation Guidance: Smart Card Enabled Physical Access Control Systems</i> , Version 2.3, The Government Smart Card Interagency Advisory Board's Physical Security Interagency Interoperability Working Group https://www.idmanagement.gov/docs/pacs-tig-scepacs.pdf
PIV-I Issuers	Personal Identity Verification Interoperability for Issuers https://www.idmanagement.gov/docs/fpki-pivi-for-issuers.pdf
PKCS#1	Public-Key Cryptography Standards (PKCS) #1: RSA Cryptography Specifications https://www.ietf.org/rfc/rfc3447.txt
PKCS#12	PKCS #12: Personal Information Exchange Syntax https://www.ietf.org/rfc/rfc7290.txt
RFC 2585	Internet X.509 Public Key Infrastructure: Operational Protocols: FTP and HTTP https://www.ietf.org/rfc/rfc2585.txt
RFC 3647	Certificate Policy and Certification Practices Framework https://www.ietf.org/rfc/rfc3647.txt
RFC 4122	A Universally Unique IDentifier (UUID) URN Namespace https://www.ietf.org/rfc/rfc4122.txt
RFC 5280	Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. https://www.ietf.org/rfc/rfc5280.txt
RFC 5322	Internet Message Format https://www.ietf.org/rfc/rfc5322.txt
RFC 6960	X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP. https://www.ietf.org/rfc/rfc6960.txt
RFC 8551	Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 4.0 Message Specification https://www.ietf.org/rfc/rfc8551.txt
SP 800-37	Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach, NIST Special

	Publication 800-37 https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final
SP 800-56A	Recommendation for Pair-Wise Key Establishment Schemes Using Discrete Logarithm Cryptography, NIST Special Publication 800-56A https://csrc.nist.gov/publications/detail/sp/800-56a/rev-3/final
SP 800-57	Recommendation for Key Management: Part 1- General, NIST Special Publication 800-57 Part 1 https://csrc.nist.gov/publications/detail/sp/800-57-part-1/rev-5/final
SP 800-63	Digital Identity Guidelines https://csrc.nist.gov/publications/detail/sp/800-63/3/final
SP 800-73	Interfaces for Personal Identity Verification https://csrc.nist.gov/publications/detail/sp/800-73/4/final
SP 800-76	Biometric Specifications for Personal Identity Verification, NIST Special Publication 800-76 https://csrc.nist.gov/publications/detail/sp/800-76/2/final
SP 800-78	Cryptographic Algorithms and Key Sizes for Personal Identity Verification, NIST Special Publication 800-78 https://csrc.nist.gov/publications/detail/sp/800-78/4/final
SP 800-79	Guidelines for the Accreditation of Personal Identity Verification Card Issuers, NIST Special Publication 800-79 https://csrc.nist.gov/publications/detail/sp/800-79/2/final
SP 800-89	Recommendation for Obtaining Assurances for Digital Signature Applications, NIST Special Publication 800-89 https://csrc.nist.gov/publications/detail/sp/800-89/final
SP 800-157	Guidelines for Derived Personal Identity Verification (PIV) Credentials, NIST Special Publication 800-157 https://csrc.nist.gov/publications/detail/sp/800-157/final
X.509	ITU-T Recommendation X.509 (2005) ISO/IEC 9594-8:2005, Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks.

APPENDIX E: ACRONYMS AND ABBREVIATIONS

AES	Advanced Encryption Standard
AIA	Authority Information Access
AID	Application Identifier
APL	Approved Products List
CA	Certification Authority
CHUID	Cardholder Unique Identifier
CIO	Chief Information Officer
CISA	Certified Information System Auditor
CISO	Chief Information Security Officer
CMS	Card Management System
CN	Common Name
COMSEC	Communications Security
CP	Certificate Policy
CPS	Certification Practice Statement
CRL	Certificate Revocation List
CSOR	Computer Security Object Registry
CSS	Certificate Status Server
DDS	Data Decryption Server
DN	Distinguished Name
DNS	Domain Name System
DSA	Digital Signature Algorithm

DSS	Digital Signature Standard
ECC	Elliptic Curve Cryptography
FBCA	Federal Bridge Certification Authority
FIPS	Federal Information Processing Standard
FPKIMA	Federal Public Key Infrastructure Management Authority
FPKI	Federal Public Key Infrastructure
FPKIPA	Federal PKI Policy Authority
FPKIMA	Federal PKI Management Authority
FTCA	Federal Tort Claims Act
GSA	General Services Administration
HTTP	Hypertext Transfer Protocol
HSM	Hardware Security Module
IANA	Internet Assigned Numbers Authority
IDMS	Identity Management System
ISO	International Organization for Standardization
ISSO	Information Systems Security Officer
ITAR	International Traffic in Arms Regulation
ITU	International Telecommunications Union
ITU-T	International Telecommunications Union – Telecommunications Sector
KED	Key Escrow Database
KRA	Key Recovery Agent
KRO	Key Recovery Officer
KRP	Key Recovery Policy

KRPS	Key Recovery Practice Statement
LDAP	Lightweight Directory Access Protocol
MOA	Memorandum of Agreement
NACI	National Agency Check with Written Inquiries
NACLC	National Agency Check with Law Enforcement Check
NIST	National Institute of Standards and Technology
NSA	National Security Agency
OCSP	Online Certificate Status Protocol
OID	Object Identifier
PIN	Personal Identification Number
PIV-I	Personal Identity Verification – Interoperable
PKCS	Public Key Certificate Standard
PKI	Public Key Infrastructure
PKIX	Public Key Infrastructure X.509
POC	Point of Contact
RA	Registration Authority
RDN	Relative Distinguished Name
RFC	Request For Comments
RSA	Rivest-Shamir-Adleman (encryption algorithm)
SHA-1	Secure Hash Algorithm, Version 1
SIA	Subject Information Access
SP	Special Publication
TLD	Top Level Domain

TLS	Transport Layer Security
UPN	User Principal Name
UPS	Uninterrupted Power Supply
URI	Universal Resource Identifier
URL	Uniform Resource Locator
U.S.C.	United States Code
UUID	Universally Unique Identifier (defined by RFC 4122)
VPN	Virtual Private Network
WWW	World Wide Web

APPENDIX F: GLOSSARY

Access	Ability to make use of any information system (IS) resource.
Access Control	Process of granting access to information system resources only to authorized users, programs, processes, or other systems.
Accreditation	Formal declaration by a Designated Approving Authority that an Information System is approved to operate in a particular security mode using a prescribed set of safeguards at an acceptable level of risk.
Activation Data	Private data, other than keys, that are required to access cryptographic modules (i.e., unlock private keys for signing or decryption events).
Affiliated Organization	Organizations that authorize affiliation with Subscribers of PIV-I certificates.
Applicant	The Subscriber is sometimes also called an "Applicant" after applying to a certification authority for a certificate, but before the certificate issuance procedure is completed. [ABADSG footnote 32]
Archive	A collection of documents created or gathered by the CA and selected for long-term preservation as evidence of their activities.
Audit	Independent review and examination of records and activities to assess the adequacy of system controls, to ensure compliance with established policies and operational procedures, and to recommend necessary changes in controls, policies, or procedures.
Audit Log	A chronological record of information system activities, including records of system accesses and operations performed in a given period.
Audit Record	An individual entry in an audit log related to an audited event.
Authenticate	To confirm the identity of an entity when that identity is presented.
Authentication	Security measure designed to establish the validity of a transmission, message, or originator, or a means of verifying an individual's authorization to receive specific categories of information.

Backup	Copy of files and programs made to facilitate recovery if necessary.
Binding	Process of associating two related elements of information.
Biometric	A physical or behavioral characteristic of a human being.
Certificate	A digital representation of information which at least (1) identifies the certification authority issuing it, (2) names or identifies its Subscriber, (3) contains the Subscriber's public key, (4) identifies its operational period, and (5) is digitally signed by the certification authority issuing it. [ABADSG]. As used in this CP, the term “certificate” refers to X.509 certificates that expressly reference the OID of this CP in the certificatePolicies extension.
Certification Authority (CA)	An authority trusted by one or more users to issue and manage X.509 public key certificates and CRLs.
CA Facility	The collection of equipment, personnel, procedures and structures that are used by a certification authority to perform certificate issuance and revocation.
Certificate Management Authority (CMA)	A Certification Authority or a Registration Authority.
Certification Authority Software	Key management and cryptographic software used to manage certificates issued to Subscribers.
Certificate Policy (CP)	A certificate policy is a specialized form of administrative policy tuned to electronic transactions performed during certificate management. A certificate policy addresses all aspects associated with the generation, production, distribution, accounting, compromise recovery and administration of digital certificates. Indirectly, a certificate policy can also govern the transactions conducted using a communications system protected by a certificate-based security system. By controlling critical certificate extensions, such policies and associated enforcement technology can support provision of the security services required by particular applications.
Certification Practice Statement (CPS)	A statement of the practices that a CA employs in issuing, suspending, revoking, and renewing certificates and providing access to them, in accordance with specific requirements (i.e., requirements specified in this CP, or requirements specified in a contract for services).

Certificate-Related Information	Information, such as a Subscriber's postal address, that is not included in a certificate. May be used by a CA managing certificates.
Certificate Revocation List (CRL)	A list maintained by a certification authority of the certificates that it has issued that are revoked prior to their stated expiration date.
Certificate Status Server (CSS)	A trusted entity that provides on-line verification to a relying party of a subject certificate's revocation status.
Client (application)	A system entity, usually a computer process acting on behalf of a human user that makes use of a service provided by a server.
Compromise	Disclosure of information to unauthorized persons, or a violation of the security policy of a system in which unauthorized intentional or unintentional disclosure, modification, destruction, or loss of an object may have occurred.
Computer Security Objects Registry (CSOR)	Computer Security Objects Registry operated by the National Institute of Standards and Technology.
Confidentiality	Assurance that information is not disclosed to unauthorized entities or processes.
Containerization	A form of operating system virtualization, through which applications are run in isolated user spaces called containers, all using the same shared operating system (OS).
Cross-Certificate	A certificate used to establish a trust relationship between two certification authorities.
Cryptographic Module	The set of hardware, software, firmware, or some combination thereof that implements cryptographic logic or processes, including cryptographic algorithms, and is contained within the cryptographic boundary of the module. [FIPS 140]
Custodial Subscriber Key Stores	Custodial Subscriber Key Stores hold keys for a number of Subscriber certificates in one location.
Data Decryption Server	An automated system that obtains subscriber private keys from the Key Escrow Database or another Data Decryption Server in order to support decryption of data entering and leaving the Enterprise. An example of such data is e-mail.
Data Integrity	Assurance that the data are unchanged from creation to reception.

Device	A non-person entity, i.e., a piece of hardware or a software application
Digital Signature	The result of a transformation of a message by means of a cryptographic system using keys such that a relying party can determine: (1) whether the transformation was created using the private key that corresponds to the public key in the signer's digital certificate; and (2) whether the message has been altered since the transformation was made.
Encryption Certificate	A certificate containing a public key that is used to encrypt electronic messages, files, documents, or data transmissions, or to establish or exchange a session key for these same purposes.
Entity	For the purposes of this document, "Entity" refers to an organization, corporation, community of interest, or government agency with operational control of a CA.
Entity CA	A CA that acts on behalf of an Entity, and is under the operational control of an Entity. The Entity may be an organization, corporation, or community of interest. For the Federal Government, an Entity may be any department, subordinate element of a department, or independent organizational entity that is statutorily or constitutionally recognized as being part of the Federal Government.
FPKI Management Authority (FPKIMA)	The Federal Public Key Infrastructure Management Authority is the organization responsible for operating the Federal Common Policy Certification Authority.
Federal Public Key Infrastructure Policy Authority (FPKIPA)	The FPKIPA is a Federal Government body responsible for setting, implementing, and administering policy decisions regarding the Federal PKI Architecture.
Firewall	Gateway that limits access between networks in accordance with local security policy.
Hypervisor	Computer software, firmware or hardware that creates and runs virtual machines. A hypervisor uses native execution to share and manage hardware, allowing for multiple environments which are isolated from one another, yet exist on the same physical machine. Also known as an isolation kernel or virtual machine monitor.
In-Person Antecedent	An Antecedent event is an in-person proofing event that occurred previously and may suffice as meeting the in-person identity proofing requirements.

Information Systems Security Officer (ISSO)	Person responsible to the Designated Approving Authority for ensuring the security of an information system throughout its life-cycle, from design through disposal.
Integrity	Protection against unauthorized modification or destruction of information. A state in which information has remained unaltered from the point it was produced by a source, during transmission, storage, and eventual receipt by the destination.
Intellectual Property	Useful artistic, technical, and/or industrial information, knowledge or ideas that convey ownership and control of tangible or virtual usage and/or representation.
Intermediate CA	A CA that is subordinate to another CA, and has a CA subordinate to itself.
Key Escrow	A deposit of the private key of a Subscriber and other pertinent information pursuant to an escrow agreement or similar contract binding upon the Subscriber, the terms of which require one or more agents to hold the Subscriber's private key for the benefit of the Subscriber, an employer, or other party, upon provisions set forth in the agreement. [adapted from ABADSG, "Commercial key escrow service"]
Key Escrow Database (KED)	The function, system, or subsystem that maintains the key escrow repository and responds to key escrow and key recovery requests from one or more Key Recovery Agents, as specified by this policy.
Key Exchange	The process of exchanging public keys in order to establish secure communications.
Key Generation Material	Random numbers, pseudo-random numbers, and cryptographic parameters used in generating cryptographic keys.
Key Pair	Two mathematically related keys having the properties that (1) one (public) key can be used to encrypt a message that can only be decrypted using the other (private) key, and (2) even knowing the public key, it is computationally infeasible to discover the private key.
Key Recovery	Production of a copy of an escrowed key and delivery of that key to an authorized requestor.

Key Recovery Agent (KRA)	An individual authorized to interface with the key escrow database in conjunction with one or more other key recovery agents) to cause the key escrow database to carry out key recovery requests, as specified by this policy.
Key Recovery Official (KRO)	An individual authorized to authenticate and submit key recovery requests to the Key Recovery Agent on behalf of requestor, as specified by this policy.
Key Recovery Policy (KRP)	A key recovery policy is a specialized form of administrative policy tuned to the protection and recovery of key management private keys (i.e., decryption keys) held in escrow. A key recovery policy addresses all aspects associated with the storage and recovery of key management certificates.
Key Recovery Practices Statement (KRPS)	A statement of the practices that a Key Recovery System employs in protecting and recovering key management private keys, in accordance with specific requirements (i.e., requirements specified in the KRP).
Memorandum of Agreement (MOA)	Agreement between the FPKIPA and an Entity allowing interoperability between the Entity CA and the FBCA.
Modification (of a certificate)	The act or process by which data items bound in an existing public key certificate are changed by issuing a new certificate.
Mutual Authentication	Occurs when parties at both ends of a communication activity authenticate each other (see authentication).
National Security System	Any telecommunications or information system operated by the United States Government, the function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions, but does not include a system that is to be used for routine administrative and business applications (including payroll, finance, logistics, and personnel management applications). [ITMRA]
Network Guard	An enclave boundary protection device that controls access between a local area network that an enterprise system has a requirement to protect, and an external network that is outside the control of the enterprise system, with a high degree of assurance.

Non-Repudiation	Assurance that the sender is provided with proof of delivery and that the recipient is provided with proof of the sender's identity so that neither can later deny having processed the data. Technical non-repudiation refers to the assurance a relying party has that if a public key is used to validate a digital signature, that signature had to have been made by the corresponding private signature key.
Object Identifier (OID)	A specialized formatted number that is registered with an internationally recognized standards organization, the unique alphanumeric/numeric identifier registered under the ISO registration standard to reference a specific object or object class. In the Federal PKI, OIDS are used to uniquely identify certificate policies and cryptographic algorithms.
Offline CA	An offline certification authority is a certification authority isolated from network access, and is often kept in a powered-down state.
Out-of-Band	Communication between parties utilizing a means or method that differs from the current method of communication (e.g., one party uses U.S. Postal Service mail to communicate with another party where current communication is occurring on-line).
Physically Isolated Network	A network that is not connected to entities or systems outside a physically controlled space.
PKI Sponsor	Fills the role of a Subscriber for non-human system components that are named as public key certificate subjects, and is responsible for meeting the obligations of Subscribers as defined throughout this CP.
Policy Management Authority (PMA)	The individual or group that is responsible for the creation and maintenance of Certificate Policies and Certification Practice Statements, and for ensuring that all Entity PKI components (e.g., CAs, CSSs, Card Management Systems, RAs) are audited and operated in compliance with the entity PKI CP. The PMA evaluates non-domain policies for acceptance within the domain, and generally oversees and manages the PKI certificate policies. For the Common Policy, the PMA is the FPKIPA.
Privacy	Restricting access to Subscriber or relying party information in accordance with federal law.
Private Key	(1) The key of a signature key pair used to create a digital signature. (2) The key of an encryption key pair that is used to decrypt confidential information. In both cases, this key must be kept secret.

Public Key	(1) The key of a signature key pair used to validate a digital signature. (2) The key of an encryption key pair that is used to encrypt confidential information. In both cases, this key is normally made publicly available in the form of a digital certificate.
Public Key Infrastructure (PKI)	A set of policies, processes, server platforms, software, and workstations used for the purpose of administering certificates and public/private key pairs, including the ability to issue, maintain, and revoke public key certificates.
Registration Authority (RA)	An entity that is responsible for identification and authentication of certificate subjects, but that does not sign or issue certificates (i.e., a Registration Authority is delegated certain tasks on behalf of an authorized CA).
Re-key (a certificate)	To change the value of a cryptographic key that is being used in a cryptographic system application; this normally entails issuing a new certificate that contains the new public key.
Relying Party	A person or entity who has received information that includes a certificate and a digital signature verifiable with reference to a public key listed in the certificate, and is in a position to rely on them.
Remote Workstation	In the context of FPKI, “remote workstation” refers to a system used to access either the system hosting the CA or the CA itself through external networks for maintenance and administration. Note: Reference Section 6.6.1 for additional technical controls required of remote workstations. This term does not refer to consoles within the CA’s security perimeter or to Registration Authority workstations.
Renew (a certificate)	The act or process of extending the validity of the data binding asserted by a public key certificate by issuing a new certificate.
Repository	A system containing data relating to certificates or revocation data as specified in this CP. May refer to a directory, web server, or server which only hosts pre-generated OCSP responses.
Revoke a Certificate	To prematurely end the operational period of a certificate effective at a specific date and time.
Risk	An expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.

Root CA	In a hierarchical PKI, the CA whose public key serves as the most trusted datum (i.e., the beginning of trust paths) for a security domain.
Server	A system entity that provides a service in response to requests from clients.
Signature Certificate	A public key certificate that contains a public key intended for verifying digital signatures rather than encrypting data or performing any other cryptographic functions.
Structural Container	An organizational unit attribute included in a distinguished name solely to support local directory requirements, such as differentiation between Human Subscribers and devices.
Subordinate CA	In a hierarchical PKI, a CA whose certificate signature key is certified by another CA, and whose activities are constrained by that other CA. (See superior CA).
Subscriber	A Subscriber is an entity that (1) is the subject named or identified in a certificate issued to that entity, (2) holds a private key that corresponds to the public key listed in the certificate, and (3) does not itself issue certificates to another party. This includes, but is not limited to, an individual, an application or network device.
Superior CA	In a hierarchical PKI, a CA that has certified the certificate signature key of another CA, and that constrains the activities of that CA. (See subordinate CA).
Supervised Remote Identity Proofing	A remote identity proofing process that employs physical, technical and procedural measures that provide sufficient confidence that the remote session can be considered equivalent to a physical, in-person identity proofing process. Supervised Remote Identity Proofing must meet the criteria specified in NIST SP 800-63A Section 5.3.3 and the related [Conformance Criteria] for NIST SP 800-63A Enrollment and Identity Proofing; and must have the capacity to capture an approved biometric.
System Software Layer	A layer of software that manages lower layer hardware and software resources and provides services through well-defined interfaces to the higher layers of software. Examples of system software layers are virtual machines, hypervisors, operating systems, and any containerized architectures.

Threat	Any circumstance or event with the potential to cause harm to an information system in the form of destruction, disclosure, adverse modification of data, and/or denial of service.
Trust List	Collection of Trusted Certificates used by relying parties to authenticate other certificates.
Trusted Agent	Entity authorized to act as a representative of a CA in confirming Subscriber identification during the registration process. Trusted agents do not have automated interfaces with certification authorities.
Trusted Certificate	A certificate that is trusted by the relying party on the basis of secure and authenticated delivery. The public keys included in trusted certificates are used to start certification paths. Also known as a "trust anchor".
Two-Person Control	Continuous surveillance and control of positive control material at all times by a minimum of two authorized individuals, each capable of detecting incorrect and/or unauthorized procedures with respect to the task being performed and each familiar with established security and safety requirements.
Zeroize	A method of erasing electronically stored data by altering the contents of the data storage so as to prevent the recovery of the data. [FIPS 140]